

Documentación de sistema

Todos los documentos en un solo archivo

Versión analizada: **0.1.1+2**

Commit: **a7ebf2c**

Fecha del documento: **2026-08-27**

Documento generado desde el Markdown de **docs/system-documentation/** con **tool/build_system_documentation_pdf.py**. El Markdown es la fuente: no editar este PDF.

Contenido

- 1. Documentación de sistema · RootCause QR Inspector
- 2. 01 · Descripción general del sistema
- 3. 02 · Instalación y ejecución
- 4. 03 · Arquitectura
- 5. 04 · Mapa completo del código
- 6. 05 · Referencia técnica
- 7. 06 · Explicación profunda del código
- 8. 07 · Base de datos
- 9. 08 · Flujo de datos
- 10. 09 · APIs e integraciones
- 11. 10 · Configuración
- 12. 11 · Seguridad
- 13. 12 · Pruebas y calidad
- 14. 13 · Despliegue y operación
- 15. 14 · Solución de problemas
- 16. 15 · Riesgos y deuda técnica
- 17. 16 · Glosario
- 18. 17 · Resumen ejecutivo
- 19. 18 · Guía para un nuevo desarrollador
- 20. 19 · Matriz de trazabilidad

Documentación de sistema · RootCause QR Inspector

Portada e índice de la documentación técnica, funcional, arquitectónica y operativa del repositorio. Se escribió recorriendo el código fuente completo, no resumiendo la documentación existente: cada afirmación apunta a un archivo, una función, una prueba o un comando concreto de este repositorio.

El sistema en una frase

RootCause QR Inspector es una **aplicación móvil Flutter que inspecciona códigos QR y de barras en el propio dispositivo**, explica qué observó antes de permitir cualquier acción y permite exportar esa observación como evidencia verificable. No consulta ningún servidor.

Para quién es esta documentación

Perfil	Empieza por	Después
Persona no técnica	Descripción general	Resumen ejecutivo
Desarrollador que se incorpora	Guía para nuevos desarrolladores	Instalación → Arquitectura → Mapa del código
Desarrollador con experiencia	Referencia técnica	Explicación profunda
Auditor técnico o de seguridad	Arquitectura	Seguridad → Riesgos y deuda técnica → Trazabilidad
Operación y soporte	Despliegue y operación	Solución de problemas
Otro agente de IA	Mapa del código	Referencia técnica + Trazabilidad

Tabla de contenidos

#	Documento	Contenido	Estado
01	Descripción general del sistema	Qué es, qué problema resuelve, actores, flujo, tecnologías y límites	Completo
02	Instalación y ejecución	Requisitos, dependencias, generación de plataformas, ejecución y pruebas	Completo
03	Arquitectura	Capas, patrones, diagramas, estado, errores, persistencia y seguridad	Completo
04	Mapa completo del código	Inventario jerárquico de directorios, archivos, clases y funciones	Completo
05	Referencia técnica	Catálogo de constantes, tipos, funciones, claves, rutas y códigos de error	Completo

06	Explicación profunda del código	Flujo interno, decisiones y casos límite de los módulos importantes	Completo
07	Base de datos	Motor, almacenes, diccionario de datos, migraciones y cifrado	Completo
08	Flujo de datos	Origen, validación, transformación, almacenamiento y salida de cada dato	Completo
09	APIs e integraciones	Contratos JSON, interfaces de plataforma y ausencia deliberada de red	Completo
10	Configuración	Preferencias, política de análisis, banderas y consecuencias de cada valor	Completo
11	Seguridad	Autenticación, cifrado, validación de entrada y superficie de ataque	Completo
12	Pruebas y calidad	Suite existente, cobertura observable, huecos y propuesta priorizada	Completo
13	Despliegue y operación	CI/CD, artefactos, publicación, mantenimiento y reversión	Completo
14	Solución de problemas	Síntoma, causa, diagnóstico, solución y riesgo	Completo
15	Riesgos y deuda técnica	Hallazgos clasificados por severidad, impacto, evidencia y prioridad	Completo · informativo
16	Glosario	Términos técnicos, del dominio y del producto	Completo
17	Resumen ejecutivo	Presentación para decisión, sin detalle innecesario	Completo
18	Guía para nuevos desarrolladores	Itinerario, entorno, convenciones y primeras tareas	Completo
19	Matriz de trazabilidad	De la funcionalidad al código, a los datos y a su prueba	Completo

Los mismos documentos en PDF están en [pdf/](#). Se generan desde estos Markdown con python `tool/build_system_documentation_pdf.py`; el procedimiento está en [13-deployment-and-operations.md](#).

Datos del análisis

Dato	Valor
Fecha del análisis	26 de agosto de 2026
Versión analizada	0.1.1+2
Commit analizado	4d1ba4b
Archivos Dart en <code>lib/</code>	65
Archivos de prueba Dart	24
Casos de prueba declarados	88 (87 los ejecuta <code>flutter test</code>)
Herramientas en <code>tool/</code>	13
Reglas del motor de análisis	26

Convenciones

Estos marcadores aparecen a lo largo de los documentos y significan siempre lo mismo:

Marcador	Significado
Comprobado	Se leyó el código, se ejecutó el comando o se verificó el archivo en este repositorio
Inferencia	Conclusión razonada a partir del código, no una afirmación del propio repositorio
No identificado	Se buscó y no existe en el repositorio
No documentado en el repositorio	Existe en el código pero no lo explica la documentación previa
Requiere validación	Solo puede confirmarse con hardware, red o credenciales que este análisis no tiene

Otras convenciones:

- las rutas se escriben relativas a la raíz del repositorio;
- los nombres de clases, funciones, almacenes y claves se conservan **literales**, para que puedan buscarse con `grep`;
- ningún ejemplo contiene secretos, credenciales ni datos personales reales; se usan dominios reservados (`example.com`, `*.example`) y valores ficticios;
- los diagramas Mermaid siempre van acompañados de una explicación en texto: el diagrama nunca es el único portador de la información.

Pendiente de validar

Lo que esta documentación **no** pudo comprobar en el entorno de análisis:

1. **Ejecución de Flutter.** Flutter y Dart no están instalados en la máquina donde se escribió esta documentación. `flutter analyze`, `flutter test` y las compilaciones no se ejecutaron localmente; la evidencia proviene de la CI pública del repositorio. Ver [12-testing-and-quality.md](#).

2. **Comportamiento en dispositivo físico.** Cámara, biometría, almacén seguro, ciclo de vida y apertura de aplicaciones externas solo pueden confirmarse en un teléfono real. Ver [../quality/DEVICE_TEST_MATRIX.md](#).
3. **La corrección de lectura de 0.1.1.** Alcance de la cámara con un código lejano, confirmación audible y conteo de unidades repetidas.
4. **Carpetas nativas.** `android/`, `ios/` y `web/` no están versionadas: las genera `tool/bootstrap.py`. Lo que este análisis describe de ellas proviene de leer ese generador, no de inspeccionar el resultado.

Relación con la documentación previa

Este directorio **no sustituye** la documentación existente del repositorio; la complementa y la enlaza. La documentación previa está organizada por audiencia y tema en [../INDEX.md](#), y sigue siendo la fuente normativa en tres áreas concretas:

Área	Fuente normativa
Especificación de las 26 reglas	../rootcause/HEURISTICS.md
Contrato de evidencia exportable	../schemas/rootcause-qr-evidence.schema.json
Compromisos que no pueden romperse	../quality/COMPATIBILITY_CONTRACT.md

01 · Descripción general del sistema

Qué es

RootCause QR Inspector es una **aplicación móvil escrita en Flutter** que lee códigos QR y de barras y, antes de permitir cualquier acción, explica qué contiene el código y qué señales de riesgo observó. Todo el análisis ocurre en el teléfono: el sistema no tiene servidor, ni cuentas, ni telemetría.

Pertenece a una familia de productos llamada RootCause, organizada por **superficie observable**. Esta edición observa una sola superficie: el contenido codificado en un código gráfico y la forma en que ese contenido intenta convertirse en una acción.

Comprobado: `pubspec.yaml` declara `name: rootcause_qr_inspector`, `version: 0.1.1+2`, y ninguna dependencia de red o analítica. La única dependencia que abre algo hacia afuera es `url_launcher`, que entrega una URI a otra aplicación del sistema cuando la persona lo confirma.

Qué problema resuelve

Un código QR es una **instrucción opaca**. A simple vista no se distingue el sitio real de una imitación, ni un pago legítimo de una sustitución de beneficiario. Quien escanea con un lector convencional descubre el destino cuando ya está dentro de él.

El sistema invierte ese orden:

1. captura la carga sin ejecutarla;
2. la interpreta y muestra sus campos;
3. aplica 26 reglas locales que producen **hechos observables**;
4. deriva **hipótesis** separadas de esos hechos;
5. decide qué acción permite, y solo entonces ofrece un botón.

El producto no afirma que un destino sea seguro. Una lectura sin hallazgos significa exactamente «ninguna regla local aplicable disparó», y la interfaz lo dice con esas palabras.

A quién está dirigido

Actor	Qué hace con el sistema
Persona que recibe un QR dudoso	Lo inspecciona antes de abrirlo y decide con la evidencia a la vista
Persona que investiga un incidente	Exporta evidencia redactada con huella SHA-256 para correlacionarla
Equipo de operaciones	Cuenta productos con la sesión de inventario y exporta el conteo
Organización con marcas propias	Inyecta su política de marcas y dominios permitidos por API
Auditor	Revisa reglas, evidencia, cifrado y límites declarados

No hay roles dentro de la aplicación: **no existe autenticación de usuario ni separación de permisos**. Quien tiene el teléfono desbloqueado tiene todas las funciones. El único control de acceso es un bloqueo local opcional con la biometría o el PIN del dispositivo.

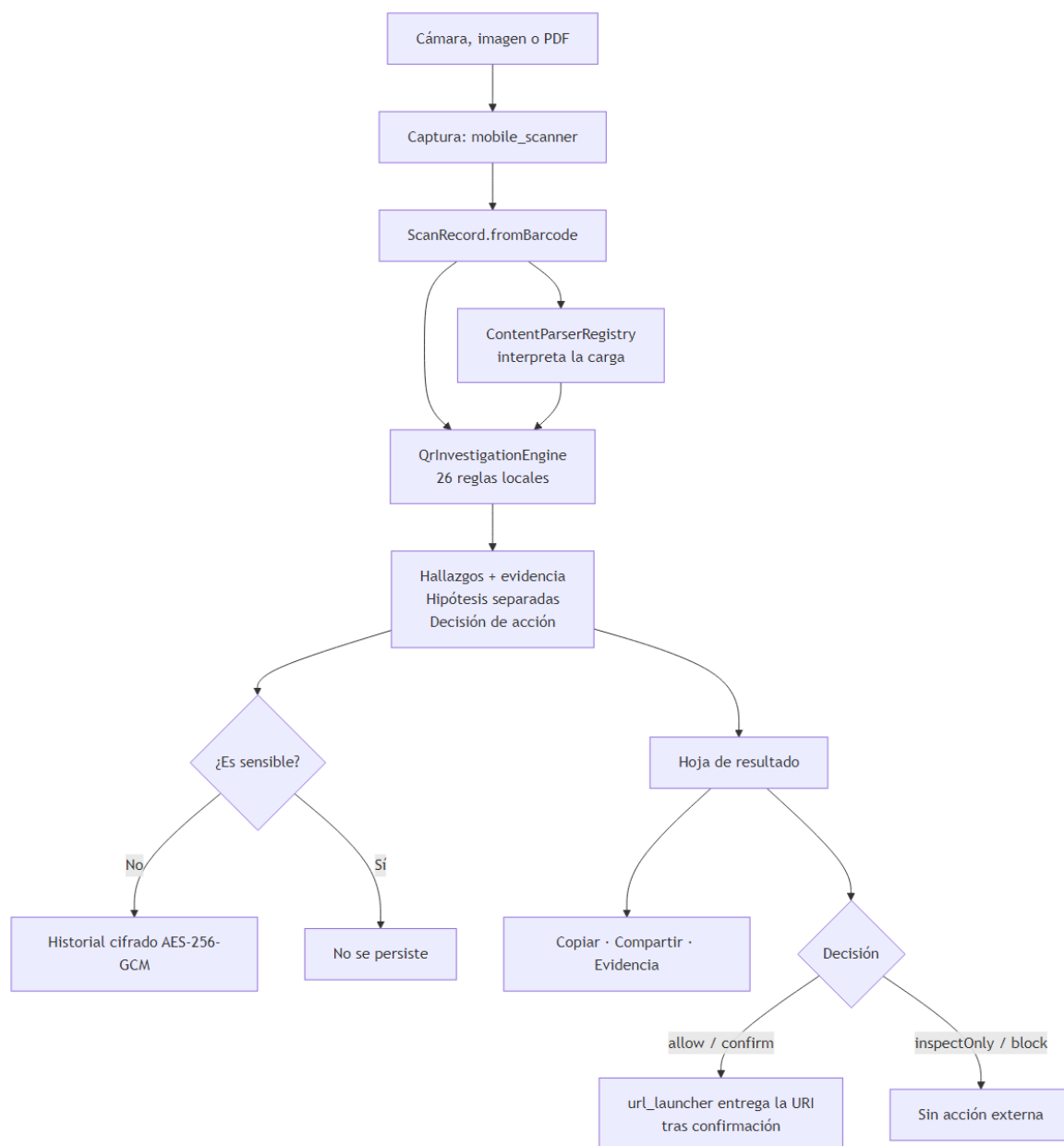
Casos de uso principales

1. **Inspeccionar un código con la cámara.** Es el flujo central.
2. **Inspeccionar códigos dentro de imágenes o de un PDF.** Por lotes, con progreso y cancelación.
3. **Consultar el historial** de casos inspeccionados, buscarlos, filtrarlos por riesgo, anotarlos y etiquetarlos.
4. **Exportar evidencia** de un caso en formato redactado y verificable.
5. **Contar inventario** leyendo códigos de producto de forma continua.
6. **Generar códigos** localmente para pruebas o para compartir datos.
7. **Recuperar registros dañados** y rotar la llave de cifrado.

Funcionalidades principales

Funcionalidad	Dónde vive	Estado
Lectura con cámara	<code>lib/features/scanner/scanner_screen.dart</code>	Activo
Lectura desde imagen y PDF	mismo archivo + <code>lib/services/pdf_page_renderer_io.dart</code>	Activo · PDF no disponible en web
Interpretación de contenido	<code>lib/services/content_interpreter.dart</code>	Activo
Motor de 26 reglas	<code>lib/core/investigation/qr_investigation_engine.dart</code>	Activo
Resultado explicado	<code>lib/features/result/scan_result_sheet.dart</code>	Activo
Evidencia exportable	<code>lib/core/investigation/qr_evidence_exporter.dart</code>	Activo
Historial cifrado	<code>lib/services/history_repository.dart</code>	Activo
Inventario	<code>lib/features/inventory/inventory_screen.dart</code>	Activo
Generador	<code>lib/features/generator/generator_screen.dart</code>	Activo
Centro de recuperación	<code>lib/features/recovery/recovery_screen.dart</code>	Activo
Rotación de llave	<code>lib/core/security/data_maintenance_service.dart</code>	Activo
Política de marcas	<code>lib/core/investigation/qr_analysis_policy.dart</code>	Paralelo a la API, no la pantalla
Banderas de capacidades futuras	<code>lib/core/feature_flags/feature_flags.dart</code>	En desarrollo

Flujo general de funcionamiento



Explicación del diagrama. La captura produce una carga cruda. Esa carga recorre dos caminos que convergen: el intérprete, que la convierte en campos legibles, y el motor de reglas, que produce hechos. El motor recibe además el resultado del intérprete, porque tres de sus reglas dependen del tipo de contenido. El resultado se muestra siempre; se guarda solo si no es sensible y la persona no desactivó el historial. La acción externa nunca es automática: depende de la decisión del motor y de una confirmación.

Entradas y salidas

Entrada	Origen	Confianza
Carga de un código	Cámara, galería, PDF	No confiable: es el objeto de análisis
Respaldo JSON de historial	Archivo elegido por la persona	No confiable: todo campo derivado se recalcula
Respaldo JSON de inventario	Archivo elegido por la persona	No confiable: se valida antes de importar
Política de análisis	API Dart de un integrador	Confiable: la aporta quien integra

Preferencias	Almacén del sistema	Confiable con valores por defecto conservadores
--------------	---------------------	---

Salida	Formato	Contiene la carga
Evidencia de un caso	JSON <code>rootcause.evidence.qr.v1</code>	No, salvo decisión explícita por API
Historial completo	JSON, CSV, XLSX	Sí, en claro. La interfaz lo advierte
Sesión de inventario	JSON, CSV, XLSX	Sí: códigos de producto
Paquete de recuperación	JSON	Solo cargas ya cifradas, sin la llave
Diagnóstico privado	JSON	No: solo tipo de error y huella de pila
Código generado	PNG, SVG	Sí: lo escribió la persona

Componentes más importantes

1. **QrInvestigationEngine** — el motor de reglas. Es una función pura sin dependencias de Flutter, cámara, base de datos ni red. Es el corazón del producto y la razón de que pueda probarse sin dispositivo.
2. **ScanRecord** — la entidad que une carga, interpretación e investigación.
3. **PayloadCipher** — el cifrado AES-256-GCM de todo lo que se persiste.
4. **QrEvidenceExporter** — el paquete forense redactado y verificable.
5. **ScannerScreen** — la pantalla que reconcilia cámara, ciclo de vida, estados visibles y lotes cancelables.

Tecnologías utilizadas

Capa	Tecnología	Versión
Lenguaje	Dart	<code>>=3.12.0 <4.0.0</code>
Framework	Flutter	<code>>=3.44.0</code> , fijado a 3.44.7 en <code>.fvmrc</code>
Base de datos	Sembast (archivo) / sembast_web (IndexedDB)	3.8.9+1 / 2.4.5+1
Cifrado	<code>cryptography</code> (AES-GCM 256)	2.9.0
Almacén de llaves	<code>flutter_secure_storage</code>	11.0.0
Captura	<code>mobile_scanner</code>	7.4.0
Generación de códigos	<code>barcode_widget</code>	2.0.4
PDF	<code>pdfrx</code>	2.4.5
Hojas de cálculo	<code>excel</code>	4.0.6
Automatización	Python 3.12 + GitHub Actions	—

Lista completa en `pubspec.yaml`. Dos versiones están ancladas a propósito y no deben subirse sin resolver antes un conflicto de resolución: ver `../quality/LOCKFILE.md`.

Límites del sistema

Lo que el sistema **no puede** hacer, por diseño y por falta de red:

- conocer la reputación, el dueño o la antigüedad de un dominio;
- resolver DNS o ver el certificado TLS que servirá el destino;
- seguir la cadena real de redirecciones HTTP;
- descargar y analizar el archivo al que apunta una ruta;
- detectar que alguien pegó una etiqueta falsa sobre un QR auténtico;
- confirmar que un beneficiario bancario es el esperado.

Estas ausencias se emiten como una lista explícita en cada investigación (limitations) y se muestran en la interfaz. Detalle completo en `../rootcause/LIMITATIONS.md`.

Integraciones externas

No hay ninguna integración de red. El sistema no llama a ninguna API. Sus únicas fronteras externas son servicios del sistema operativo:

Frontera	Para qué
Cámara	Capturar códigos
Galería / selector de archivos	Leer imágenes, PDF y respaldos JSON
Keychain / Keystore	Guardar la llave de cifrado
Autenticador local	Bloqueo biométrico opcional
Portapapeles	Copiar una carga, con borrado programado
Hoja de compartir	Entregar exportaciones a otra aplicación
<code>url_launcher</code>	Abrir una URI en otra aplicación, tras confirmación

Estado general observado en el repositorio

Comprobado en el commit analizado:

- el código fuente está completo y es coherente: los verificadores `tool/validate_structure.py` y `tool/verify_rootcause_contract.py` pasan;
- hay 88 casos de prueba declarados;
- el APK Android se publica desde un tag mediante GitHub Actions;
- las carpetas nativas no están versionadas: se generan de forma reproducible.

Requiere validación: el comportamiento en dispositivo físico —cámara, biometría, almacén seguro, ciclo de vida— y, en particular, las correcciones de lectura de la versión 0.1.1.

No identificado: ninguna publicación en Play Store o App Store, ninguna firma comercial, ningún paquete instalable de iOS.

El sistema explicado para una persona no técnica

Imagine un código QR pegado en la mesa de un restaurante, en un cartel de la calle o llegado por mensaje. Es un cuadrado de puntos: **nadie puede leerlo con los ojos**. Al escanearlo con la cámara normal del teléfono, este suele abrir directamente lo que el código diga, y solo entonces se descubre adónde llevaba.

Esta aplicación hace otra cosa. Lee el código, pero **no lo abre**. En su lugar muestra una ficha con lo que encontró dentro: si es una dirección web, cuál es exactamente; si es una red Wi-Fi, cuál; si es una instrucción de pago, a quién.

Después revisa esa información con una lista de 26 comprobaciones. Cada una es una pregunta concreta, del estilo de:

- ¿la dirección usa una conexión sin cifrar?
- ¿el nombre del sitio mezcla alfabetos para parecerse a otro?
- ¿hay una segunda dirección escondida dentro de la primera?
- ¿la ruta termina en un archivo que puede instalar algo?

Cada respuesta afirmativa es un **hecho**: algo que la aplicación observó de verdad. A partir de esos hechos propone una **sospecha** —por ejemplo, «podría ser un intento de suplantación»— y la presenta como lo que es: una sospecha que merece revisión, no una acusación ni una certeza.

Solo al final ofrece un botón para continuar, y a veces ni siquiera eso: si la dirección está tan mal formada que otra aplicación podría interpretarla de forma distinta, el botón no aparece.

Tres cosas importantes, dichas sin rodeos:

1. **Que no encuentre nada no significa que el sitio sea seguro.** Significa que ninguna de sus 26 comprobaciones se activó. La aplicación lo dice con esas palabras cada vez.
2. **Nada sale del teléfono.** No hay cuenta, no hay servidor, no hay publicidad ni estadísticas. Lo que se guarda queda cifrado en el propio dispositivo.
3. **No sustituye a un antivirus ni a su banco.** Ante un pago o una contraseña, la aplicación insiste en verificar por otra vía.

Si algo parece sospechoso, la aplicación puede generar un **informe** para compartir con alguien de confianza. Ese informe, a propósito, **no incluye el enlace completo**: lleva una huella digital del contenido, la lista de lo que se observó y lo que no se pudo comprobar. Así se puede pedir ayuda sin reenviar por accidente la contraseña, el código de acceso o los datos de pago que el código llevaba dentro.

02 · Instalación y ejecución

Todos los comandos de este documento se ejecutan desde la raíz del repositorio. Ninguno contiene secretos reales.

Requisitos previos

Requisito	Versión	Por qué esa versión	Obligatorio
Flutter	3.44.7	Fijada en <code>../../../../fvmrc</code> y en los tres workflows de CI. <code>pubspec.yaml</code> exige <code>>=3.44.0</code>	Sí
Dart	<code>>=3.12.0 <4.0.0</code>	Declarado en <code>pubspec.yaml</code> . Viene con Flutter	Sí
Python	3.12	Lo usan las 13 herramientas de <code>tool/</code>	Sí
uv	0.12.5	Solo lo usa la CI para inyectar <code>pyyaml</code> sin instalarlo. En local basta con tener <code>pyyaml</code>	No
Android SDK	API 24 o superior	<code>tool/bootstrap.py</code> fija <code>minSdk = 24</code>	Para Android
Xcode + macOS	—	Solo un host macOS puede generar y compilar el target iOS	Para iOS
Pillow	cualquiera	Solo para regenerar los iconos. Compilar no lo necesita	No

Comprobación rápida del entorno:

```
flutter --version
python --version
```

Por qué hay un paso de generación

Las carpetas `android/`, `ios/` y `web/` no están en el repositorio. `.gitignore` las excluye a propósito. Se generan de forma reproducible con `tool/bootstrap.py`, que además aplica una lista de parches necesarios: permisos, iconos, `minSdk`, versiones de la cadena Gradle, textos de uso de cámara y Face ID, y el cambio de `FlutterActivity` a `FlutterFragmentActivity` que exige la biometría.

Consecuencia práctica: **un clon recién hecho no compila hasta ejecutar el bootstrap.**

Instalación desde cero

```
git clone https://github.com/vladimiracunadev-create/rootcause-qr-inspector.git
cd rootcause-qr-inspector
flutter pub get
python tool/bootstrap.py --platforms android,web
```

`--platforms` acepta `android`, `ios` y `web`, separados por comas. Sin el argumento genera `android` (y también `ios` si el sistema es `macOS`). El target `web` existe solo como canal de demostración; no es una plataforma del producto.

En `macOS`, para trabajar con `iOS`:

```
python tool/bootstrap.py --platforms ios
```

Para regenerar desde cero una carpeta ya existente:

```
python tool/bootstrap.py --platforms android --force
```

Cuidado: `--force` borra la carpeta de la plataforma y la vuelve a crear. Cualquier cambio hecho a mano dentro de `android/`, `ios/` o `web/` se pierde. Esa es justamente la razón de que no se versionen: los cambios deben vivir en `tool/bootstrap.py`, no en el resultado.

Atajos equivalentes por sistema:

```
./tool/bootstrap.sh --platforms android,web
```

```
.\tool\bootstrap.ps1 -platforms android,web
```

Variables de entorno

No identificadas. El código de la aplicación no lee ninguna variable de entorno: no hay `String.fromEnvironment`, `--dart-define` ni archivo `.env` en el repositorio. Toda la configuración de la aplicación vive en las preferencias del dispositivo y en la política de análisis inyectada por código.

Las únicas variables presentes son de la CI, declaradas en los propios workflows:

Variable	Dónde	Valor
<code>FLUTTER_VERSION</code>	los tres workflows	<code>3.44.7</code>
<code>DEMO_BASE_HREF</code>	<code>deploy-landing.yml</code>	<code>/rootcause-qr-inspector/app/</code>
<code>GH_TOKEN</code>	<code>android-release.yml</code>	El token efímero del propio workflow

Configuración inicial

No hay ninguna. La aplicación arranca con valores por defecto conservadores y crea su base de datos en el primer inicio. Detalle de cada preferencia y su valor por defecto en [10-configuration.md](#).

Creación o restauración de la base de datos

No hay ningún paso manual. La base se crea sola:

- `AppDatabase.open()` abre el archivo `rootcause_qr_inspector_v2.db` en el directorio de soporte de la aplicación (o el almacén `IndexedDB` del mismo nombre en `web`);
- `SchemaMigrator.migrate()` aplica los pasos de esquema pendientes dentro de una transacción, antes de que ningún repositorio la use.

No existe script SQL, ni servidor, ni credenciales de base de datos. Detalle en [07-database.md](#).

Para **restaurar** datos de un respaldo se usa la propia aplicación: Historial → menú → *Importar respaldo JSON*, que muestra una vista previa antes de tocar nada.

Ejecución en desarrollo

```
flutter run
```

Con un dispositivo o emulador conectado. Para elegir destino:

```
flutter devices  
flutter run -d <id-del-dispositivo>
```

La demo web:

```
flutter run -d chrome
```

En web no están disponibles la lectura de PDF ni el almacén seguro del sistema; la aplicación lo declara en la interfaz.

Ejecución en producción

No hay «servidor de producción». Producción es un artefacto instalable.

```
flutter build apk --release
```

El APK queda en `build/app/outputs/flutter-apk/app-release.apk`.

```
flutter build web --release
```

```
flutter build ios --release
```

El build de iOS requiere macOS y una identidad de firma. La CI solo compila el simulador (`flutter build ios --debug --simulator`), que no necesita firma.

Importante sobre la firma: el APK que publica la CI está firmado con la clave de depuración que genera Flutter, no con una clave comercial. El workflow lo verifica con `apksigner` y publica su SHA-256, pero eso **no** equivale a una firma de tienda. Ver [13-deployment-and-operations.md](#).

Ejecución de las pruebas

```
flutter test
```

Ejecuta los 87 casos de `test/`. Para cobertura:

```
flutter test --coverage
```

Un archivo concreto:

```
flutter test test/core/qr_investigation_engine_test.dart
```

La prueba de integración necesita un dispositivo:

```
flutter test integration_test/app_launch_test.dart
```

Verificaciones offline

Estas dos herramientas no necesitan Flutter y son la forma más rápida de saber si un cambio rompió un contrato del repositorio:

```
python tool/validate_structure.py --require-lock
```

Comprueba YAML y JSON válidos, imports locales existentes, enlaces Markdown locales que resuelven, acciones de GitHub fijadas a SHA, coherencia entre la versión de `pubspec.yaml` y la que muestra la interfaz, ausencia de rutas absolutas del entorno, ausencia de registro de contenido sensible, recursos de la landing, iconos y presencia del lockfile.

```
python tool/verify_rootcause_contract.py
```

Comprueba que las 26 reglas del motor existen también en el JSON Schema, en los textos de la interfaz y en la documentación de heurísticas; que los fixtures solo usan dominios reservados; que la política de ejemplo es sintética; y que el contrato de redacción de la evidencia sigue intacto.

En la CI, la primera se ejecuta con `uv` para no depender de un `pyyaml` instalado:

```
uv run --with pyyaml python tool/validate_structure.py --require-lock
```

Gate completo, igual que la CI

```
flutter pub get
python tool/bootstrap.py --platforms android,web
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py
flutter analyze --fatal-infos
flutter test
flutter build web --release
flutter build apk --release
```

Hay dos scripts que encadenan variantes de esto:

Script	Para qué
<code>tool/run_quality_gate.sh</code>	Ciclo de trabajo diario: estructura, análisis, pruebas con cobertura, SBOM y licencias
<code>tool/finalize_stable.sh</code>	Antes de etiquetar una versión: exige Flutter en PATH, compila, regenera SBOM, licencias y <code>SOURCE_MANIFEST.json</code>

Errores frecuentes durante la instalación

Síntoma	Causa	Solución
No such file or directory: android/	No se ejecutó el bootstrap	<code>python tool/bootstrap.py --platforms android</code>
Flutter no está instalado o no está disponible en PATH	El bootstrap necesita Flutter para <code>flutter create</code>	Instalar Flutter y reabrir la terminal
cannot find symbol: class FilePickerPlugin	La plantilla generó AGP 9 y no se aplicaron los parches de la cadena Gradle	Volver a ejecutar el bootstrap, que fija AGP 8.11.1, KGP 2.2.20 y Gradle 8.14.3

Falta <code>pubspec.lock</code>	Se ejecutó <code>validate_structure.py --require-lock</code> sin resolver	<code>flutter pub get</code> y confirmar el lockfile
<code>ModuleNotFoundError: yaml</code>	<code>validate_structure.py</code> y <code>generate_sbom.py</code> necesitan <code>pyyaml</code>	<code>pip install pyyaml</code> o usar <code>uv run --with pyyaml</code>
Conflicto al resolver <code>pdfx</code> o <code>excel</code>	Ambas están ancladas por un conflicto real de <code>archive</code>	No subirlas sin leer ../quality/LOCKFILE.md
La versión mostrada en la interfaz no coincide	Se cambió <code>pubspec.yaml</code> sin cambiar <code>lib/core/app_info.dart</code>	Igualar ambos; es una comprobación deliberada
La demo web no lee PDF	El renderizador PDF solo existe en plataformas con <code>dart:io</code>	Exportar la página como imagen, o usar una plataforma nativa

Más síntomas, ya en ejecución, en [14-troubleshooting.md](#).

Herramientas auxiliares

Comando	Qué hace	Requiere
<code>python tool/generate_sbom.py</code>	SBOM CycloneDX en <code>build/reports/sbom.cdx.json</code>	<code>pyyaml</code> ; con Flutter incluye el árbol resuelto
<code>python tool/generate_license_inventory.py</code>	Inventario de licencias de las dependencias	<code>flutter pub get</code> previo
<code>python tool/generate_checksums.py <archivo...></code>	SHA-256 de cada archivo	—
<code>python tool/generate_source_manifest.py</code>	Regenera <code>SOURCE_MANIFEST.json</code> con el hash de cada archivo fuente	—
<code>python tool/generate_launcher_icons.py</code>	Regenera los iconos versionados	Pillow
<code>python tool/generate_scan_beep.py</code>	Regenera el tono de confirmación	—
<code>python tool/build_system_documentation_pdf.py</code>	Genera los PDF de esta documentación	<code>markdown</code> , <code>xhtml2pdf</code> ; <code>mmdc</code> para los diagramas

03 · Arquitectura

Estilo arquitectónico

Es una **aplicación monolítica cliente, en capas, con un núcleo puro**. No hay servidor, no hay microservicios, no hay comunicación entre procesos.

La decisión estructural que define todo lo demás: **el motor de análisis no depende de Flutter**. `QrInvestigationEngine.analyze` recibe una cadena, una interpretación, una política y un instante, y devuelve un objeto serializable. No toca cámara, base de datos, red ni widgets. Por eso puede probarse sin dispositivo, compararse entre versiones y, en el futuro, reutilizarse desde una CLI o un backend.

El resto de la aplicación son **proyecciones** de ese núcleo: la interfaz lo dibuja, la base de datos lo cifra y lo guarda, el exportador lo convierte en un paquete portable.

Mapa mental del sistema



Explicación. Cuatro bloques sostienen el sistema y uno lo rodea. Captura alimenta al núcleo; el núcleo produce datos que la persistencia guarda cifrados y la interfaz muestra. Operación no es parte de la aplicación en ejecución: es el andamiaje que garantiza que lo que se compila coincide con lo que se documenta.

Capas y responsabilidades

Capa	Directorio	Responsabilidad	Puede depender de
Modelos	<code>lib/models/</code>	Entidades inmutables y su serialización	Solo de otros modelos y del núcleo de investigación
Núcleo	<code>lib/core/</code>	Investigación, seguridad, base de datos, recuperación, tema, localización, diagnóstico	Modelos
Servicios	<code>lib/services/</code>	Interpretación, repositorios, importación, exportación, plataforma	Núcleo, modelos

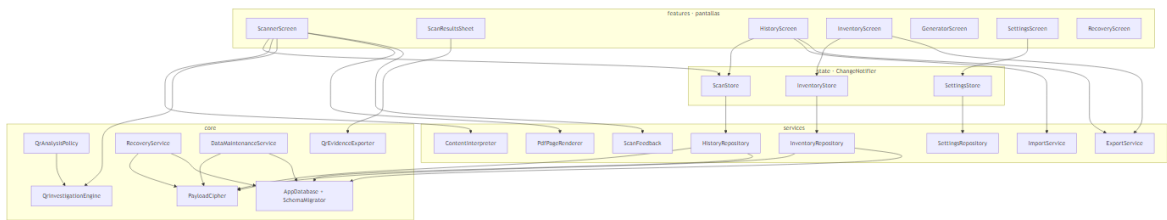
Estado	<code>lib/state/</code>	Stores <code>ChangeNotifier</code> que la interfaz observa	Servicios, modelos
Funcionalidades	<code>lib/features/</code>	Pantallas y widgets por caso de uso	Todo lo anterior
Arranque	<code>lib/main.dart</code> , <code>bootstrap.dart</code> , <code>bootstrap_host.dart</code> , <code>app.dart</code>	Composición y ciclo de vida de la aplicación	Todo

La dirección de las dependencias es estricta y la comprueba `tool/validate_structure.py`, que falla si un `import` local apunta a un archivo inexistente. **Nada en `lib/core/investigation/` importa Flutter**, lo que se puede verificar con:

```
grep -rl "package:flutter" lib/core/investigation/
```

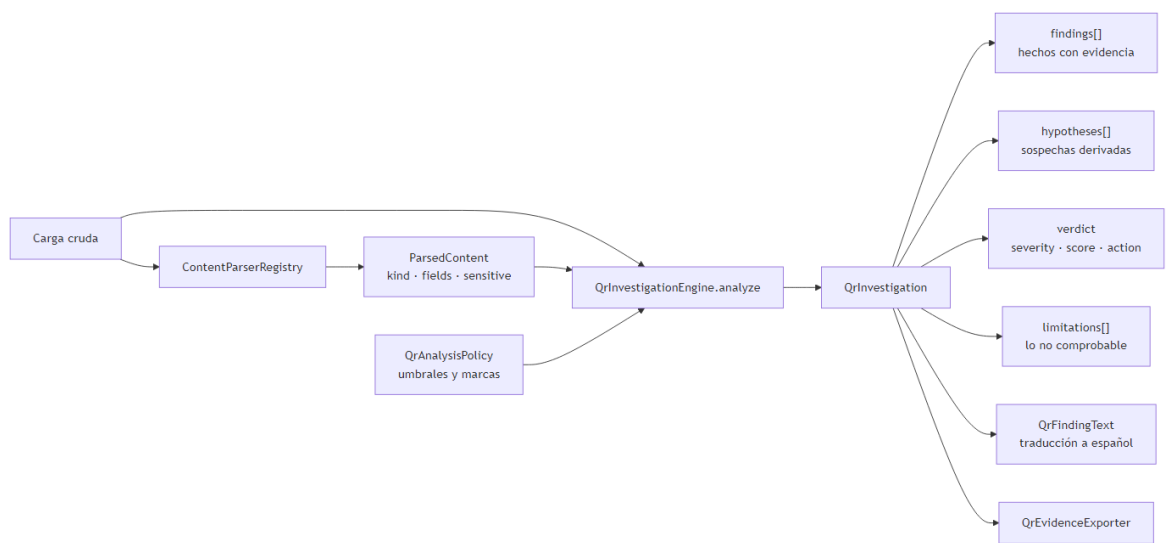
que no devuelve el motor ni el contrato.

Diagrama de arquitectura



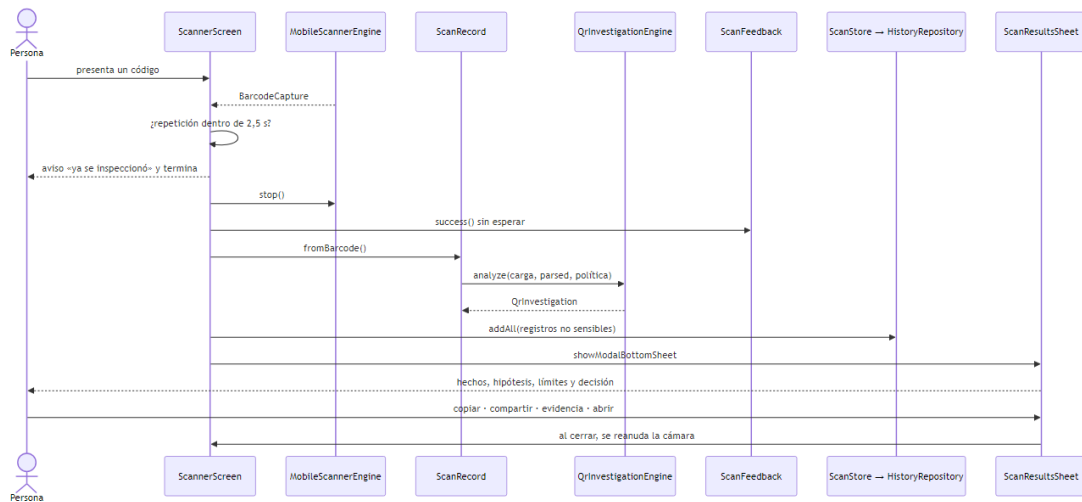
Explicación. Las pantallas nunca hablan con la base de datos: pasan por un store, y el store por un repositorio. La única excepción deliberada es el análisis: `ScannerScreen` construye un `ScanRecord`, y ese constructor invoca directamente al intérprete y al motor, porque ambos son funciones puras sin estado que compartir. El cifrado está por debajo de todos los repositorios: no existe camino que escriba en la base sin pasar por `PayloadCipher`.

Diagrama de componentes del núcleo de investigación



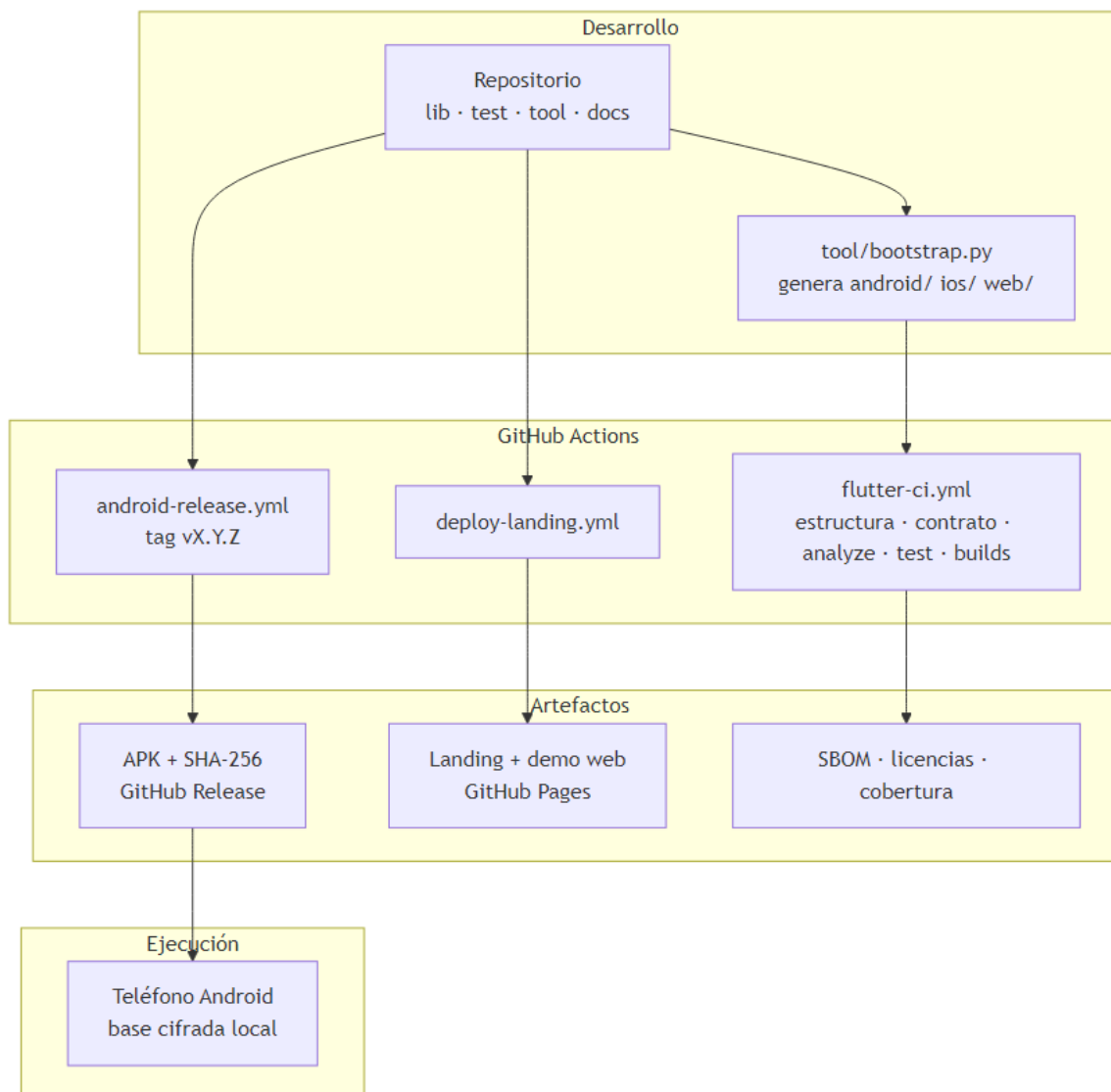
Explicación. El motor recibe tres entradas y produce una sola salida serializable. Los identificadores de hallazgo son estables y neutrales al idioma; `QrFindingText` es la única capa que los convierte en español, de modo que traducir la interfaz nunca altera el formato de evidencia. El exportador consume la investigación, no la interfaz.

Flujo principal, paso a paso



Explicación. Tres detalles del diagrama son decisiones de diseño, no casualidades. Primero, el filtro de repetición ocurre **antes** de cualquier trabajo, y cuando descarta algo lo dice. Segundo, la confirmación sonora se lanza sin esperarla: si el reproductor de audio tarda, el resultado no espera. Tercero, el guardado ocurre antes de mostrar la hoja, y solo con los registros que no son sensibles.

Diagrama de despliegue



Explicación. El repositorio no contiene binarios de producto; los produce la CI. Un tag semántico dispara la publicación del APK con su checksum y su atestación de procedencia. La landing y la demo web se despliegan por separado y no son plataformas del producto.

Patrones de diseño identificados

Patrón	Dónde	Por qué
Repositorio	HistoryRepository, InventoryRepository, RecoveryRepository, SettingsRepository	Aísla el almacenamiento del resto
Observador	Los tres stores extienden ChangeNotifier	La interfaz se redibuja sola
Estrategia + registro	ContentParser y ContentParserRegistry	Permite añadir formatos sin tocar el intérprete

Adaptador	ScannerEngine sobre mobile_scanner; ScanSecurityAnalyzer sobre el motor	Cambiar el paquete de captura no toca persistencia; el adaptador conserva RiskLevel para pantallas heredadas
Fábrica con nombre	ScanRecord.fromBarcode, .manual, .fromJson	Tres orígenes con reglas distintas de confianza
Objeto de valor inmutable	Todos los modelos, con copyWith	Evita mutación compartida
Sobre versionado	PayloadCipher	Permite evolucionar el cifrado sin perder lo escrito
Cola serial	AsyncWriteQueue	Ordena escrituras concurrentes de inventario
Testigo de cancelación	CancellationToken	Cancelación cooperativa de lotes
Compilación condicional	database_opener.dart, pdf_page_renderer.dart	Una implementación por plataforma, sin if (kIsWeb) disperso

Manejo de estado

No se usa ninguna librería de gestión de estado. Hay tres stores `ChangeNotifier` creados una sola vez en el arranque y pasados hacia abajo por constructor:

Store	Qué contiene	Cuándo notifica
ScanStore	Historial descifrado y ordenado, estado de carga y de migración	Después de persistir
InventoryStore	Sesiones y sesión activa	Después de persistir, dentro de la cola serial
SettingsStore	Preferencias	Antes de persistir

La diferencia de orden es deliberada. Un cambio de historial o inventario no debe mostrarse como confirmado si la base todavía no lo escribió; un cambio de tema, en cambio, debe verse al instante y su escritura no puede corromper datos.

No hay inyección de dependencias ni localizador de servicios: `AppServices` agrupa lo que se construyó y se entrega por constructor. Es más verboso y hace explícitas las dependencias de cada pantalla.

Procesos síncronos y asíncronos

Proceso	Naturaleza	Nota
Análisis de una carga	Síncrono y puro	Milisegundos; sin E/S
Cifrado y descifrado	Asíncrono	Preparado fuera de la transacción
Lectura del historial	Asíncrono	Descifra registro a registro y aísla los ilegibles

Lote de imágenes o PDF	Asíncrono cancelable	Con progreso, <code>await Future.delayed(Duration.zero)</code> para ceder el hilo
Codificación de CSV y XLSX	<code>Isolate (compute)</code>	Un historial grande bloquearía la interfaz
Escrituras de inventario	Serializadas	<code>AsyncWriteQueue</code>
Rotación de llave	Asíncrona, en dos fases	Reencrpta en memoria y luego escribe en una transacción

Manejo de errores

Cuatro niveles, de fuera hacia dentro:

1. **Zona guardada** — `main()` envuelve `runApp` en `runZonedGuarded`, e instala `FlutterError.onError` y `PlatformDispatcher.instance.onError`. Todo error no capturado llega a `AppDiagnostics`.
2. **Arranque** — si `AppBootstrapper.initialize` falla, `BootstrapHost` muestra la pantalla Inicio seguro con cuatro salidas: reintentar, abrir sin datos persistentes, restablecer preferencias visuales o copiar el diagnóstico.
3. **Por operación** — la cámara traduce cualquier excepción a un estado visible; el descifrado que falla aísla el registro en vez de propagarse; la importación cuenta el registro rechazado y continúa.
4. **Diagnóstico** — `AppDiagnostics` guarda como máximo 100 entradas con instante, área, tipo de error y huella de las cuatro primeras líneas de la pila. **No guarda el mensaje de la excepción**, porque un mensaje puede arrastrar una ruta, una consulta o un valor de la persona.

Autenticación y autorización

- **No hay autenticación de usuario ni modelo de permisos.** No hay cuentas, roles ni servidor que autorizar.
- Existe un **bloqueo local opcional** (`BiometricLockGate`): cuando está activo, la aplicación se bloquea al perder el primer plano —`inactive`, `paused`, `hidden` o `detached`— y exige autenticarse con el método del dispositivo. Sin salida alternativa: si falla, solo se puede reintentar.
- La autorización real que existe es **sobre acciones, no sobre personas**: `QrActionDecision` decide si una carga puede entregarse a otra aplicación.

Persistencia y caché

Qué	Dónde	Cifrado
Historial	Almacén <code>scan_history</code> de Sembast	Sí, carga completa
Inventarios	Almacén <code>inventory_sessions</code>	Sí, carga completa
Incidencias de recuperación	Almacén <code>recovery_issues</code>	Conserva el sobre original
Metadatos de esquema	Almacén <code>_schema_meta</code>	No: solo números y marcas
Llave activa	Almacén <code>_security_meta</code>	No: es un identificador, no la llave
Llave de cifrado	Keychain / Keystore	Es el secreto
Preferencias	<code>SharedPreferencesAsync</code>	No: no contienen carga

Cachés en memoria: `SecureStorageKeyProvider` cachea llaves ya leídas, y los stores mantienen la lista descifrada mientras la aplicación vive. No hay caché en disco de datos descifrados.

Procesos en segundo plano

No hay ninguno. Sin servicios, sin `WorkManager`, sin tareas programadas, sin notificaciones push. La aplicación solo trabaja mientras está en primer plano; de hecho, detiene la cámara en cuanto pasa a `inactive`.

Lo más parecido son dos temporizadores en memoria: el borrado del portapapeles (`ClipboardService`) y los avisos transitorios del escáner. Ambos mueren con el proceso, y así está declarado.

Diagrama entidad-relación

El sistema no usa un motor relacional; el equivalente conceptual está en [07-database.md](#), junto al diccionario de datos y las migraciones.

Fronteras de extensión

Frontera	Implementación actual	Cómo se extiende
Motor de captura	<code>MobileScannerEngine</code>	Implementar <code>ScannerEngine</code>
Formatos de contenido	<code>LegacyContentParser</code>	<code>ContentParserRegistry.register</code> con prioridad mayor que -1000
Política organizacional	<code>QrAnalysisPolicy</code> por API	Falta la pantalla de carga y administración
Reglas	26 reglas en el motor	Motor, textos, esquema, fixture, pruebas, documentación y <code>engineVersion</code> , todo en la misma entrega
Persistencia	Sembast	El opener por compilación condicional
Reputación remota	Ninguna	Bandera <code>urlReputation</code> , apagada

Regla que atraviesa todas: **un dato ausente nunca se convierte en un valor favorable**. Una regla que no puede evaluarse se omite y su límite se declara.

04 · Mapa completo del código

Inventario jerárquico de todo lo relevante del repositorio. La columna **Estado** usa cuatro valores: *activo* (participa en el flujo del producto), *legado* (se conserva por compatibilidad y está declarado como tal), *experimental* (existe pero está apagado) y *no determinado*.

Raíz del repositorio

Ruta	Qué es	Estado
pubspec.yaml · pubspec.lock	Manifiesto y resolución fijada de dependencias	Activo
analysis_options.yaml	flutter_lints más cuatro reglas propias	Activo
.fvmrc	Fija Flutter 3.44.7	Activo
.gitattributes	Fuerza LF para que los hashes de SOURCE_MANIFEST.json sean verificables tras clonar en Windows	Activo
.gitignore	Excluye android/, ios/, web/, macos/ y artefactos	Activo
SOURCE_MANIFEST.json	SHA-256 y tamaño de cada archivo fuente	Activo
RELEASE_SOURCE.json	Metadatos de la entrega y qué se validó	Activo
README.md · CHANGELOG.md · VALIDATION.md · IMPLEMENTATION_STATUS.md	Documentación raíz	Activo
MASTER_PROMPT.md	Instrucciones de estilo y límites del proyecto	Activo
SECURITY.md · CONTRIBUTING.md · LICENSE	Política de seguridad, contribución y licencia MIT	Activo
assets/	Iconos versionados y el tono scan_success.wav	Activo
config/rootcause-qr-policy.example.json	Política de ejemplo, solo dominios .example	Activo · referencia
schemas/rootcause-qr-evidence.schema.json	JSON Schema 2020-12 de la evidencia	Activo · contrato
fixtures/qr/manifest.json	12 casos sintéticos de regresión del motor	Activo
test_assets/	Imágenes reales de regresión y su manifiesto	Activo
landing/	Sitio estático publicado en GitHub Pages	Activo · no es la app
build/	Artefactos y evidencia de ejecuciones anteriores	No versionado

android/ ios/ web/	No existen en el repositorio; los genera tool/bootstrap.py	Generado
--------------------	--	----------

lib/ — arranque

Archivo	Símbolos	Responsabilidad	Usado por	Estado
main.dart	main()	Instala los capturadores de error y arranca la app dentro de una zona guardada	Punto de entrada	Activo
bootstrap.dart	AppServices, AppBootstrapper.initialize	Abre base, cifrado, dispositivos y stores en el orden correcto	BootstrapHost	Activo
bootstrap_host.dart	BootstrapHost, _StartupRecovery	Decide entre la app y la pantalla de inicio seguro	main	Activo
app.dart	RootCauseQrInspector, HandheldFrame, BiometricLockGate, HomeShell, navigationLabelBehaviorForWidth	Templ, idioma, marco de teléfono, bloqueo y navegación de cinco secciones	BootstrapHost	Activo

lib/core/ — infraestructura transversal

core/investigation/ — el núcleo del producto

Archivo	Símbolos principales	Responsabilidad	Depende de	Estado
qr_investigation.dart	QrSeverity, QrFindingConfidence, QrFindingCategory, QrActionDecision, QrEvidenceFact, QrFinding, QrInvestigation	Contrato de datos neutral al idioma, con toJson/fromJson	Nada externo	Activo
qr_investigation_engine.dart	QrInvestigationEngine y 14 auxiliares privados	Analiza, el puntaje, la decisión y las hipótesis	crypto, política, ParsedContent	Activo
qr_analysis_policy.dart	QrTrustedBrand, QrAnalysisPolicy	Umbrales y marcas de la organización	Nada	Activo · sin UI
qr_finding_text.dart	QrFindingText.title	Completar/expandir/translate traduce ids a español	Completar/expandir/translate	Activo
qr_evidence_exporter.dart	QrEvidenceExporter	Completar/expandir/translate redactado con checksum canónico	crypto, ScanRecord	Activo

core/security/

Archivo	Símbolos	Responsabilidad	Estado
payload_cipher.dart	EncryptionKeyProvider, SecureStorageKeyProvider, MemoryEncryptionKeyProvider, CipherEnvelopeInfo, PayloadCipher	AES-256-GCM con sobre versionado y llave por identificador	Activo
encryption_metadata_repo	EncryptionMetadataRepository	Guarda la llave activa dentro de la base, no en preferencias	Activo
data_maintenance_service	EncryptionRotationResult, DataMaintenanceService, CipherEnvelopeInfo, Key	Rotación transaccional con rotación de llaves	Activo
scan_security_analyzer	RiskLevel, SecurityAssessment, ScanSecurityAnalyzer	Adaptador entre el motor y las pantallas heredadas	Legado declarado

core/database/

Archivo	Símbolos	Responsabilidad	Estado
app_database.dart	AppDatabase.open/openTemporary/close	Apertura/cierre	Activo
database_opener.dart	Reexport condicional	Elige backend por plataforma	Activo
database_opener_io.dart	openScannerDatabase	Archivo en el directorio de soporte	Activo
database_opener_web.dart	openScannerDatabase	IndexedDB	Activo · solo demo
database_opener_stub.dart	openScannerDatabase	Lanza <code>UnsupportedError</code>	Activo · defensa
schema_migrator.dart	SchemaMigrationResult, SchemaMigrator	Cuatro pasos idempotentes en una transacción	Activo

core/recovery/, core/performance/, otros

Archivo	Símbolos	Responsabilidad	Estado
recovery/recovery_issue	RecoveryEntityType, RecoveryIssueState, RecoveryIssue	Incidencia con su sobre cifrado	Activo
recovery/recovery_repository	RecoveryRepository.record/insert/load/mark/clearResolved	Añade/elimina/marca/resuelve <code>recovery_issues</code> con id determinista	Activo
recovery/recovery_service	RecoveryService.load/retry/scan/refresh	Acciones sobre <code>Bundle</code> aislados	Activo
performance/async_write	AsyncWriteQueue.run	Serializa escrituras sin que un fallo envenene la cola	Activo

performance/cancellation	OperationCancelledException, CancellationToken, BatchProgress	Cancelación cooperativa y progreso	Activo
diagnostics/app_diagnostic	DiagnosticEntry, AppDiagnostics, installGlobalErrorHandlers	Diagnóstico sin cargas ni mensajes	Activo
diagnostics/startup_fail	StartupFailure.from	Fallo de arranque reducido a lo mostrable	Activo
feature_flags/feature_flag	FeatureFlags con nueve banderas	Capacidades futuras apagadas	Experimental · apagado
localization/app_localization	AppLocalizations, AppStringsContext	Diez cadenas y el delegado que rechaza inglés	Activo · parcial
theme/app_theme.dart	AppTheme.light/dark	Material 3 con contraste, densidad y movimiento	Activo
utils/barcode_labels.dart	BarcodeLabels.format/contentType	Contenibles de simbología y tipo	Activo
app_info.dart	appVersion, appName	Único lugar donde se escribe la versión visible	Activo

lib/models/

Archivo	Símbolos	Campos clave	Estado
scan_record.dart	ScanRecord + 3 fábricas + payloadForBarcode	id, rawValue, parsed, investigation, riskLevel, favorite, tags, notes	Activo
parsed_content.dart	ContentKind (17 valores), ParsedContent	kind, title, fields, sensitive	Activo
app_settings.dart	AppLanguage, AppSettings	17 preferencias más featureFlags	Activo
inventory_session.dart	InventoryItem, InventorySession	items por código, totalUnits, isOpen	Activo

lib/services/

Archivo	Símbolos	Responsabilidad	Estado
content_interpreter.dart	ContentInterpreter.parse + 12 auxiliares	Interpreta 17 familias de contenido y decide sensitive	Activo
history_repository.dart	HistoryMigrationStatus, HistoryRepository	Historial cifrado, poda, recorte y migración heredada	Activo
inventory_repository.dart	InventoryRepository.loadSealers/sealers	Sealers/sealers	Activo

<code>settings_repository.dart</code>	<code>SettingsRepository.load/Save</code>	<code>SecureStorageNonSensitive</code>	Activo
<code>import_service.dart</code>	<code>ImportStrategy</code> , <code>HistoryImportPreview</code> , <code>InventoryImportPreview</code> , <code>ImportService</code>	Lectura de respaldos como entrada no confiable	Activo
<code>export_service.dart</code>	<code>ExportService</code> con 6 métodos	JSON, CSV y XLSX sin cifrar	Activo
<code>scan_feedback.dart</code>	<code>ScanTonePlayer</code> , <code>AssetScanTonePlayer</code> , <code>ScanFeedback</code>	Tono y vibración con degradación	Activo
<code>clipboard_service.dart</code>	<code>ClipboardService.copy</code>	Copia con borrado programado	Activo
<code>biometric_service.dart</code>	<code>BiometricService.isAvailable</code>	<code>BiometricService.authenticate</code>	Activo
<code>pdf_page_renderer.dart</code>	Reexport condicional	Elige implementación	Activo
<code>pdf_page_renderer_io.dart</code>	<code>RenderedPdfPage</code> , <code>PdfPageRenderer</code>	Rasteriza hasta 50 páginas con límites y limpieza	Activo
<code>pdf_page_renderer_stub.dart</code>	diversos tipos	Declara la ausencia en web	Activo · defensa

lib/state/

Archivo	Símbolos	Métodos públicos	Estado
<code>scan_store.dart</code>	<code>ScanStore</code>	<code>initialize</code> , <code>retryMigration</code> , <code>importPreview</code> , <code>addAll</code> , <code>update</code> , <code>toggleFavorite</code> , <code>pruneOlderThan</code> , <code>remove</code> , <code>clear</code>	Activo
<code>inventory_store.dart</code>	<code>InventoryStore</code>	<code>initialize</code> , <code>importSession</code> , <code>createSession</code> , <code>activate</code> , <code>reopenSession</code> , <code>updateItemNotes</code> , <code>addScan</code> , <code>setQuantity</code> , <code>closeActive</code> , <code>deleteSession</code>	Activo
<code>settings_store.dart</code>	<code>SettingsStore</code>	<code>initialize</code> , <code>update</code>	Activo

lib/features/

Archivo	Widget principal	Responsabilidad	Estado
<code>scanner/scanner_screen.dart</code>	<code>ScannerScreen</code>	Cámara, cinco estados, lotes cancelables, filtro de repetición	Activo

scanner/domain/scanner_	eScannerEngine	Frontera estable de captura	Activo
scanner/data/mobile_scan	MobileScannerEngine	Configuración real del controlador y de la resolución	Activo
scanner/widgets/scan_sta	ScanPhaseart ScanStatusBar	Estado siempre visible y anunciado	Activo
scanner/widgets/scanner_	ScannerOver lay	Atenúa fuera del marco y barre la línea	Activo
scanner/widgets/scanner_	ScannerViewportGeometry	Geometría del marco sin solapes	Activo
result/scan_result_sheet	ScanResultsSheet, ScanRecordCard	Hechos, hipótesis, límites, acciones y evidencia	Activo
history/history_screen.	dHistoryScreen	Búsqueda, filtros, notas, importación y exportación	Activo
inventory/inventory_scre	InventoryScreen	Sesiones y conteo continuo	Activo
generator/generator_scre	GeneratorScreen	Nueve tipos de carga, diez formatos, PNG y SVG	Activo
settings/settings_screen	SettingsScreen	Apariencia, inspección, privacidad, datos y versión	Activo
recovery/recovery_screen	RecoveryScreen	Registros aislados y diagnóstico	Activo
formats/formats_screen.	dFormatsScreen	Catálogo informativo de simbologías	Activo
formats/domain/content.	pContentParser	Interfaz de extensión	Activo
formats/domain/content.	pContentParserRegistry, LegacyContentParser	Registro ordenado con respaldo integrado	Activo

tool/ — 13 herramientas

Archivo	Qué hace	Lo usa
bootstrap.py	Genera y parchea android/, ios/, web/	Desarrollo y los tres workflows
bootstrap.sh · bootstrap.ps1	Envoltorios por sistema	Desarrollo
validate_structure.py	14 comprobaciones offline del repositorio	CI y desarrollo
verify_rootcause_contract.py	Coherencia de las 26 reglas y del contrato de evidencia	CI y desarrollo
generate_sbom.py	SBOM CycloneDX	CI
generate_license_inventory.py	Inventario de licencias	CI
generate_checksums.py	SHA-256 de archivos	CI de release

<code>generate_source_manifest.py</code>	Regenera <code>SOURCE_MANIFEST.json</code>	Antes de etiquetar
<code>generate_launcher_icons.py</code>	Dibuja los iconos por código	Manual, requiere Pillow
<code>generate_scan_beep.py</code>	Genera el tono de confirmación	Manual
<code>run_quality_gate.sh</code>	Gate de trabajo diario	Desarrollo
<code>finalize_stable.sh</code>	Gate previo a etiquetar	Antes de un release
<code>build_system_documentation_pdf.py</code>	Genera los PDF de esta documentación	Manual

test/ — 24 archivos, 88 casos

Archivo	Casos	Qué protege
<code>core/qr_investigation_engine_test.dart</code>	13	Las reglas, las hipótesis y la decisión
<code>core/qr_evidence_exporter_test.dart</code>	1	Redacción, alteración y canonicalización
<code>core/payload_cipher_test.dart</code>	5	Sobres, llave ausente, manipulación, versión futura
<code>core/data_maintenance_test.dart</code>	3	Rotación transaccional y limpieza de llave huérfana
<code>core/schema_migrator_test.dart</code>	1	Idempotencia de las migraciones
<code>core/recovery_service_test.dart</code>	1	El paquete no filtra llave ni texto claro
<code>core/diagnostics_test.dart</code>	1	El diagnóstico no incluye mensajes ni valores
<code>core/localization_test.dart</code>	4	La interfaz solo se ofrece en español
<code>core/accessibility_test.dart</code>	1	Contraste y objetivos táctiles con texto al 200 %
<code>core/handheld_frame_test.dart</code>	4	Marco de teléfono y etiquetas de navegación
<code>core/async_write_queue_test.dart</code>	2	Orden y aislamiento de fallos
<code>core/cancellation_token_test.dart</code>	2	Cancelación y fracción de progreso
<code>features/scan_status_bar_test.dart</code>	7	Los estados visibles, incluido <code>Código leído</code>
<code>features/scanner_viewport_geometry_test.dart</code>	1	El marco no se solapa con los controles
<code>features/scanner_engine_config_test.dart</code>	1	Resolución y modo de detección de la cámara
<code>services/import_service_test.dart</code>	5	Entrada no confiable y límites
<code>services/history_repository_test.dart</code>	1	<code>replaceAll</code> atómico

<code>services/content_parser_registry1test.dart</code>		Aislamiento y protección del parser integrado
<code>services/scan_feedback_test.dart</code>	6	Tono, vibración, precalentado y degradación
<code>content_interpreter_test.dart</code>	6	Wi-Fi, vCard, GS1, EMVCo, <code>www.</code> , ISBN
<code>scan_security_analyzer_test.dart</code>	9	El adaptador y sus niveles de riesgo
<code>scan_record_test.dart</code>	4	Serialización, binario y contenido sensible
<code>inventory_session_test.dart</code>	1	Unidades y serialización
<code>integration_test/app_launch_test1.dart</code>		Arranque normal o seguro; requiere dispositivo

Elementos sin uso, duplicados o de compatibilidad

Hallazgos de este recorrido, con su clasificación. El detalle y la recomendación están en [15-risks-and-technical-debt.md](#).

Elemento	Clasificación	Nota
<code>RiskLevel</code> y <code>SecurityAssessment</code>	Legado declarado	El propio código lo documenta: existe para filtros e importaciones heredadas; su verdad es <code>QrInvestigation.severity</code>
<code>FeatureFlags</code> (9 banderas)	Experimental apagado	Se serializa en preferencias pero ninguna bandera se lee en <code>lib/</code>
Claves inglesas de <code>AppLocalizations</code>	Parcial	Existen y hay una prueba que impide exponer inglés hasta traducir todas las pantallas
<code>PayloadCipher.legacyKeyId</code>	Duplicado aparente	Vale <code>'v2'</code> , igual que <code>currentKeyId</code>
<code>AppLanguage.en</code>	Inalcanzable por la interfaz	El desplegable de Ajustes lo convierte a «Sistema»
<code>ScannerEngine.controller</code>	Fuga de abstracción	La frontera expone el tipo del paquete que pretende ocultar
<code>HandheldFrame</code> en móvil	Sin efecto	Por debajo de 560 px no envuelve nada; es intencional

05 · Referencia técnica

Catálogo de consulta. Todos los nombres son literales del código y pueden buscarse con grep.

Constantes de identidad y versión

Constante	Archivo	Valor	Nota
appVersion	lib/core/app_info.dart	'0.1.1'	Único lugar donde se escribe la versión visible. tool/valid falla si diverge de pubspec.yaml
appName	lib/core/app_info.dart	'RootCause QR Inspector'	Verificado por tool/verif
QrInvestigationEngine.engineVersion	motor	'0.1.0'	Versión del motor de reglas, independiente de la app. Solo sube si cambia una regla
QrInvestigation.schema	contrato	'rootcause.qr-investigation.v1'	
QrEvidenceExporter.schema	exportador	'rootcause.evidence.qr.v1'	

Límites y umbrales

Constante	Archivo	Valor	Efecto al superarlo
-----------	---------	-------	---------------------

HistoryRepository.maxItems	historial	5000	Se borran los registros más antiguos
ImportService.maxHistoryRecords	importación	5000	FormatExce antes de tocar la base
ImportService.maxImportBytes	importación	25 * 1024 * 1024	FormatExce
ImportService.maxJsonDepth	importación	32	FormatExce
ImportService.maxJsonNodes	importación	100000	FormatExce
ImportService.maxInventoryItems	importación	10000	FormatExce
ImportService.currentSchemaVersion	importación	2	Un respaldo con versión mayor se rechaza
AppDiagnostics.maxEntries	diagnóstico	100	Se descartan las entradas más antiguas
SchemaMigrator.currentVersion	migrador	4	
PayloadCipher.currentVersion	cifrado	2	Un sobre con versión mayor se rechaza
HandheldFrame.maxWidth	app.dart	560	Por encima, la interfaz se centra a ese ancho

<code>_repeatWindow</code>	<code>scanner_screen.dart</code>	2500 ms	Ventana de repetición del mismo código
<code>MobileScannerEngine.inspectionResolution</code>	Resolución de captura	<code>Size(1920, 1080)</code>	Resolución pedida en inspección
<code>MobileScannerEngine.inventoryResolution</code>	Resolución de captura	<code>Size(1280, 720)</code>	Resolución pedida en inventario
maxPages de <code>PdfPageRenderer.pickAndRender</code>	PDF	50	Se ignoran las páginas siguientes
<code>limit de pickMultiImage</code>	escáner	20	Máximo de imágenes por lote

Valores por defecto de `QrAnalysisPolicy`

Campo	Valor	Regla que lo consume
<code>maxLength</code>	240	<code>url-excessive-length</code>
<code>maxDomainLabels</code>	5	<code>host-deep-subdomains</code>
<code>allowPrivateTargets</code>	false	<code>host-private-or-local</code>
<code>trustedBrands</code>	<code>[]</code>	<code>brand-domain-mismatch</code>

Tipos de datos

Enumeraciones

Enum	Archivo	Valores
<code>QrSeverity</code>	investigación	<code>normal, warning, critical</code>
<code>QrFindingConfidence</code>	investigación	<code>low, medium, high</code>
<code>QrFindingCategory</code>	investigación	<code>transport, identity, obfuscation, destination, credential, download, redirect, sensitiveAction</code>

QrActionDecision	investigación	allow, confirm, inspectOnly, block
ContentKind	parsed_content.dart	url, wifi, contact, event, email, phone, sms, geo, otp, gs1, isbn, product, payment, crypto, identity, binary, text
RiskLevel	analizador	low, caution, high — legado
AppLanguage	ajustes	system, esCl, es, en — en no se ofrece
ImportStrategy	importación	merge, skipDuplicates, replace
RecoveryEntityType	recuperación	history, inventory, migration, database, startup
RecoveryIssueState	recuperación	unresolved, recovered, deleted
ScanPhase	barra de estado	starting, scanning, captured, paused, unavailable

Estructuras principales

Clase	Campos
QrEvidenceFact	id, value
QrFinding	id, severity, score, confidence, category, evidence[]
QrInvestigation	engineVersion, analyzedAt, payloadSha256, severity, score, action, normalizedHost?, effectiveUri?, findings[], hypotheses[], evaluatedRuleIds[], limitations[]
ParsedContent	kind, title, summary?, fields, sensitive
ScanRecord	id, rawValue, displayValue, format, contentType, scannedAt, source, riskLevel, riskReasons[], canOpen, parsed, investigation, favorite, tags[], notes
InventoryItem	code, format, label, quantity, firstScannedAt, lastScannedAt, notes
InventorySession	id, name, createdAt, closedAt?, items
RecoveryIssue	id, entityType, entityId, detectedAt, code, state, encryptedPayload?
CipherEnvelopeInfo	version, algorithm, keyId, legacy
HistoryMigrationStatus	completed, migrated, errorCode?, backupPresent
EncryptionRotationResult	keyId, historyRecords, inventorySessions
SchemaMigrationResult	fromVersion, toVersion, applied[]

ScannerViewportGeometry	compact, statusReserve, controlsReserve, scanWindow
RenderedPdfPage	pageNumber, imagePath
DiagnosticEntry	at, area, errorType, stackFingerprint

Funciones y métodos principales

QrInvestigationEngine.analyze

Aspecto	Detalle
Archivo	lib/core/investigation/qr_investigation_engine.dart
Firma	static QrInvestigation analyze(String rawValue, {ParsedContent? parsed, QrAnalysisPolicy policy = const QrAnalysisPolicy(), DateTime? analyzedAt})
Propósito	Producir hechos, hipótesis, decisión y límites a partir de una carga
Retorna	QrInvestigation serializable
Excepciones	Ninguna: toda entrada produce un resultado
Efectos secundarios	Ninguno. Función pura
Invocada por	ScanSecurityAnalyzer.analyze y, a través de él, las tres fábricas de ScanRecord
Invoca	_declaredScheme, _toWebUri, _rawAuthority, _isIpAddress, _isPrivateOrLocalHost, _hasMixedScripts, _containsControlOrInvisible, _safeDecode, _looksLikeCredentialLure, _nestedRedirect, _sameHostFamily, _brandMismatch, _comparable, _hostMatches
Ejemplo	analyze('https://xn--ppl-43d.example/login') → severity: critical, hallazgos host-punycode y credential-lure-path, hipótesis qr-phishing-suspected y credential-theft-suspected
Riesgo al modificar	Cambiar condición o peso sin subir engineVersion rompe la comparabilidad de las evidencias ya exportadas. verify_rootcause_contract.py falla si el número de reglas deja de ser 26 o si un id no existe en esquema, textos y heurísticas

QrEvidenceExporter.toMap

Aspecto	Detalle
---------	---------

Firma	<code>static Map<String, Object?> toMap(ScanRecord record, {bool includeRawPayload = false, String? previousEvidenceHash})</code>
Propósito	Paquete forense portable
Excepciones	<code>ArgumentError</code> si <code>previousEvidenceHash</code> no es SHA-256 hexadecimal en minúsculas
Efectos secundarios	Ninguno
Riesgo al modificar	Con <code>includeRawPayload</code> en <code>false</code> debe eliminar <code>effectiveUri</code> ; sin eso una consulta con token reaparece por una ruta secundaria

`QrEvidenceExporter.verify`

Aspecto	Detalle
Firma	<code>static bool verify(Map<String, dynamic> bundle)</code>
Retorna	<code>true</code> si <code>bundleHash</code> coincide con el recalculado sobre el JSON canónico
Nota	Es un checksum sin clave. No prueba autoría; el campo <code>assurance</code> lo declara

`PayloadCipher`

Método	Firma	Excepciones
<code>encryptJson</code>	<code>Future<String> encryptJson(Map<String, dynamic> value, {String? keyId})</code>	<code>StateError('encryption_key_missing:<id>')</code> si la llave ya se marcó ausente
<code>decryptJson</code>	<code>Future<Map<String, dynamic>> decryptJson(String encoded)</code>	<code>FormatException</code> por versión o algoritmo; <code>StateError</code> por llave ausente; error de MAC si la carga fue manipulada
<code>inspect</code>	<code>CipherEnvelopeInfo inspect(String encoded)</code>	<code>FormatException</code> si no es JSON
<code>upgradeEnvelope</code>	<code>Future<String> upgradeEnvelope(String encoded)</code>	Las de descifrado
<code>activateKey</code>	<code>void activateKey(String keyId)</code>	<code>ArgumentError</code> si el id está vacío

`ScanRecord.fromJson`

Aspecto	Detalle
---------	---------

Firma	<code>factory ScanRecord.fromJson(Map<String, dynamic> json, {bool trustDerivedAnalysis = true})</code>
Riesgo al modificar	Con <code>true</code> acepta el análisis del archivo; la importación debe pasar <code>false.verify_rootcause_contract.py</code> comprueba que <code>import_service.dart</code> contiene <code>trustDerivedAnalysis: false</code>

`ImportService.parseHistoryBytes`

Aspecto	Detalle
Firma	<code>static HistoryImportPreview parseHistoryBytes(List<int> bytes, {required Set<String> existingIds, String fileName = 'respaldo.json'})</code>
Excepciones	<code>FormatException</code> por tamaño, forma, aplicación incompatible, tipo, versión futura o exceso de registros
Efectos secundarios	Ninguno: no toca la base. La escritura ocurre después, en <code>ScanStore.importPreview</code>

`DataMaintenanceService.rotateEncryptionKey`

Aspecto	Detalle
Firma	<code>Future<EncryptionRotationResult> rotateEncryptionKey()</code>
Excepciones	<code>StateError('encryption_rotation_in_progress')</code> , <code>history_payload_missing:<id></code> , <code>inventory_payload_missing:<id></code>
Efectos secundarios	Reescribe historial e inventario y cambia la llave activa, todo en una transacción
Riesgo al modificar	Mover el cifrado dentro de la transacción alarga el bloqueo y reabre la posibilidad de un estado mixto

Otras funciones de consulta frecuente

Función	Archivo	Qué devuelve
<code>ScanRecord.payloadForBarcode</code>	modelo	Texto del código o <code>binary-base64:<...></code> ; cadena vacía si no hay nada
<code>ContentInterpreter.parse</code>	servicio	<code>ParsedContent</code> , incluida la marca <code>sensitive</code>
<code>ScanSecurityAnalyzer.normalizedActionUri</code>	modelo	<code>Uri</code> accionable o <code>null</code>
<code>ScannerViewportGeometry.forSize</code>	escáner	Geometría del marco sin solapes
<code>navigationLabelBehaviorForWidth</code>	<code>app.dart</code>	Ocultar las etiquetas por debajo de 360 dp

<code>AsyncWriteQueue.run<T></code>	rendimiento	Encola una operación y devuelve su valor o su error
<code>installGlobalErrorHandlers</code>	diagnóstico	Nada; instala los capturadores globales

Los 26 identificadores de regla

`transport-http`, `authority-userinfo`, `host-punycode`, `host-mixed-script`, `host-unicode`, `host-ip-literal`, `host-private-or-local`, `host-shortener`, `host-deep-subdomains`, `host-trailing-dot`, `host-hyphen-density`, `host-empty`, `port-unusual`, `url-excessive-length`, `url-control-character`, `authority-obfuscated`, `encoded-separator`, `download-dangerous-extension`, `credential-lure-path`, `tracking-excessive`, `redirect-nested-domain`, `brand-domain-mismatch`, `scheme-blocked`, `sensitive-secret`, `payment-instruction`, `opaque-binary-payload`.

Condición, severidad, peso, confianza y falso positivo de cada una: [../rootcause/HEURISTICS.md](https://rootcause.com/HEURISTICS.md).

Las 6 hipótesis

`qr-phishing-suspected`, `credential-theft-suspected`, `malware-delivery-suspected`, `payment-substitution-review`, `local-network-lure`, `unsafe-uri-execution`.

Los 7 límites declarados

`no-remote-reputation`, `no-dns-resolution`, `no-certificate-validation`, `no-redirect-following`, `no-domain-age-check`, `no-visual-sticker-tamper-detection`, `no-destination-safety-guarantee`.

Identificadores de evidencia

`scheme`, `host`, `normalizedHost`, `port`, `extension`, `subdomainLabels`, `length`, `redirectHost`, `redirectParameter`, `brandId`, `token`, `trackingParameters`, `contentKind`.

Claves de preferencias

Clave	Tipo	Por defecto	Se restablece con <code>resetNonSensitive</code>
<code>theme_mode</code>	String	system	Sí
<code>language</code>	String	system	Sí
<code>sound_enabled</code>	bool	true	Sí
<code>vibration_enabled</code>	bool	true	Sí
<code>save_history</code>	bool	true	No
<code>private_mode</code>	bool	false	No
<code>auto_torch</code>	bool	false	Sí
<code>use_scan_window</code>	bool	true	Sí
<code>confirm_before_open</code>	bool	true	Sí

hide_sensitive_values	bool	true	Sí
biometric_lock	bool	false	No
high_contrast	bool	false	Sí
large_controls	bool	false	Sí
reduce_motion	bool	false	Sí
clear_clipboard_seconds	int	30	Sí
history_retention_days	int	0 (sin límite)	Sí
feature_flags	String JSON	todas false	Sí
scan_history_v1	String	—	Origen heredado que se migra y se borra
scan_history_v1_backup	String	—	Respaldo cifrado del origen heredado
history_migrated_to_v2	bool	—	Marca de migración completada
history_migration_error	String	—	Código del último fallo de migración
encryption_active_key_id	String	—	Se traslada a la base y se borra de preferencias

Almacenes de la base de datos

Almacén	Clave	Contenido
scan_history	id del registro	id, scannedAt, payload cifrado
inventory_sessions	id de sesión	id, createdAt, payload cifrado
recovery_issues	id determinista	Incidencia serializada con su sobre
_schema_meta	nombre del metadato	Versión de esquema y marcas
_security_meta	encryption_active_key_id	Identificador de la llave activa

Rutas de navegación

No hay rutas con nombre ni router declarativo. La navegación es:

Destino	Cómo se llega
Cinco secciones principales	Índice del <code>NavigationBar</code> en <code>HomeShell</code>
Hoja de resultado	<code>showModalBottomSheet</code> desde el escáner o el historial
<code>FormatsScreen</code>	<code>MaterialPageRoute</code> desde Ajustes

RecoveryScreen	MaterialPageRoute desde Ajustes
Diálogos	showDialog en el punto de uso

Endpoints

No identificados. El sistema no expone ni consume ningún endpoint HTTP. Ver [09-apis-and-integrations.md](#).

Comandos

Comando	Efecto
<code>flutter pub get</code>	Resuelve dependencias
<code>python tool/bootstrap.py --platforms android,web</code>	Genera y parchea las carpetas nativas
<code>python tool/validate_structure.py --require-lock</code>	14 comprobaciones offline
<code>python tool/verify_rootcause_contract.py</code>	Coherencia del contrato de reglas
<code>flutter analyze --fatal-infos</code>	Análisis estático estricto
<code>flutter test</code>	87 casos
<code>flutter build apk --release</code>	APK instalable
<code>python tool/generate_source_manifest.py</code>	Regenera los hashes de la fuente
<code>python tool/build_system_documentation_pdf.py</code>	Genera los PDF de esta documentación

Archivos de configuración

Archivo	Formato	Qué configura
<code>pubspec.yaml</code>	YAML	Dependencias, versión, assets
<code>analysis_options.yaml</code>	YAML	Lints
<code>.fvmrc</code>	JSON	Versión de Flutter
<code>.gitattributes</code>	texto	Finales de línea LF
<code>config/rootcause-qr-policy.example.json</code>	JSON	Ejemplo de política, no se carga en tiempo de ejecución
<code>.github/workflows/*.yaml</code>	YAML	CI, release y publicación de la landing
<code>.github/dependabot.yaml</code>	YAML	Actualizaciones, con <code>pdf-rx</code> bloqueado por encima de 2.4.5

Códigos de error

Estos códigos aparecen en las incidencias de recuperación, en las excepciones y en las preferencias. Son cadenas estables, aptas para diagnóstico.

Código	Origen	Significado
missing_payload	repositorios	El registro no tiene sobre cifrado
decrypt_<Tipo>	repositorios	El descifrado falló; <Tipo> es la clase de la excepción
legacy_<Tipo>	migración de historial	La conversión del historial heredado falló
encryption_key_missing:<keyId>	PayloadCipher	La llave de ese sobre no está en el almacén
encryption_rotation_in_progress	mantenimiento	Ya hay una rotación en curso
history_payload_missing:<id>	rotación	Un registro de historial está incompleto
inventory_payload_missing:<id>	rotación	Una sesión está incompleta
migration_limit_exceeded	migración	El resultado superaría los 5000 registros
migration_verification_failed	migración	La transacción no contiene todo lo esperado
history_v1_to_v2	recuperación	Identificador de la incidencia de migración
legacy_not_list	migración	El historial heredado no era una lista

Los `FormatException` de importación llevan mensaje en español legible por la persona y se muestran como «El respaldo no es válido o no pudo leerse».

Códigos de la cámara

Código de <code>MobileScannerErrorCode</code>	Mensaje mostrado
permissionDenied	«Falta el permiso de cámara. Actívalo en los ajustes del sistema y vuelve a intentarlo.»
unsupported	«Este dispositivo no permite leer códigos con la cámara.»
cualquier otro	«La cámara no pudo iniciarse. Toca «Reintentar».»

06 · Explicación profunda del código

Este documento explica **cómo funciona por dentro** cada módulo importante: su flujo, sus decisiones condicionales, sus cambios de estado y sus casos límite. Las funciones triviales —`copyWith`, `toJson` simétricos, etiquetas de presentación— no se detallan aquí; están inventariadas en [04-code-map.md](#) y [05-technical-reference.md](#).

1. Arranque: de `main()` a la primera pantalla

Archivos: `lib/main.dart`, `lib/bootstrap.dart`, `lib/bootstrap_host.dart`

Objetivo

Dejar la aplicación en uno de dos estados válidos: funcionando con sus servicios listos, o mostrando una pantalla de recuperación que permita salir del problema. Nunca en una pantalla en blanco.

Flujo

`main()` hace tres cosas antes de dibujar nada:

1. `WidgetsFlutterBinding.ensureInitialized();`
2. `installGlobalErrorHandlers()`, que engancha `FlutterError.onError` y `PlatformDispatcher.instance.onError`;
3. `runZonedGuarded(() => runApp(...), ...)`, que captura los errores asíncronos que escapan de todo lo anterior.

El orden importa: los capturadores se instalan **antes** de `runApp`, así que un fallo durante la construcción del primer widget ya queda registrado.

`AppBootstrapper.initialize` compone el sistema en un orden que no es arbitrario:

```
1. AppDatabase.open() o openTemporary() → ejecuta SchemaMigrator.migrate()
2. RecoveryRepository(database)
3. EncryptionMetadataRepository(database)
4. activeKeyId = temporary ? 'v2' : await metadata.loadActiveKeyId()
5. PayloadCipher(keyProvider: temporary ? memoria : Keychain, activeKeyId)
6. SettingsStore.initialize()
7. Future.wait([ScanStore.initialize(), InventoryStore.initialize()])
8. scans.pruneOlderThan(settings.value.historyRetentionDays)
```

Por qué ese orden. El paso 4 lee el identificador de llave activa **desde la base de datos**, no desde preferencias: si una rotación anterior se interrumpió, la base es la única fuente que coincide con los registros ya reescritos. El paso 5 no puede ocurrir antes, porque necesita ese identificador. El paso 8 va al final porque necesita la preferencia de retención ya cargada.

Decisiones condicionales

```
if (temporary) {
  try { await settings.initialize(); } on Object { /* ... */ }
} else {
  await settings.initialize();
}
```

En modo temporal, un fallo al leer preferencias **se ignora**. Es deliberado: ese modo existe precisamente para arrancar cuando el almacenamiento del sistema no responde. En modo normal el mismo fallo sí se propaga, porque

significa que algo está roto y la persona debe saberlo.

Tratamiento de errores

```
} on Object {  
  await database?.close();  
  rethrow;  
}
```

Cualquier excepción cierra la base antes de relanzar. Sin esto, un reintento encontraría el archivo abierto por la instancia anterior.

BootstrapHost captura ese error y construye `StartupFailure`, que reduce el fallo a **tipo de error y huella de las cuatro primeras líneas de la pila**. El mensaje mostrado es fijo y no proviene de la excepción, porque un mensaje puede arrastrar una ruta de archivo o un valor de la persona.

Casos límite

- **Base corrupta o permisos denegados:** «Inicio seguro» con cuatro salidas.
- **Modo temporal:** `MemoryEncryptionKeyProvider` y base en memoria con nombre único por microsegundo. Nada de esa sesión es recuperable después.
- **Preferencias corruptas:** «Restablecer preferencias visuales» borra 14 claves y conserva `save_history`, `private_mode` y `biometric_lock`.

2. El motor de reglas

Archivo: `lib/core/investigation/qr_investigation_engine.dart`

Objetivo

Convertir una carga en hechos observables, sin red y de forma determinista.

Entrada y salida

Entra (`rawValue`, `parsed?`, `policy`, `analyzedAt?`). Sale un `QrInvestigation`.

Flujo interno, bloque a bloque

Bloque 0 — preparación.

```
final String value = rawValue.trim();  
final String lower = value.toLowerCase();
```

La copia de trabajo se recorta para que el parser de URI tolere espacios accidentales. **La huella, en cambio, se calcula sobre `rawValue` sin recortar:**

```
payloadSha256: sha256.convert(utf8.encode(rawValue)).toString(),
```

Es una decisión de seguridad. Dos códigos visualmente idénticos que difieran en un byte invisible producen huellas distintas, que es justo lo que una investigación necesita distinguir. Una prueba lo fija: `analyze('\nhttps://...\n')` debe tener distinta huella que la versión limpia, y además disparar `url-control-character`.

Bloque 1 — clasificación de la carga.

```
final String? declaredScheme = _declaredScheme(value);
final bool safeAction = declaredScheme != null && _safeActionSchemes.contains(declaredScheme);
final Uri? webUri = _toWebUri(value);
```

`_toWebUri` antepone `https://` si la carga empieza por `www.`, y devuelve `null` si el esquema resultante no es `http` ni `https`. `_safeActionSchemes` contiene `mailto`, `tel`, `sms`, `smsto` y `geo`: son acciones que pueden entregarse a otra aplicación pero no son web.

Bloque 2 — reglas independientes del host.

`url-control-character` se evalúa para cualquier URI accionable, no solo web. Es la única regla que examina `rawValue` en lugar de la copia recortada, y detecta:

- runas de control (`< 0x20`, `0x7F`);
- espacios de ancho cero y BOM (`200B`, `200C`, `200D`, `FEFF`);
- controles bidireccionales (`202A–202E`, `2066–2069`);
- sus equivalentes codificados en porcentaje (`%00–%1f`, `%7f`, `%e2%80%8b`, `%ef%bb%bf`).

Dispara `forceBlock`. El motivo: un control bidireccional puede hacer que una URI se **muestre** de una forma y se **interprete** de otra.

`sensitive-secret`, `payment-instruction` y `opaque-binary-payload` dependen del tipo de contenido que aportó el intérprete, con una comprobación de prefijo como respaldo por si el intérprete no estuviera disponible.

`scheme-blocked` solo se evalúa cuando no hay URI web ni acción segura, y solo dispara si el esquema no está en la lista de estructuras conocidas (`wifi`, `otpauth`, `bitcoin`, `mecard`, `begin`, `binary-base64`...). Es la regla que bloquea `javascript:` y cualquier esquema de aplicación desconocido.

Bloque 3 — reglas de URL. Solo se ejecutan si `webUri != null`. Trabajan sobre tres vistas distintas de la misma URL, y la distinción es importante:

Vista	Cómo se obtiene	Quién la usa
<code>webUri.host</code> normalizado	El parser de Dart	Punycode, mixed-script, IP, acortador, subdominios
<code>_rawAuthority(value)</code>	Texto entre <code>://</code> y el primer <code>/</code> , <code>#</code> o <code>?</code>	<code>authority-obfuscated</code> , <code>encoded-separator</code> , <code>host-trailing-dot</code>
<code>_safeDecode(webUri.path)</code>	Ruta decodificada, tolerante a error	<code>download-dangerous-extension</code>

Usar la autoridad **cruda** es lo que permite detectar `\`, espacios o varios `@`: el parser normalizado ya los habría absorbido o reinterpretado.

Bloque 4 — agregación.

```
severity = hay algún critical ? critical : hay algún warning ? warning : normal
score    = suma de pesos, acotada a [0, 100]
```

La severidad **no** se deriva del puntaje. El puntaje ordena evidencia; no es una probabilidad.

Bloque 5 — decisión.

```
if (forceBlock)      action = block;
else if (webUri != null) action = findings.isEmpty ? allow : confirm;
else if (safeAction)  action = confirm;
else                  action = inspectOnly;
```

Una URL crítica pero interpretable queda en `confirm`, no en `block`. La razón: bloquear no significa «malicioso», significa «no puedo entregar esto sin ambigüedad». Un dominio con Punycode es entregable; una autoridad con dos `@` no lo es.

Bloque 6 — hipótesis. Se derivan de conjuntos de ids, nunca del puntaje, y **no suman puntos**. `credential-theft-suspected` exige la coexistencia de `credential-lure-path` con una señal de identidad o de ocultación de destino: sin esa condición, cualquier página de acceso legítima la dispararía.

Casos límite tratados

Caso	Tratamiento
Host que empieza por <code>fc</code>	<code>_isPrivateOrLocalHost</code> exige <code>h.contains(':')</code> antes de mirar prefijos IPv6, así que <code>fca.example</code> no se confunde con una IPv6 privada. Hay una prueba dedicada
Ruta con codificación inválida	<code>_safeDecode</code> captura <code>FormatException</code> y devuelve el original
Parámetro de redirección relativo al protocolo	<code>//host/x</code> se completa con el esquema visible antes de comparar
Redirección al mismo dominio	<code>_sameHostFamily</code> compara por sufijo; no dispara si comparten familia
Token de marca demasiado corto	Se ignora por debajo de 4 caracteres alfanuméricos
Hallazgo repetido	<code>_FindingCollector</code> deduplica por id

Riesgos al modificar

Cambiar peso o condición sin subir `engineVersion` deja dos exportaciones con la misma versión y distinto significado. Mover una regla fuera de su bloque cambia qué ids aparecen en `evaluatedRuleIds`, que es cómo un lector distingue «la regla no aplicó» de «la regla no se ejecutó».

3. El intérprete de contenido

Archivo: `lib/services/content_interpreter.dart`

Objetivo

Convertir la carga en campos legibles y decidir si es sensible.

El orden de las ramas es el algoritmo

`parse` es una cadena de comprobaciones cuyo **orden es significativo**, porque varios formatos comparten forma:

1. prefijo `binary-base64`;
2. esquemas explícitos: `wifi`;, `begin:vcard`, `mecard`;, `begin:vevent`, `mailto:matmsg`;, `tel`;, `sms:smsto`;, `geo`;, `otpauth`;, `bitcoin`:/lightning:/ethereum;;
3. cabeceras fijas de pago: `SPC`\n (Swiss QR), `BCD`\n (EPC/SEPA), `000201` con `6304` (EMVCo);
4. `@` con `ANSI` (AAMVA);
5. GS1 por paréntesis de identificador de aplicación;
6. ISBN por longitud y prefijo;

7. URL web;
8. producto numérico de 8 a 14 dígitos;
9. texto plano.

Reordenar estas ramas cambia la interpretación de cargas reales. Por ejemplo, mover la comprobación de URL antes que la de esquemas rompería `mailto:` con consulta.

La decisión de `sensitive`

Es la que determina si un registro puede guardarse en el historial automático. Se activa en cinco situaciones:

Situación	Condición
OTP	<code>otpauth</code> : siempre marca sensible
Wi-Fi con contraseña	<code>values['P']</code> no vacío
Pago	EMVCo, EPC, Swiss QR y cripto siempre
Identidad	AAMVA siempre
URL con secreto	Ver abajo

Para URL, se comprueban 17 claves (`token`, `secret`, `password`, `code`, `jwt`, `sig`, `signature`, `access_token`, `api_key`, `apikey`, `auth`, `authorization`, `credential`, `key`, `otp`, `samlresponse`, `session`) en tres lugares: `userInfo` no vacío, nombres de parámetros de consulta, y el fragmento.

El fragmento merece atención: se comprueba con una expresión regular `(?:^|[\?&])clave=` en lugar de `contains`, para no marcar como sensible una URL cuyo fragmento simplemente contenga la palabra. Una prueba cubre el caso de un correo dentro de la consulta que **no** debe clasificarse como credencial.

Auxiliares con lógica propia

- `_segments` analiza el formato `CLAVE:valor;` de Wi-Fi y MeCard respetando el escape con `\`, para que una contraseña con `;` o `:` no parta el registro.
- `_tlv` recorre la estructura tipo-longitud-valor de EMVCo con avance explícito y se detiene ante una longitud imposible, en lugar de lanzar.

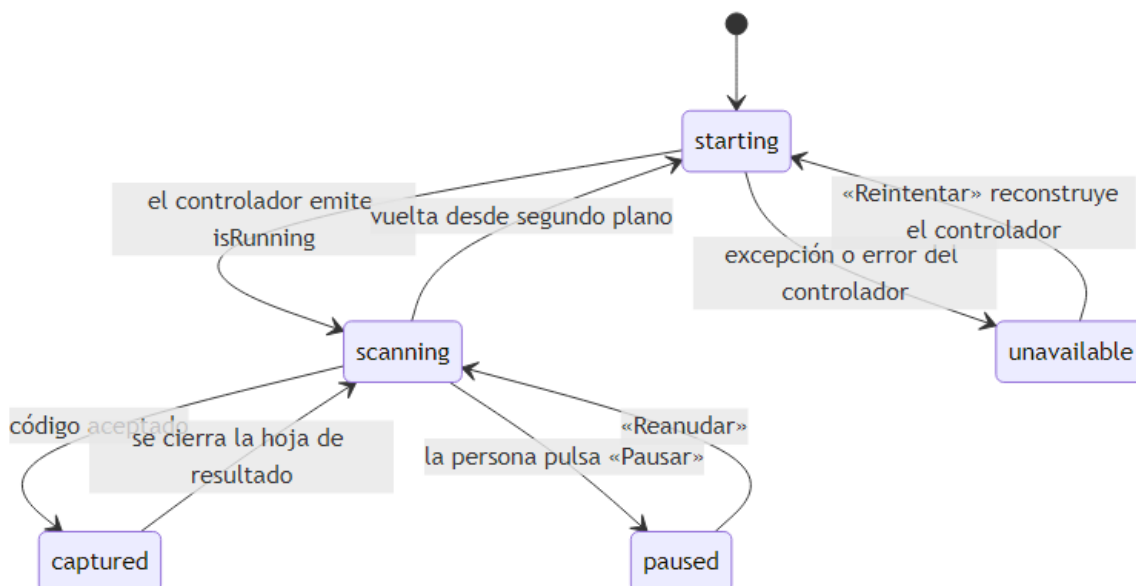
4. La pantalla de inspección

Archivo: `lib/features/scanner/scanner_screen.dart`

Objetivo

Que en todo momento se sepa qué está haciendo la cámara, y que ninguna lectura se descarte en silencio.

Máquina de estados



La función que decide es corta y su orden importa:

```

if (_startFailure != null || state.error != null) return ScanPhase.unavailable;
if (_handlingResult) return ScanPhase.captured;
if (_paused) return ScanPhase.paused;
if (state.isRunning) return ScanPhase.scanning;
return ScanPhase.starting;

```

`_handlingResult` se comprueba **antes** que `_paused`. Antes de la versión 0.1.1 ambos producían `paused`, de modo que una lectura conseguida se anunciaba con el vocabulario del estado contrario: «Inspección en pausa».

handleCapture, paso a paso

1. **Guardas.** Si ya se está atendiendo un resultado, si está en pausa o si el widget se desmontó, sale.
2. **Deduplicación dentro del cuadro.** Varios códigos en la misma imagen se reducen a un mapa por carga; los vacíos se descartan.
3. **Firma.** Las cargas se ordenan y se unen con `|`. Ordenar es lo que hace que el mismo par de códigos produzca la misma firma aunque el motor los entregue en distinto orden.
4. **Filtro de repetición.**

```

dart if (misma firma && ahora - _lastDetectedAt < 2,5 s) { _lastDetectedAt = ahora; // el enfriamiento se renueva mientras el código siga a la vista _showRepeatNotice(); // y se explica return; }

```

Renovar `_lastDetectedAt` es lo que evita el bucle: si el código permanece delante del lente, no se reabre su resultado cada 2,5 segundos. En cuanto se aparta, el temporizador expira y volver a apuntar lo lee de nuevo.

5. **Transición a captured** y parada de la cámara. 6. **Confirmación sin bloquear.**

`unawaited(_feedback.success(...))`. Esperar la reproducción retrasaba el resultado, sobre todo en la primera lectura. 7. **Construcción de los registros** con un único `scannedAt` compartido, para que varios códigos del mismo cuadro sean correlacionables. 8. `_persistAndShow`. 9. **finally:** se renueva `_lastDetectedAt` con el instante del cierre, se vuelve a `scanning` y se reanuda la cámara si no hay pausa manual.

_persistAndShow: la política de persistencia

```

if (_settings.saveHistory && !_settings.privateMode) {
  final persistent = records.where((r) => !r.isSensitive).toList();
  await widget.store.addAll(persistent);
}

```

Tres condiciones deben cumplirse para guardar. El filtro por `isSensitive` es **incondicional**: aunque la persona tenga el historial activado, un QR con secreto OTP o contraseña Wi-Fi no se escribe. Se muestra igual en el resultado inmediato, que vive solo en memoria.

Ciclo de vida y recuperación de la cámara

MobileScanner solo gestiona el ciclo de vida cuando él crea el controlador. Aquí lo crea la pantalla, así que le corresponde:

- `resumed` → `_startCamera()` si no hay pausa ni resultado abierto;
- `inactive` → `_stopCamera()`.

`_restartCamera` es la vía de recuperación: para, desecha, y **solo entonces** crea uno nuevo con una `UniqueKey` distinta. El orden es obligatorio: ambos controladores comparten una única sesión de cámara de la plataforma, y desechar el viejo después de crear el nuevo derribaría la sesión recién tomada. Además limpia `_lastSignature`, porque un reinicio manual es un «inténtalo otra vez» explícito.

Lotes de imagen y PDF

Ambos comparten `_runBatchDialog`, que abre un diálogo modal no descartable con progreso y botón de cancelar, ejecuta la operación y garantiza en su `finally` que el diálogo se cierra y que el testigo y el progreso se liberan.

Dentro del lote: se detiene la cámara, se procesa imagen por imagen comprobando la cancelación entre cada una, y se cede el hilo con `await Future<void>.delayed(Duration.zero)` para que la interfaz siga respondiendo. El `finally` interno reanuda la cámara y, en el caso del PDF, borra los PNG temporales.

La cancelación se distingue del error: `OperationCancelledException` produce «Análisis cancelado sin modificar el historial», y cualquier otra excepción produce un mensaje de fallo. En ambos casos el historial queda intacto.

5. El cifrado

Archivo: `lib/core/security/payload_cipher.dart`

Flujo de cifrado

1. se resuelve el identificador de llave (el pasado o el activo);
2. si ese identificador está marcado como ausente, se lanza sin intentar nada;
3. se obtiene o crea la llave;
4. se cifra el JSON con AES-256-GCM;
5. se serializa el sobre con versión, algoritmo, identificador, instante, nonce, texto cifrado y MAC.

Flujo de descifrado y sus tres rechazos

```
final bool legacy = !envelope.containsKey('version');
final int version = legacy ? 1 : envelope['version'] as int? ?? 1;
if (version < 1 || version > currentVersion) throw FormatException(...);
if (algorithm != currentAlgorithm)          throw FormatException(...);
final SecretKey? key = await _keyProvider.read(keyId);
if (key == null) { _missingKeyIds.add(keyId); throw StateError('encryption_key_missing:$keyId'); }
```

La tercera comprobación es la más importante del archivo. El proveedor expone `read` —que puede devolver `null`— y `readOrCreate`. El descifrado usa `read`. Si usara `readOrCreate`, una llave ausente se recrearía vacía y todos los registros anteriores quedarían ilegibles para siempre, sin aviso.

Además, el identificador se apunta en `_missingKeyIds`, lo que **bloquea nuevas escrituras** con esa llave hasta que la persona recupere, rote o descarte de forma explícita.

La manipulación de la carga la detecta el MAC de GCM, no una comprobación propia. Hay una prueba que altera el texto cifrado y espera el rechazo.

6. La rotación de llave

Archivo: `lib/core/security/data_maintenance_service.dart`

Por qué existe en dos fases

Fase 1 (fuera de la transacción): descifrar y volver a cifrar TODO en memoria
Fase 2 (una sola transacción): escribir registros + identificador de llave
Fallo en cualquier punto: revertir y BORRAR la llave nueva del almacén

Si el cifrado ocurriera dentro de la transacción, la base quedaría bloqueada durante operaciones criptográficas de miles de registros. Si el identificador de llave se guardara fuera de la transacción, una interrupción dejaría metadatos apuntando a una llave con la que la mitad de los registros no está cifrada.

El bloque `catch` borra la llave recién generada. Sin eso, un intento fallido dejaría en el almacén seguro material huérfano que una versión posterior podría confundir con una llave activa. Una prueba lo verifica explícitamente.

`_rotationInProgress` impide dos rotaciones simultáneas; la pantalla además deshabilita el control y bloquea la interfaz con un diálogo mientras dura.

7. El historial

Archivo: `lib/services/history_repository.dart`

Lectura: aislar, no borrar

Para cada registro:

- si no hay `payload` → incidencia `missing_payload` y se continúa;
- si el descifrado falla → incidencia `decrypt_<Tipo>` **conservando el sobre original** y se continúa;
- si el sobre es antiguo → se reescribe con el actual, de forma perezosa.

La consecuencia práctica es que **un registro dañado nunca impide leer los demás**, y nada se borra de forma automática.

La migración del historial heredado

Es el procedimiento más delicado del archivo, y su orden es el contrato:

1. si ya está marcada como completada, se informa y se termina;
2. si no hay origen, se marca completada y se termina;
3. **se guarda un respaldo cifrado del origen exacto**, codificado en Base64, antes de tocar nada;
4. se decodifica, se convierte cada registro y se cifra;
5. `_migrateRecordsAtomically` escribe dentro de una transacción y, **dentro de la misma transacción**, comprueba que el conjunto resultante contiene todo lo esperado; si no, lanza y la transacción se revierte;
6. solo entonces se borra la clave antigua y se marca completada;

7. ante cualquier fallo: el origen queda intacto, se guarda el código de error y se crea una incidencia de recuperación.

El paso 3 nunca duplica el historial en claro: el respaldo también va cifrado.

8. La importación como entrada no confiable

Archivo: `lib/services/import_service.dart`

Cinco barreras, en orden

1. **Tamaño**, comprobado dos veces: en el archivo y en los bytes leídos.
2. **Forma**, con `_validateJsonShape`, que recorre el árbol de forma **iterativa** con una pila explícita. No es recursiva a propósito: un JSON diseñado para agotar la pila no puede provocar un desbordamiento. Cuenta nodos y profundidad y aborta al superar 100 000 o 32.
3. **Identidad del sobre**: solo `RootCause QR Inspector` o `Universal Code Scanner`, y solo con el `type` esperado. Una `schemaVersion` superior a la actual se rechaza en vez de interpretarse a medias.
4. **Cantidad**: máximo de registros y de productos por sesión.
5. **Recálculo obligatorio**:

```
dart final ScanRecord record = ScanRecord.fromJson( Map<String, dynamic>.from(value),
trustDerivedAnalysis: false, );
```

Con `false`, `ScanRecord.fromJson` **recalcula** el id como SHA-256(`carga|instante`) y vuelve a ejecutar el motor sobre la carga y el instante originales. El archivo no puede imponer id, puntaje, hallazgos ni decisión. Hay una prueba llamada «un respaldo no puede inyectar un veredicto o id derivados», y `verify_rootcause_contract.py` falla si esa línea desaparece del archivo.

Un registro que falla cualquier validación se cuenta como rechazado y **no interrumpe** la importación del resto. La escritura no ocurre aquí: la vista previa es solo lectura, y la persona elige después la estrategia.

9. El exportador de evidencia

Archivo: `lib/core/investigation/qr_evidence_exporter.dart`

La redacción

```
if (!includeRawPayload) {
  investigation.remove('effectiveUri');
}
```

Esta línea es el corazón del contrato. Omitir `rawPayload` no basta: `effectiveUri` contiene la misma consulta y el mismo token. Sin esta eliminación un paquete «redactado» reconstruiría el secreto por una ruta secundaria.

El campo `redaction` declara cuál de las dos variantes es: `payload-omitted` o `none-user-authorized`. El JSON Schema lo hace obligatorio y, mediante `if/then`, prohíbe `rawPayload`, `parsed` y `effectiveUri` cuando vale `payload-omitted`.

El checksum canónico

```
bundleHash = SHA-256( JSON con claves ordenadas, sin bundleHash )
```

`_canonicalJson` recorre el objeto ordenando las claves de cada mapa. Sin eso, reordenar el JSON —algo que hace cualquier herramienta que lo reescriba— invalidaría un paquete cuyo contenido no cambió. Hay una prueba que invierte el orden de las claves y espera que siga verificando.

Lo que el checksum **no** es, y así lo declara el campo `assurance`: no es firma digital, ni MAC, ni prueba de autoría. Cualquiera que modifique el archivo puede recalcularlo. Sirve para comprobar consistencia frente a una huella obtenida por una ruta confiable.

10. La cola de escrituras del inventario

Archivo: `lib/core/performance/async_write_queue.dart`

Diecinueve líneas que resuelven un problema real:

```
Future<T> run<T>(Future<T> Function() operation) {
  final Completer<T> completer = Completer<T>();
  _tail = _tail.then<void>((_) async {
    try { completer.complete(await operation()); }
    on Object catch (error, stack) { completer.completeError(error, stack); }
  });
  return completer.future;
}
```

El detalle importante es el `try/catch` **dentro** del encadenamiento. Sin él, una operación fallida dejaría `_tail` en estado de error y **toda escritura posterior quedaría descartada en silencio**. Con él, cada llamante recibe su propio resultado o su propio error, y la cola sigue viva. Dos pruebas cubren exactamente eso: el orden de ejecución y el aislamiento de fallos.

El inventario lo necesita porque recibe lecturas continuas de la cámara mientras la persona edita cantidades y notas: dos escrituras simultáneas sobre el mismo mapa de productos se pisarían.

11. El renderizador de PDF

Archivo: `lib/services/pdf_page_renderer_io.dart`

Control de recursos

Control	Valor	Por qué
Páginas	máximo 50	Un PDF de cientos de páginas agotaría la memoria
Escala	lado mayor ≈ 2400 px, acotada a <code>[1.5, 4.0]</code>	Suficiente para leer un QR pequeño sin generar imágenes enormes
Liberación	<code>pdfImage.dispose()</code> y <code>image.dispose()</code> en <code>finally</code>	Cada página se libera en cuanto se escribe en disco
Cancelación	Se propaga al testigo nativo de la página	Cancelar detiene el render en curso, no solo el bucle
Limpieza	En error y al terminar	No deja PNG temporales

La cancelación merece detalle: `cancellationToken.addListener(cancelRender)` se registra antes de renderizar y se retira en el `finally`, y `cancelRender()` se llama también de inmediato por si la cancelación llegó entre

medias.

12. La confirmación de lectura

Archivo: `lib/services/scan_feedback.dart`

Por qué no usa el sonido del sistema

`SystemSound.play(SystemSoundType.click)` se traduce en Android al efecto de sonido de la interfaz, que queda **silenciado en cuanto la persona apaga los sonidos táctiles**. Ese es el ajuste habitual, así que la confirmación desaparecía en la mayoría de los teléfonos. Por eso el tono es un asset propio.

Degradación en cadena

```
warmUp() → construye el reproductor al abrir la pantalla
play()   → si falla, marca el tono no disponible y no vuelve a intentarlo
fallback → SystemSound.play
si falla → silencio, sin excepción
```

La vibración va por un canal independiente y también absorbe su fallo. Ni el sonido ni la vibración pueden romper una lectura: cada `try` termina en un comentario que explica por qué se ignora la excepción.

`AssetScanTonePlayer` configura `mixWithOthers` para no interrumpir música ni llamadas por un tono de una décima de segundo, y hace `seek(Duration.zero)` antes de cada reproducción para que una segunda lectura no salga muda mientras la primera aún suena.

07 · Base de datos

Motor

No hay motor relacional. El sistema usa **Sembast**, una base de datos NoSQL embebida, orientada a documentos, escrita en Dart puro y sin servidor.

Plataforma	Backend	Archivo o almacén
Android e iOS	sembast sobre archivo	<directorio de soporte>/rootcause_qr_inspector_v2.db
Web (demo)	sembast_web sobre IndexedDB	Base rootcause_qr_inspector_v2.db
Otras	database_opener_stub.dart	Lanza <code>UnsupportedError</code>

La elección se resuelve **en compilación**, no en ejecución:

```
export 'database_opener_stub.dart'  
  if (dart.library.io) 'database_opener_io.dart'  
  if (dart.library.js_interop) 'database_opener_web.dart';
```

El sufijo `_v2` del nombre existe porque esta base coexiste con la generación anterior heredada del lector universal.

Consecuencias de este diseño, que conviene tener claras al auditar:

- **no hay credenciales de base de datos**, ni cadena de conexión, ni puerto;
- **no hay SQL**: no existe superficie de inyección SQL;
- **no hay esquema declarado**: los almacenes se crean de forma perezosa;
- la integridad referencial no la impone el motor, sino el código.

Forma de conexión

```
final AppDatabase db = await AppDatabase.open(); // persistente  
final AppDatabase tmp = await AppDatabase.openTemporary(); // en memoria
```

`open()` crea el directorio si falta, abre el archivo con `version: 2` y ejecuta `SchemaMigrator.migrate()` **antes** de devolver la instancia, de modo que ningún repositorio observe un esquema a medio migrar.

`openTemporary()` abre una base en memoria con nombre único por microsegundo (`rcqr_temporary_<micros>`). Es el modo de arranque seguro: la aplicación funciona sin poder tocar ni dañar los datos persistentes.

Configuración necesaria

Ninguna. No hay variables de entorno, archivos de conexión ni migraciones que lanzar a mano.

Almacenes

Sembast llama *store* a lo que en una base relacional sería una tabla. Hay cinco.

`scan_history`

Columna	Tipo	Nulo	Descripción
<i>clave del registro</i>	String	No	Igual a <code>id</code> . SHA-256 truncado a 20 de <code>carga\ instante</code>
<code>id</code>	String	No	Repetido dentro del valor para reconstruir el registro
<code>scannedAt</code>	String ISO-8601 UTC	No	En claro a propósito: permite ordenar y podar sin descifrar
<code>payload</code>	String	No	Sobre AES-256-GCM con el <code>ScanRecord</code> completo

Ordenación: descendente por `scannedAt`. **Límite:** 5000 registros; el recorte elimina los más antiguos. **Quién lo usa:** `HistoryRepository`, `RecoveryService`, `DataMaintenanceService`.

`inventory_sessions`

Columna	Tipo	Nulo	Descripción
<i>clave</i>	String	No	Igual a <code>id</code> . SHA-1 truncado a 16 de <code>micros\ nombre</code>
<code>id</code>	String	No	Identificador de la sesión
<code>createdAt</code>	String ISO-8601	No	En claro, para ordenar
<code>payload</code>	String	No	Sobre cifrado con la <code>InventorySession</code> completa

Ordenación: descendente por `createdAt`. **Quién lo usa:** `InventoryRepository`, `RecoveryService`, `DataMaintenanceService`.

`recovery_issues`

Columna	Tipo	Nulo	Descripción
<i>clave</i>	String	No	SHA-256 truncado a 24 de <code>tipo\ entidad\ código</code> . Determinista: el mismo fallo no genera duplicados
<code>id</code>	String	No	Igual a la clave
<code>entityType</code>	String	No	<code>history</code> , <code>inventory</code> , <code>migration</code> , <code>database</code> o <code>startup</code>
<code>entityId</code>	String	No	Clave del registro afectado
<code>detectedAt</code>	String ISO-8601 UTC	No	Cuándo se detectó
<code>code</code>	String	No	Ver códigos de error en 05-technical-reference.md

state	String	No	unresolved, recovered o deleted
encryptedPayload	String	Sí	El sobre original tal cual. Nunca texto claro

schema_meta

Clave	Tipo	Escrita por
schemaVersion	int	Cada migración
v2MigratedAt	String ISO-8601	Paso 2
recoveryStoreEnabled	bool	Paso 3
cipherEnvelopeVersion	int	Paso 3
encryptionMetadataInDatabase	bool	Paso 4

security_meta

Clave	Tipo	Descripción
encryption_active_key_id	String	Identificador de la llave activa. No es la llave : la llave vive en Keychain/Keystore

Diccionario de datos del contenido cifrado

El payload de scan_history contiene, ya descifrado, un ScanRecord:

Campo	Tipo	Nulo	Descripción
id	String	No	SHA-256 truncado a 20
rawValue	String	No	Carga exacta del código
displayValue	String	No	Valor legible; para binario, «Datos binarios (N bytes)» más la carga
format	String	No	Simbología legible, p. ej. QR Code
contentType	String	No	Título del contenido interpretado
scannedAt	String ISO-8601 UTC	No	Serializado en UTC para que un respaldo movido entre zonas conserve el id
source	String	No	Cámara, Imagen, PDF · página N, Inventario, Importado
riskLevel	String	No	low, caution o high. Derivado

riskReasons	List<String>	No	Explicaciones en español. Derivado
canOpen	bool	No	Derivado
parsed	Object	No	ParsedContent
investigation	Object	No	QrInvestigation completa
favorite	bool	No	Marca de la persona
tags	List<String>	No	Etiquetas de la persona
notes	String	No	Nota libre de la persona

parsed:

Campo	Tipo	Descripción
kind	String	Uno de los 17 ContentKind
title	String	Título en español
summary	String?	Resumen corto
fields	Map<String,String>	Campos legibles
sensitive	bool	Decide si el registro puede persistirse

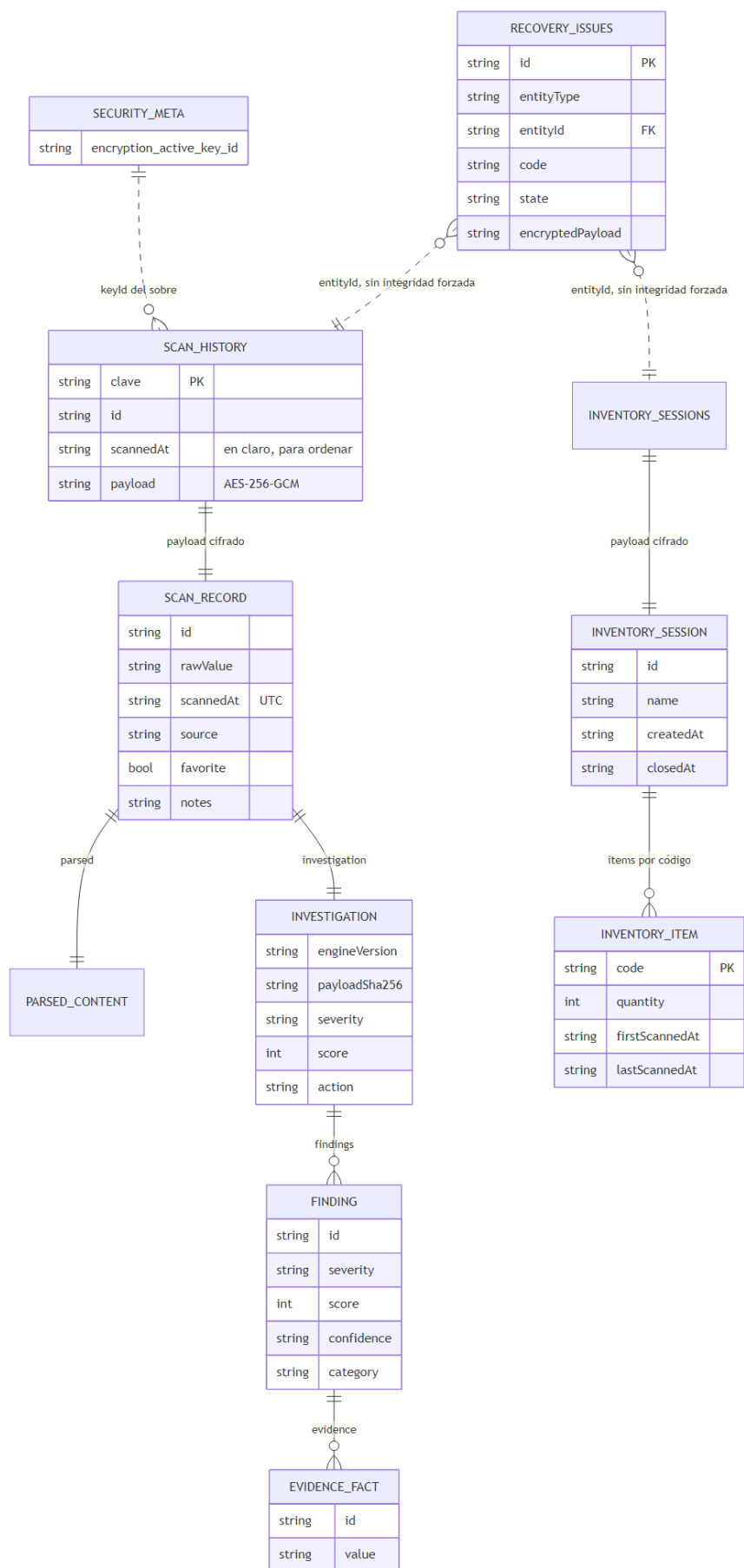
investigation: ver el JSON Schema en [../schemas/rootcause-qr-evidence.schema.json](#), sección \$defs.investigation.

El payload de inventory_sessions contiene una InventorySession:

Campo	Tipo	Descripción
id	String	Identificador
name	String	Nombre dado por la persona
createdAt	String ISO-8601	Apertura
closedAt	String?	Cierre; null mientras esté abierta
items	Map<String, InventoryItem>	Clave: la carga del código

InventoryItem: code, format, label, quantity, firstScannedAt, lastScannedAt, notes.

Relaciones



Explicación del diagrama. Las líneas continuas son contención real: un registro de historial *contiene* un ScanRecord cifrado, que a su vez contiene su interpretación y su investigación. Las líneas punteadas son

referencias **lógicas** que ningún motor valida: una incidencia de recuperación guarda el `entityId` del registro afectado, pero si ese registro se borra la incidencia sobrevive. `RecoveryService.discard` es quien mantiene la coherencia, no la base.

La relación con `_security_meta` es igualmente lógica: cada sobre lleva su propio `keyId`, y el metadato indica cuál es el activo para escribir. Por eso una rotación debe cambiar ambos en la **misma** transacción.

Índices

No hay índices declarados. Sembast no los expone en esta versión de la API. Las consultas usan `Finder` con orden y filtro, que recorren el almacén:

Consulta	Dónde	Coste
Historial ordenado, límite 5000	<code>HistoryRepository.load</code>	Recorrido completo
Registros anteriores a una fecha	<code>HistoryRepository.pruneOlderThan</code>	Filtro <code>Filter.lessThan('scannedAt', corte)</code>
Los más antiguos para recortar	<code>HistoryRepository._trim</code>	Orden ascendente con límite
Sesiones por fecha	<code>InventoryRepository.load</code>	Recorrido completo
Incidencias por fecha	<code>RecoveryRepository.load</code>	Recorrido completo

Que `scannedAt` y `createdAt` estén **en claro** es lo que hace posible ordenar y podar sin descifrar 5000 sobres. Es una decisión de rendimiento con un coste de privacidad declarado: quien acceda al archivo sabe *cuándo* hubo lecturas, aunque no *qué* se leyó.

Restricciones e integridad

Regla	Quién la impone
La clave del historial es el id del registro	<code>HistoryRepository</code> , al escribir
El id es <code>SHA-256(carga\ instante)</code> truncado	<code>ScanRecord</code> , en sus fábricas
La clave de un producto es su carga	<code>InventoryStore.addScan</code>
Un id de incidencia no se duplica	Derivación determinista en <code>RecoveryRepository.record</code>
Solo una sesión activa	<code>InventoryStore.activeSession</code> , que exige <code>isOpen</code>
Un registro sensible no se persiste	<code>ScannerScreen._persistAndShow</code>
Máximo 5000 registros	<code>HistoryRepository._trim</code>

Procedimientos almacenados, funciones y disparadores

No identificados. Sembast no los soporta. Toda la lógica está en Dart.

Migraciones

SchemaMigrator mantiene el número de esquema en `_schema_meta`. Una instalación sin ese registro se interpreta como versión 1.

Paso	Qué escribe	Motivo
2	<code>v2MigratedAt</code>	Marca temporal de la primera migración
3	<code>recoveryStoreEnabled</code> , <code>cipherEnvelopeVersion</code>	Reserva el almacén de recuperación y fija la versión de sobre
4	<code>encryptionMetadataInDatabase</code>	Declara que la llave activa vive en la base

Los cuatro pasos ocurren **dentro de una sola transacción** y son idempotentes: Sembast crea los almacenes de forma perezosa, así que una migración solo escribe metadatos que otros componentes consultan.

`test/core/schema_migrator_test.dart` comprueba que ejecutarla dos veces no produce cambios adicionales.

Hay una segunda migración, independiente del esquema: la del **historial heredado guardado en preferencias**. Está explicada paso a paso en [06-deep-code-explanation.md](#) y documentada en [../quality/MIGRATIONS.md](#).

Datos iniciales

No hay semillas. Una instalación nueva arranca con historial e inventario vacíos. Los únicos datos precargados están en la interfaz del generador, y son valores de ejemplo con dominios reservados.

Transacciones

Operación	Por qué es transaccional
Migración de esquema	O se aplican todos los pasos o ninguno
<code>HistoryRepository.replaceAll</code>	Borrar e insertar debe ser atómico
<code>HistoryRepository.upsertAll</code>	Un lote no puede quedar a medias
<code>pruneOlderThan</code> y <code>_trim</code>	Borrado en bloque
<code>_migrateRecordsAtomically</code>	Escribe y verifica dentro de la misma transacción
<code>rotateEncryptionKey</code>	Registros y llave activa cambian juntos
<code>RecoveryRepository.clearResolved</code>	Borrado en bloque

Patrón común y deliberado: **el cifrado se prepara siempre fuera de la transacción**, y dentro solo quedan las escrituras.

Datos sensibles almacenados

Dato	Dónde	Protección
Carga de los códigos	<code>payload</code> de <code>scan_history</code>	AES-256-GCM
Notas y etiquetas	Dentro del mismo sobre	AES-256-GCM

Códigos de producto	payload de <code>inventory_sessions</code>	AES-256-GCM
Instantes de lectura	<code>scannedAt</code> , <code>createdAt</code>	En claro
Llave de cifrado	Keychain / Keystore	Almacén seguro del sistema
OTP, Wi-Fi con contraseña, pagos, identidad	No se almacenan	Filtrados antes de escribir

Respaldo y recuperación

No hay respaldo automático. No existe exportación programada ni copia en la nube. Las vías disponibles son manuales y explícitas:

Vía	Qué produce	Contiene la carga
Historial → Exportar JSON/CSV/XLSX	Archivo completo	Sí, en claro. La interfaz lo advierte
Inventario → Exportar	Sesión completa	Sí
Recuperación → Copiar paquete	Incidencias con sobres cifrados	No: sin la llave no se leen
Resultado → Evidencia	Paquete redactado de un caso	No, salvo decisión explícita por API

En Android, `tool/bootstrap.py` fija `android:allowBackup="false"` en el manifiesto, así que la base **no entra en la copia de seguridad automática del sistema**. Es coherente con el modelo: la llave vive en el Keystore y no viajaría con la copia, de modo que un respaldo restaurado en otro dispositivo contendría sobres ilegibles.

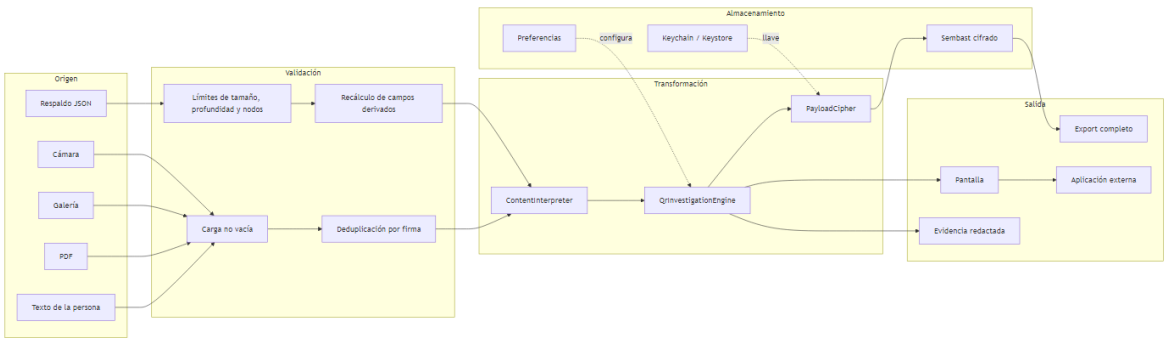
Consecuencia operativa que debe conocerse: desinstalar la aplicación, o perder el dispositivo, significa perder el historial. No hay recuperación posible, por diseño.

Relación entre almacenes y código

Almacén	Repositorio	Store	Pantalla
<code>scan_history</code>	<code>HistoryRepository</code>	<code>ScanStore</code>	Escáner, Historial
<code>inventory_sessions</code>	<code>InventoryRepository</code>	<code>InventoryStore</code>	Inventario
<code>recovery_issues</code>	<code>RecoveryRepository</code>	—	Recuperación
<code>_schema_meta</code>	<code>SchemaMigrator</code>	—	—
<code>_security_meta</code>	<code>EncryptionMetadataRepository</code>		Ajustes (rotación)

08 · Flujo de datos

Panorama



Explicación. Hay dos caminos de entrada con niveles de confianza distintos. La captura pasa por validaciones ligeras porque el contenido es el objeto de estudio; un respaldo importado pasa por límites duros y por un recálculo obligatorio de todo campo derivado. Ambos convergen en el intérprete y el motor. Desde ahí, el dato se bifurca: a la pantalla siempre; a la base solo si supera la política de persistencia; a un archivo solo si la persona lo exporta.

De dónde provienen los datos

Dato	Origen	Confianza	Control aplicado
Carga de un código	Cámara, imagen, PDF	Ninguna: es el objeto de análisis	Nunca se ejecuta; se interpreta y se analiza
Bytes de un código binario	rawDecodedBytes	Ninguna	Se codifica como binary-base64: y se marca opaco
Respaldo de historial	Archivo elegido	Ninguna	Cinco barreras; ver 06
Respaldo de inventario	Archivo elegido	Ninguna	Tamaño, forma, sobre y límite de productos
Preferencias	Almacén del sistema	Media	Valor por defecto conservador por clave
Política de análisis	Código del integrador	Alta	Es configuración, no entrada
Llave de cifrado	Keychain / Keystore	Alta	Nunca se recrea al descifrar
Notas y etiquetas	Teclado	Alta	Se recortan; se guardan cifradas

Cómo se validan

Captura

1. `ScanRecord.payloadForBarcode` descarta el código sin texto ni bytes.
2. Los códigos del mismo cuadro se reducen a un mapa por carga.
3. La firma ordenada de las cargas alimenta el filtro de repetición de 2,5 s.

4. No hay validación de *contenido*: analizar contenido inválido es la función.

Importación

Las cinco barreras están detalladas en [06-deep-code-explanation.md](#). La más importante: todo campo derivado se **recalcula**, así que un archivo no puede imponer un veredicto favorable.

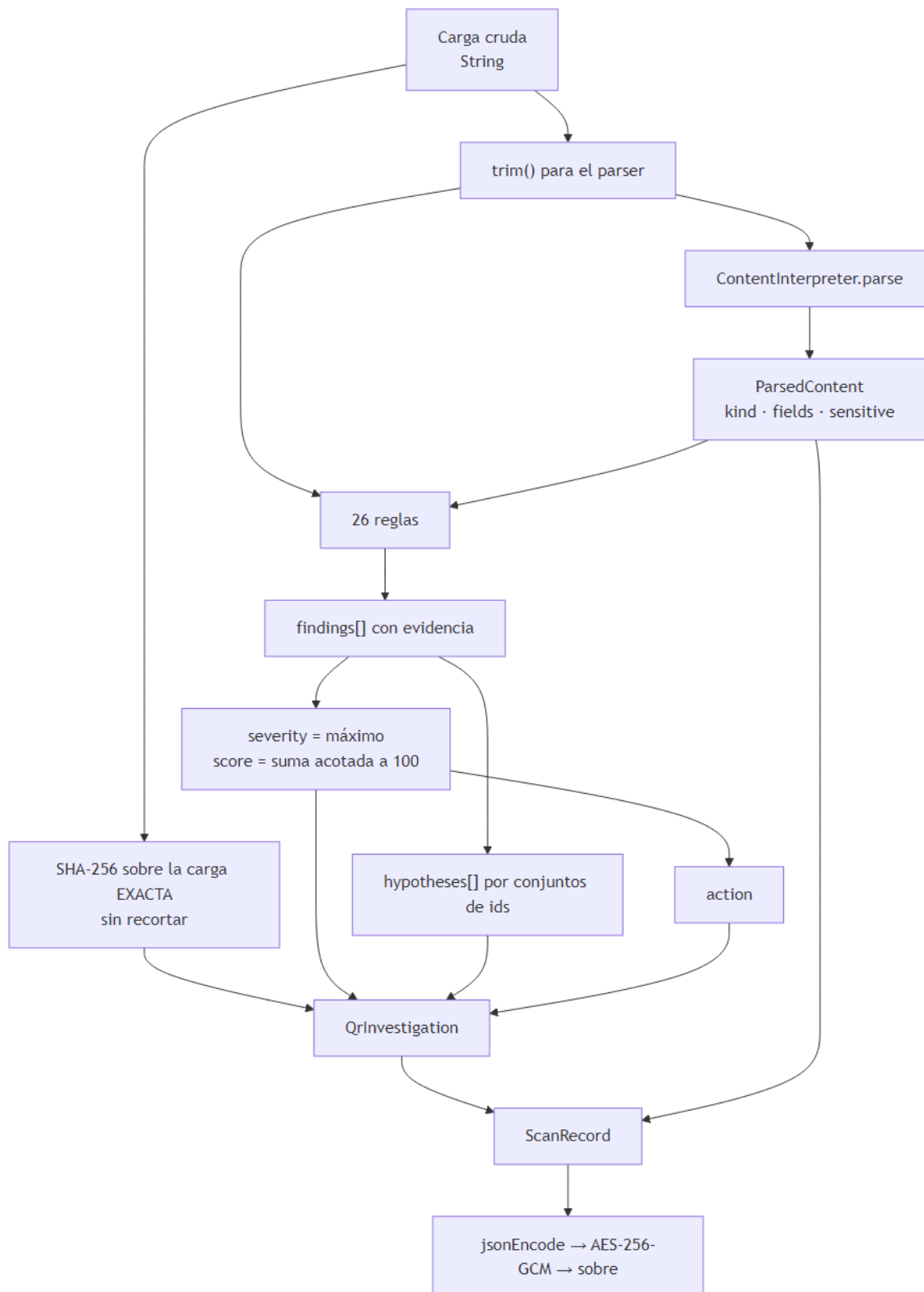
Preferencias

Cada lectura aplica un valor por defecto:

```
soundEnabled: await _preferences.getBool('sound_enabled') ?? true,
```

Las banderas se decodifican dentro de un `try`; si el JSON está corrupto se vuelve a `const FeatureFlags()`, todas apagadas.

Cómo se transforman



Explicación. La bifurcación de la izquierda es deliberada: la huella cubre la carga exacta, mientras que el análisis trabaja sobre una copia recortada. Así, un código con un carácter invisible al principio produce una huella distinta y además dispara `url-control-character`, en lugar de pasar por idéntico a otro.

Transformaciones concretas, con su archivo:

Transformación	Dónde	Nota
----------------	-------	------

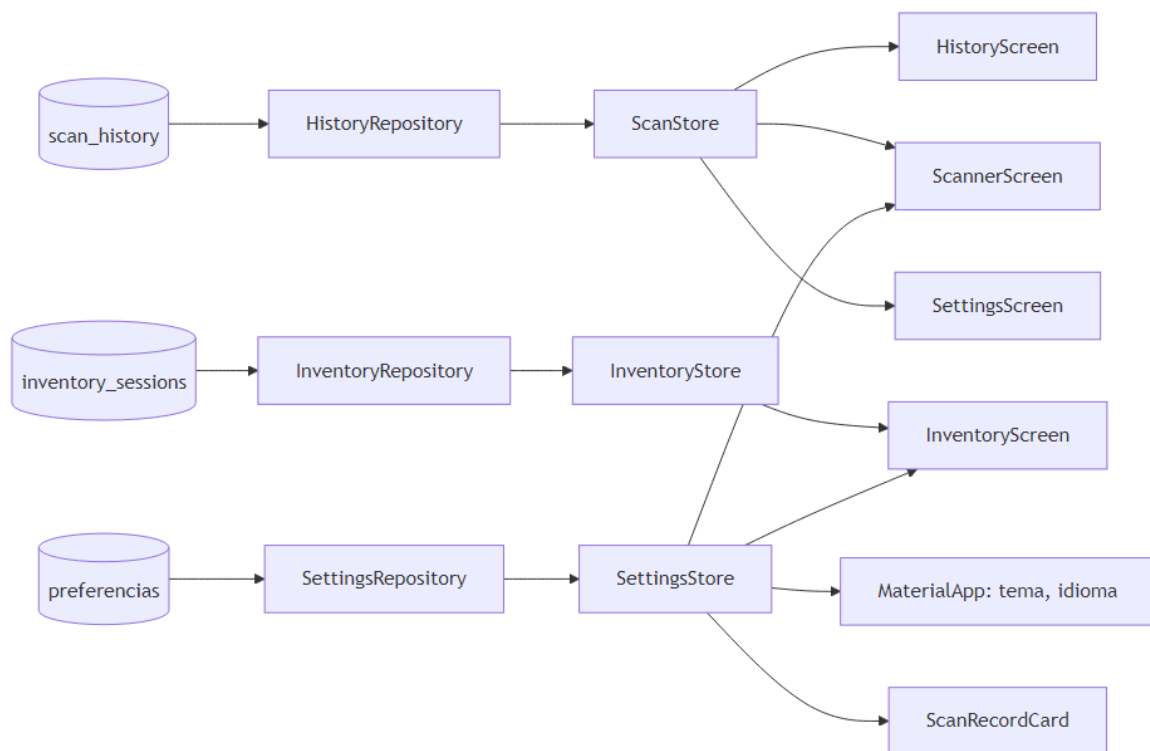
Bytes → <code>binary-base64:</code>	<code>ScanRecord.payloadForBarcode</code>	Da una carga estable a lo que no es texto
<code>www.x</code> → <code>https://www.x</code>	<code>_toWebUri</code> y <code>ContentInterpreter._webUri</code>	Solo para analizar; la carga guardada no cambia
Ruta con <code>%xx</code> → decodificada	<code>_safeDecode</code>	Tolerante a codificación inválida
Marca o token → comparable	<code>_comparable</code>	Minúsculas sin caracteres no alfanuméricos
Instante local → UTC	<code>ScanRecord.toJson</code>	Conserva id y correlación entre zonas horarias
Objeto → sobre cifrado	<code>PayloadCipher.encryptJson</code>	Nonce, texto cifrado y MAC en Base64
Objeto → JSON canónico	<code>QrEvidenceExporter._canonicalJson</code>	Claves ordenadas, para que el checksum resista reordenamientos

Dónde se almacenan

Ver [07-database.md](#). Resumen del destino de cada dato:

Dato	Destino	Cifrado
ScanRecord completo	<code>scan_history.payload</code>	Sí
Instante de lectura	<code>scan_history.scannedAt</code>	No
<code>InventorySession</code>	<code>inventory_sessions.payload</code>	Sí
Sobre de un registro ilegible	<code>recovery_issues.encryptedPayload</code>	Ya venía cifrado
Preferencias	<code>SharedPreferencesAsync</code>	No
Llave	Keychain / Keystore	Es el secreto
Diagnóstico	Solo memoria , máximo 100 entradas	No aplica
Páginas de PDF rasterizadas	Directorio temporal	No; se borran al terminar

Qué componentes los consumen



Explicación. Ninguna pantalla lee la base directamente. El único dato que atraviesa todas las capas es la configuración: el tema la usa el MaterialApp, la política de ocultación la usa la tarjeta de resultado, y las opciones de sonido y marco las usan las dos pantallas con cámara.

Qué información se envía a servicios externos

Ninguna, de forma automática. No hay ninguna llamada de red en lib/.

Las únicas salidas fuera del proceso las inicia siempre la persona:

Salida	Qué sale	Confirmación previa
Abrir una URI	La URI, a la aplicación que el sistema elija	Sí, salvo a <code>allow</code> con la confirmación general desactivada
Compartir evidencia	JSON redactado	La propia acción es la confirmación
Compartir historial	JSON, CSV o XLSX en claro	Sí, diálogo explícito de advertencia
Compartir inventario	JSON, CSV o XLSX	La propia acción
Compartir contacto o evento	<code>.vcf</code> o <code>.ics</code> con la carga	Sí, si el contenido es sensible
Compartir código generado	PNG o SVG	La propia acción
Copiar al portapapeles	La carga	Sí, si es sensible; con borrado programado
Copiar diagnóstico	Metadatos técnicos, sin cargas	La propia acción
Copiar paquete de recuperación	Sobres cifrados, sin llave	La propia acción

Detalle de la acción externa: `url_launcher` con `LaunchMode.platformDefault`. Antes de invocarlo se comprueba `QrActionDecision`: si es `block`, el botón no existe.

Qué datos se presentan a la persona

Elemento	Qué muestra	Ocultación
Tarjeta de resultado	Campos interpretados	Los campos sensibles se sustituyen por si <code>hideSensitiveValues</code> está activo
Banner de riesgo	Severidad, puntaje, decisión, número de señales	—
Detalle de hallazgos	Título, explicación, acción sugerida, id técnico y hechos	—
Hipótesis	Etiqueta en español	—
Límites	Lista de lo no comprobado	Siempre visible
Historial	Resumen, formato, fecha y carga	Sin ocultación en la lista
Barra de estado	Fase de la cámara y mensaje	Anunciada como región activa

La ocultación de campos alcanza a Contraseña, Secreto, Consulta, Dirección, IBAN y Carga, y solo cuando el contenido está marcado como sensible.

Dónde pueden producirse errores, pérdidas o inconsistencias

Punto	Riesgo	Mitigación
Descifrado de un registro	Llave ausente o carga manipulada	Se aísla como incidencia, no se borra ; el resto sigue cargando
Migración del historial heredado	Pérdida al borrar el origen antes de verificar	Respaldo cifrado previo, verificación dentro de la transacción, borrado al final
Rotación de llave	Estado mixto	Reencriptado en memoria y escritura en una sola transacción; la llave nueva se borra si falla
Recorte a 5000	Pérdida de los registros más antiguos	Es el comportamiento declarado; el límite está documentado
Retención configurada	Borrado por antigüedad	Ocurre al arrancar y al cambiar la opción; el valor por defecto es «sin límite»
Modo temporal	Todo se pierde al cerrar	Banner permanente en la interfaz
Desinstalación	Pérdida total: la llave vive en el Keystore	<code>allowBackup="false"</code> . Sin recuperación posible, por diseño
Importación con <code>replace</code>	Sustituye la base completa	Vista previa antes de elegir la estrategia; la escritura es transaccional
Lote cancelado	Ninguna: el historial no se toca	Mensaje explícito
Portapapeles	El valor sobrevive si la app muere antes del temporizador	Límite declarado

Reloj del dispositivo	Un instante erróneo cambia el id	El id es SHA-256(carga\ instante); no hay corrección de reloj
-----------------------	----------------------------------	---

Datos personales y sensibles que se procesan

Categoría	De dónde	Qué se hace
Contraseñas Wi-Fi	QR WIFI:	Se muestran ocultas; no se persisten
Secretos OTP	QR otpauth:	Se muestran ocultos; no se persisten
Datos de pago	EMVCo, EPC, Swiss QR, cripto	Se muestran; no se persisten
Documentos de identidad	AAMVA	Se muestran; no se persisten
Contactos	vCard, MeCard	Se muestran y sí se persisten : no están marcados como sensibles
URL con token, secreto o firma	Consulta, fragmento o <code>userinfo</code>	Se marcan sensibles y no se persisten
Notas y etiquetas	La persona	Se persisten cifradas

Hallazgo declarado. Los contactos (vCard/MeCard) contienen nombre, teléfono, correo y dirección, y **no** están marcados como sensitive, así que entran en el historial automático. Es coherente con la política escrita —que enumera OTP, Wi-Fi, pago e identidad— pero merece revisión explícita. Registrado en [15-risks-and-technical-debt.md](#).

Ejemplo de flujo completo

Carga observada: `https://banco.example@evil.example/acceso`. Ningún dato real.

- Captura
`rawValue = "https://banco.example@evil.example/acceso"`
- Huella
`payloadSha256 = SHA-256 de esa cadena exacta`
- Interpretación
`kind = url`
`summary = "evil.example"`
`fields = {Dominio: evil.example, Protocolo: HTTPS, Ruta: /acceso, ...}`
`sensitive = false` (no hay clave de secreto en la consulta)
- Reglas
`authority-userinfo critical · 25 · alta · evidencia host=evil.example`
`credential-lure-path warning · 8 · media · evidencia host=evil.example`
- Agregación
`severity = critical` `score = 33/100` `action = confirm`
- Hipótesis
`qr-phishing-suspected`
`credential-theft-suspected`
- Persistencia
no es sensible y el historial está activo → se cifra y se guarda
- Presentación
banner rojo, 33/100, "Decisión: confirmación obligatoria"

```
señales con su id técnico y sus hechos  
límites: reputación remota · DNS efectivo · certificado servido · ...
```

9. Acción

el botón «Abrir con confirmación» existe, pero exige un diálogo que advierte de las señales críticas

10. Evidencia (si se exporta)

```
observation.redaction = "payload-omitted"  
sin rawPayload, sin parsed, sin effectiveUri  
integrity.bundleHash = SHA-256 del JSON canónico  
integrity.assurance = "checksum-only-not-authenticated"
```

El paquete de evidencia de este caso **no contiene** la URL. Contiene su huella, los dos ids de hallazgo, sus hechos mínimos, las hipótesis y los límites. Basta para pedir ayuda o correlacionar, y no reenvía el destino.

09 · APIs e integraciones

Resumen: no hay API de red

Comprobado. El sistema **no expone ni consume ningún endpoint HTTP**. No hay cliente HTTP, ni WebSocket, ni gRPC, ni SDK de terceros que llame a un servidor. El paquete `http` de Dart no figura en `pubspec.yaml`.

Verificación reproducible:

```
grep -rn "http\.get\|http\.post\|HttpClient\|WebSocket\|dio\|Dio(" lib/
```

No devuelve resultados en el código de la aplicación.

Consecuencias para una auditoría:

- no hay autenticación de API, ni tokens, ni claves de servicio;
- no hay CORS ni CSRF que configurar: no existe superficie web propia;
- no hay límites de tasa, reintentos ni webhooks;
- **no hay dependencia de disponibilidad de terceros**: la aplicación funciona entera en modo avión.

Lo que sí existe son **contratos de datos** —formatos que otros sistemas pueden leer— e **interfaces de plataforma** —servicios del sistema operativo—. Este documento cataloga ambos.

Contratos de datos publicados

1. `rootcause.evidence.qr.v1` — evidencia exportable

Es el contrato principal del producto hacia el exterior.

Aspecto	Valor
Esquema formal	<code>../../../../schemas/rootcause-qr-evidence.schema.json</code>
Dialecto	JSON Schema Draft 2020-12
Productor	<code>QrEvidenceExporter.toMap</code>
Verificador	<code>QrEvidenceExporter.verify</code>
Transporte	Archivo compartido por la persona; nunca por red
Nombre del archivo	<code>rootcause-qr-evidence-<id del registro>.json</code>

Estructura:

Campo	Tipo	Obligatorio	Descripción
<code>schema</code>	<code>const</code>	Sí	<code>rootcause.evidence.qr.v1</code>
<code>product.name</code>	<code>const</code>	Sí	RootCause QR Inspector
<code>product.version</code>	<code>string</code>	Sí	Patrón <code>^\d+\.\d+\.\d+\$</code>

bundleId	string	Sí	24 caracteres hex; SHA-256 de id\ huella\ instante
observedAt	date-time	Sí	Instante de la observación, en UTC
observation.source	string	Sí	Cámara, Imagen, PDF · página N...
observation.symbology	string	Sí	Simbología legible
observation.contentKind	string	Sí	Uno de los 17 ContentKind
observation.sensitive	bool	Sí	Si el contenido se clasificó como sensible
observation.payloadBytes	int ≥ 0	Sí	Tamaño de la carga en bytes
observation.payloadSha256	sha256	Sí	Huella de la carga exacta
observation.redaction	enum	Sí	payload-omitted o none-user-authorized
observation.rawPayload	string	Prohibido si payload-omitted	La carga completa
observation.parsed	object	Prohibido si payload-omitted	Campos interpretados
investigation	object	Sí	La investigación completa
integrity.algorithm	const	Sí	SHA-256
integrity.assurance	const	Sí	checksum-only-not-authenticated
integrity.bundleHash	sha256	Sí	Checksum del paquete
integrity.previousEvidenceSha256	sha256	No	Enlace manual a un paquete anterior

additionalProperties: false en todos los niveles: un campo no previsto invalida el paquete.

Ejemplo **redactado** (valores ficticios):

```
{
  "schema": "rootcause.evidence.qr.v1",
  "product": { "name": "RootCause QR Inspector", "version": "0.1.1" },
  "bundleId": "0f3a91c47b25de806a1c4f7b",
  "observedAt": "2026-08-26T14:02:11.000Z",
  "observation": {
    "source": "Cámara",
    "symbology": "QR Code",
    "contentKind": "url",
    "sensitive": false,
    "payloadBytes": 41,
    "payloadSha256": "3b1f...c9",
    "redaction": "payload-omitted"
  },
  "investigation": {
    "schema": "rootcause.qr-investigation.v1",
```



```

"engineVersion": "0.1.0",
"analyzedAt": "2026-08-26T14:02:11.000Z",
"payloadSha256": "3b1f...c9",
"verdict": { "severity": "critical", "score": 33, "action": "confirm" },
"normalizedHost": "evil.example",
"findings": [
  {
    "id": "authority-userinfo",
    "severity": "critical",
    "score": 25,
    "confidence": "high",
    "category": "obfuscation",
    "evidence": [{ "id": "host", "value": "evil.example" }]
  }
],
"hypotheses": ["qr-phishing-suspected"],
"evaluatedRuleIds": ["url-control-character", "sensitive-secret", "..."],
"limitations": ["no-remote-reputation", "no-dns-resolution", "..."]
},
"integrity": {
  "algorithm": "SHA-256",
  "assurance": "checksum-only-not-authenticated",
  "bundleHash": "a7c0...41"
}
}

```

Observe que **no hay ninguna URL**. Hay una huella, un host normalizado, ids de hallazgo y sus hechos mínimos.

Cómo verificar un paquete sin la aplicación:

1. quitar `integrity.bundleHash` del objeto;
2. serializar el resultado con las claves de cada objeto ordenadas alfabéticamente y sin espacios;
3. calcular SHA-256 sobre esos bytes UTF-8;
4. comparar con el valor retirado.

Coincidir prueba **consistencia interna**, no autoría: quien modifique el archivo puede recalcularlo. El campo `assurance` lo dice explícitamente.

2. rootcause.qr-investigation.v1 — investigación

Va embebida dentro de la evidencia y también dentro de cada `ScanRecord` persistido. Definida en `$defs.investigation` del mismo esquema.

3. rootcause.qr-policy.v1 — política de análisis

Aspecto	Valor
Ejemplo	<code>../../../../config/rootcause-qr-policy.example.json</code>
Consumidor	<code>QrAnalysisPolicy.fromJson</code>
Estado	La interfaz no carga este archivo. Es un contrato para integradores

```

{
  "schema": "rootcause.qr-policy.v1",
  "maxUrlLength": 240,
  "maxDomainLabels": 5,
  "allowPrivateTargets": false,
  "trustedBrands": [
    {
      "id": "banco-ejemplo",

```

```

    "tokens": ["banco-ejemplo", "bancoejemplo"],
    "allowedHosts": ["banco-ejemplo.example"]
  }
}
}

```

`tool/verify_rootcause_contract.py` exige que el ejemplo use **solo** dominios `.example` y que cada token tenga al menos cuatro caracteres alfanuméricos.

4. Respaldo de historial e inventario

Campo	Valor
<code>application</code>	RootCause QR Inspector o Universal Code Scanner
<code>schemaVersion</code>	2 actual; 1 es la lista heredada sin sobre
<code>type</code>	history o inventory
<code>exportedAt</code>	ISO-8601 UTC
<code>records / session</code>	Contenido

Contiene las cargas en claro. No es un formato de evidencia.

5. Paquete de recuperación

`type: recovery`, con las incidencias y sus sobres **todavía cifrados**. Incluye un campo `notice` que declara que no lleva llave.

6. `rootcause.qr-fixtures.v1`

Casos sintéticos de regresión en `../../fixtures/qr/manifest.json`. Los valida `verify_rootcause_contract.py`: mínimo 12 casos, ids únicos, acciones y severidades válidas, reglas existentes y **hosts reservados** —con `bit.ly` como única excepción, necesaria para probar la regla de acortadores—.

Interfaces de plataforma consumidas

No son APIs de red: son servicios del sistema operativo a través de plugins.

Interfaz	Paquete	Qué pide	Permiso	Si falla
Cámara	<code>mobile_scanner</code> 7.4.0	Cuadros para decodificar	<code>CAMERA</code>	Estado <code>unavailable</code> con acción de reintento
Galería	<code>image_picker</code> 12.3	Hasta 20 imágenes	Selector del sistema	Lote vacío, mensaje
Archivos	<code>file_picker</code> 12.0.0	JSON o PDF	Selector del sistema	Se cancela sin efecto
Render de PDF	<code>pdfrx</code> 2.4.5	Páginas a imagen	—	<code>UnsupportedError</code> en web
Almacén seguro	<code>flutter_secure_storage</code> 11.0.0	Guardar la llave	Keychain / Keystore	Arranque seguro y modo temporal

Autenticación local	local_auth 3.0.2	Huella, rostro o PIN	USE_BIOMETRIC	Devuelve <code>false</code> ; la app sigue bloqueada
Audio	audioplayers 6.8.1	Reproducir el tono	—	Degrada al sonido del sistema
Vibración	flutter/services	heavyImpact	—	Se ignora
Portapapeles	flutter/services	Copiar y limpiar	—	Se ignora
Compartir	share_plus 13.3.0	Entregar un archivo	—	Excepción capturada por la pantalla
Abrir URI	url_launcher 6.3.2	Delegar la URI	—	Mensaje: no hay aplicación compatible
Directorios	path_provider 2.1.6	Soporte y temporal	—	Arranque seguro
Preferencias	shared_preferences 2.5.5	Configuración	—	Valores por defecto

Permisos declarados

tool/bootstrap.py los inserta en el manifiesto de Android:

```
<uses-permission android:name="android.permission.CAMERA" />
<uses-permission android:name="android.permission.USE_BIOMETRIC" />
<uses-feature android:name="android.hardware.camera.any" android:required="false" />
```

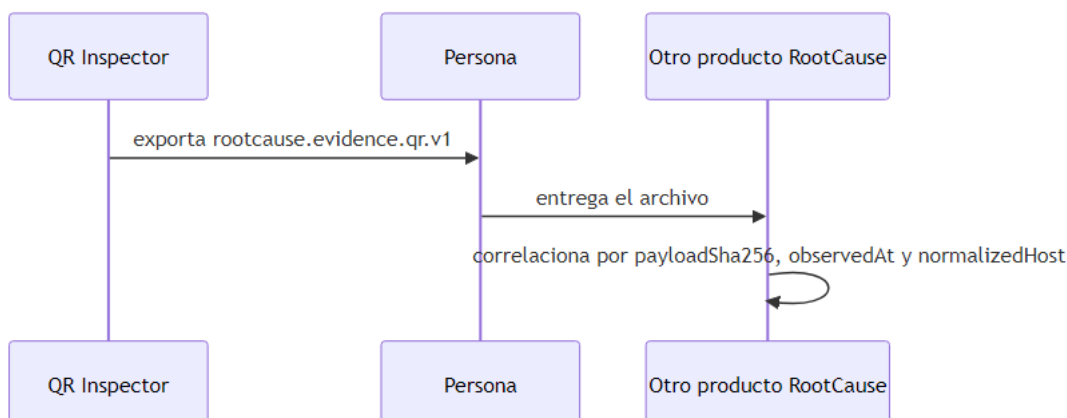
Y añade `android:allowBackup="false"` a la etiqueta `<application>`.

En iOS inserta tres descripciones de uso en `Info.plist`: `NSCameraUsageDescription`, `NSPhotoLibraryUsageDescription` y `NSFaceIDUsageDescription`, además de un archivo de *entitlements* con `keychain-access-groups` vacío.

No se pide permiso de red, ubicación, contactos, micrófono ni almacenamiento externo.

Integración con la familia RootCause

En esta versión la integración es **manual y explícita**. No hay sincronización automática, ni servidor, ni bus entre aplicaciones.



Explicación. La persona es el transporte. Es una decisión de privacidad: sin un canal automático no hay forma de que un evento salga del dispositivo sin una acción deliberada.

Campos pensados para correlacionar, sin revelar la carga:

Campo	Uso
<code>observation.payloadSha256</code>	Identificar el mismo código en dos superficies
<code>observedAt</code>	Ventana temporal
<code>investigation.normalizedHost</code>	Coincidencia por destino
<code>investigation.findings[].id</code>	Coincidencia por tipo de señal
<code>integrity.bundleHash</code>	Detectar que el paquete cambió

Mapeo propuesto a un esquema común futuro: `../rootcause/INTEGRATION.md`.

Puntos de extensión para integradores

Punto	Interfaz	Cómo
Política de análisis	<code>QrAnalysisPolicy</code>	Pasarla a <code>QrInvestigationEngine.analyze</code> o a <code>ScanSecurityAnalyzer.analyze</code>
Nuevo formato de contenido	<code>ContentParser</code>	<code>ContentParserRegistry.instance.register(p</code> con prioridad > -1000
Nuevo motor de captura	<code>ScannerEngine</code>	Implementar los nueve miembros
Evidencia con carga completa	<code>includeRawPayload: true</code>	Solo por API: la interfaz no ofrece ese botón
Cadena de evidencias	<code>previousEvidenceHash</code>	Debe ser SHA-256 hexadecimal en minúsculas

Ejemplo de parser adicional:

```
class MiParser implements ContentParser {
  @override String get id => 'mi-formato';
  @override int get priority => 100;           // mayor que el integrado (-1000)
  @override bool canParse(String raw) => raw.startsWith('MIFORMATO:');
  @override ParsedContent parse(String raw) => ParsedContent(
    kind: ContentKind.text,
    title: 'Mi formato',
    fields: <String, String>{'Contenido': raw.substring(11)},
  );
}

ContentParserRegistry.instance.register(const MiParser());
```

El parser integrado `builtin-v2` está protegido: `unregister` no puede eliminarlo, así que nunca queda la aplicación sin intérprete.

Webhooks, reintentos y límites de tasa

No aplican. No hay comunicación de red. Los únicos límites del sistema son locales y están en [05-technical-reference.md](#).

Dependencias de proveedores externos

En **ejecución**, ninguna: la aplicación no depende de que ningún servicio esté disponible.

En **construcción y publicación** sí hay dependencias operativas:

Proveedor	Para qué	Riesgo si falla
pub.dev	Resolver dependencias	No se compila; el lockfile fija versiones pero no las almacena
GitHub Actions	Analizar, probar, compilar y publicar	No hay artefacto nuevo
GitHub Releases	Distribuir el APK	No hay canal de descarga alternativo
GitHub Pages	Landing y demo	Solo afecta a la documentación pública
Google ML Kit / Apple Vision	Decodificar códigos	Vienen embebidos en el plugin; no son un servicio remoto

10 · Configuración

Dónde vive la configuración

Hay cuatro lugares, y conviene no confundirlos:

Lugar	Qué configura	Quién lo cambia	Persistente
Preferencias del dispositivo	Comportamiento de la aplicación	La persona, desde Ajustes	Sí
<code>QrAnalysisPolicy</code>	Umbrales y marcas del motor	Un integrador, por código	No: se pasa en cada llamada
Archivos del repositorio	Compilación y publicación	Quien desarrolla	Sí, versionado
Variables de entorno	Nada en la aplicación	—	—

Comprobado: no hay `String.fromEnvironment`, `--dart-define` ni archivo `.env` en el repositorio. La aplicación no lee ninguna variable de entorno.

Preferencias

Se guardan con `SharedPreferencesAsync` —no en la base cifrada— porque ninguna contiene carga escaneada. Cada lectura aplica un valor por defecto, así que una clave ausente o corrupta nunca deja la aplicación sin configuración.

Apariencia y accesibilidad

Clave	Tipo	Por defecto	Efecto	Consecuencia de un valor incorrecto
<code>theme_mode</code>	<code>system/light/dark</code>	<code>system</code>	Tema claro u oscuro	Un valor desconocido cae a <code>system</code>
<code>language</code>	<code>system/esCL/es/en</code>	<code>system</code>	Idioma de la interfaz	en existe pero no se ofrece ; el desplegable lo muestra como «Sistema»
<code>high_contrast</code>	<code>bool</code>	<code>false</code>	Sube el contraste y marca los bordes de tarjeta	Ninguna: es visual
<code>large_controls</code>	<code>bool</code>	<code>false</code>	Aumenta la densidad táctil sin tocar la escala tipográfica	Ninguna
<code>reduce_motion</code>	<code>bool</code>	<code>false</code>	Elimina transiciones; la barra de estado se dibuja llena y quieta y el marco no barre	Ninguna

Inspección

Clave	Tipo	Por defecto	Efecto	Consecuencia de un valor incorrecto
use_scan_window	bool	true	Dibuja el marco de encuadre. Es solo visual: la lectura analiza toda la imagen	Ninguna sobre la detección. Antes de 0.1.1 sí filtraba, y descartaba códigos en silencio
auto_torch	bool	false	Enciende la linterna al iniciar la cámara	Consumo de batería
sound_enabled	bool	true	Tono de confirmación al leer	Desactivarlo deja la confirmación en la vibración y el estado visible
vibration_enabled	bool	true	Vibración heavyImpact al leer	Igual que el anterior

Desactivar **sonido y vibración a la vez** deja la confirmación de lectura únicamente en el estado visible Código leído y en la apertura del resultado.

Privacidad y seguridad

Clave	Tipo	Por defecto	Efecto	Consecuencia de un valor incorrecto
save_history	bool	true	Guarda las lecturas no sensibles	En false no se conserva nada; los resultados siguen mostrándose
private_mode	bool	false	Mientras esté activo, ninguna lectura se guarda	Se puede confundir con «no funciona el historial»
hide_sensitive_values	bool	true	Oculto contraseña, secreto, consulta, dirección, IBAN y carga tras ••••••••	En false los valores sensibles se muestran directamente en pantalla
confirm_before_open	bool	true	Exige confirmación antes de entregar una URI	En false sigue habiendo confirmación si el motor decide confirm o si el riesgo no es bajo
biometric_lock	bool	false	Bloquea la aplicación al perder el primer plano	Solo se activa si la autenticación tiene éxito en ese momento
clear_clipboard_seconds	int	30	Borra el portapapeles si no cambió. Valores ofrecidos: 0, 15, 30, 60, 300	0 significa nunca borrar

history_retention_days	0	Elimina lecturas más antiguas al arrancar y al cambiar la opción. Valores: 0, 30, 90, 365	0 significa sin límite , no «borrar todo»
------------------------	---	--	--

Banderas de capacidades

feature_flags se guarda como JSON con nueve booleanos, todos false:

experimentalParsers, secondaryScannerEngine, ocr, nfc, urlReputation, productLookup, encryptedSync, enterpriseApi, kioskMode.

Estado comprobado: ninguna bandera se lee en lib/. Se serializan y deserializan, pero no cambian comportamiento. Son un contrato de reserva; su regla, en `../quality/FEATURE_FLAGS.md`, es que activar una nunca debe cambiar el formato persistente.

Si el JSON está corrupto, la lectura cae a `const FeatureFlags()` dentro de un `try`: todas apagadas.

Claves internas, no visibles en Ajustes

Clave	Para qué
scan_history_v1	Historial heredado en claro. Se migra y se borra
scan_history_v1_backup	Respaldo cifrado del origen heredado
history_migrated_to_v2	Marca de migración completada
history_migration_error	Código del último fallo de migración
encryption_active_key_id	Valor heredado; se traslada a la base y se borra de aquí

Restablecer preferencias

SettingsRepository.resetNonSensitive —la opción «Restablecer preferencias visuales» del arranque seguro— borra 14 claves y **conserva deliberadamente tres**:

Clave conservada	Por qué
save_history	Su valor por defecto es «guardar»
private_mode	Su valor por defecto es «no privado»
biometric_lock	Su valor por defecto es «sin bloqueo»

Restablecerlas relajaría la postura de privacidad que la persona había elegido. Las que sí se restablecen —como `hide_sensitive_values` o `confirm_before_open`— vuelven a un valor **más** conservador, no menos.

Política de análisis

QrAnalysisPolicy parametriza el motor sin tocar su código.

Campo	Por defecto	Regla afectada	Consecuencia de subirlo o bajarlo
-------	-------------	----------------	-----------------------------------

maxLength	240	url-excessive-length	Muy alto: nunca dispara. Muy bajo: ruido en URL legítimas largas
maxDomainLabels	5	host-deep-subdomains	Muy bajo: falsos positivos en infraestructura corporativa
allowPrivateTargets	false	host-private-or-local	En true silencia una señal crítica. Solo tiene sentido en despliegues internos donde un panel en 192.168.x.x es el destino esperado
trustedBrands	[]	brand-domain-mismatch	Sin marcas, la regla nunca dispara

Cada `QrTrustedBrand` declara `id`, `tokens` y `allowedHosts`. Los tokens se comparan reducidos a letras y dígitos, así que `banco-ejemplo` también detecta `bancoejemplo`. Un token con menos de cuatro caracteres alfanuméricos se ignora, para no disparar la regla con fragmentos genéricos.

Cómo se inyecta hoy

```
const QrAnalysisPolicy policy = QrAnalysisPolicy(
    maxLength: 300,
    trustedBrands: <QrTrustedBrand>[
        QrTrustedBrand(
            id: 'banco-ejemplo',
            tokens: <String>['banco-ejemplo'],
            allowedHosts: <String>['banco-ejemplo.example'],
        ),
    ],
);

final QrInvestigation resultado = QrInvestigationEngine.analyze(
    carga,
    parsed: ContentInterpreter.parse(carga),
    policy: policy,
);
```

Límite declarado. La aplicación **no carga** `config/rootcause-qr-policy.example.json` en tiempo de ejecución. No existe pantalla para importar, firmar ni administrar una política. El archivo es un contrato de referencia para integradores, y `QrAnalysisPolicy.fromJson` existe para consumirlo desde código propio.

Diferencias entre entornos

No hay entornos. No existen perfiles de desarrollo, pruebas y producción, ni sabores de compilación, ni configuración condicional por entorno. La misma aplicación se comporta igual en depuración y en release.

Las únicas diferencias reales son de **plataforma**, y se resuelven en compilación:

Diferencia	Nativo	Web (demo)
Base de datos	Archivo Sembast	IndexedDB
Lectura de PDF	Disponible	<code>UnsupportedError</code> ; la opción se oculta
Almacén de llaves	Keychain / Keystore	Lo que ofrezca el navegador

Menú de imagen y PDF	Habilitado	Deshabilitado (enabled: !kIsWeb)
----------------------	------------	----------------------------------

Configuración de compilación y publicación

Archivo	Qué fija	Cambiarlo implica
pubspec.yaml	Versión, dependencias, assets	La versión debe igualarse en lib/core/app_info.dart o falla la validación
.fvmrc	Flutter 3.44.7	Debe cambiarse a la vez que FLUTTER_VERSION en los tres workflows
analysis_options.yaml	flutter_lints más always_declare_return_types, avoid_print, prefer_final_locals, use_build_context_synchronously	Relajarlo debilita el gate de CI
.gitattributes	LF en todo el texto	Necesario para que los hashes de SOURCE_MANIFEST.json sigan siendo verificables tras clonar en Windows
.github/dependabot.yml	pdfx bloqueado por encima de 2.4.5	Ver ../quality/LOCKFILE.md antes de levantarlo

Constantes fijadas en tool/bootstrap.py

Constante	Valor	Por qué
ANDROID_GRADLE_PLUGIN	8.11.1	La plantilla de Flutter 3.44.7 genera AGP 9, cuyo Kotlin integrado rompe varios plugins de este conjunto
KOTLIN_GRADLE_PLUGIN	2.2.20	Mínimo que Flutter 3.44.7 no marca obsoleto
GRADLE_DISTRIBUTION	8.14.3	Compatible con AGP 8.11.1
minSdk	24	Android 7.0
Plataforma iOS	15.5	Podfile, proyecto y AppFrameworkInfo.plist
PRODUCT_PLATFORMS	("android", "ios")	validate_structure.py falla si cambia
GENERATABLE_TARGETS	(*PRODUCT_PLATFORMS, "web")	Mantiene web separado como canal de demostración

Las dos últimas están **verificadas por el validador estructural**: es una barrera deliberada para que el escritorio no vuelva a presentarse como plataforma del producto.

Configuraciones sensibles

Configuración	Riesgo si se cambia sin criterio
<code>allowPrivateTargets: true</code>	Silencia <code>host-private-or-local</code> , una señal crítica
<code>hide_sensitive_values: false</code>	Contraseñas y secretos visibles en pantalla, y en cualquier captura
<code>clear_clipboard_seconds: 0</code>	Una carga sensible permanece en el portapapeles indefinidamente
<code>private_mode: false</code> con historial activo	Se conservan lecturas que quizá no se querían conservar
<code>confirm_before_open: false</code>	Reduce las barreras, aunque el motor mantiene las suyas
Relajar <code>analysis_options.yaml</code>	Debilita el gate que la CI aplica con <code>--fatal-infos</code>
<code>android:allowBackup a true</code>	La base entraría en la copia del sistema; la llave no viajaría con ella

Secretos

Comprobado: no hay ningún secreto en el repositorio. No hay claves de API, tokens, contraseñas ni certificados. Las razones son estructurales: no hay servicios remotos que autenticar, y la firma del APK usa la clave de depuración que genera Flutter.

Los únicos valores con forma de secreto son sintéticos y aparecen en fixtures y documentación con dominios reservados:

Valor	Dónde	Naturaleza
<code>otpauth://totp/Ejemplo?secret=SYif</code>	<code>fixtures/qr/manifest.json</code>	Cadena inventada
<code>bitcoin:bc1qexample?amount=0.01</code>	<code>fixtures</code>	Dirección inválida a propósito
<code>banco-ejemplo.example</code>	política de ejemplo	TLD reservado
<code>https://example.com/...</code>	pruebas y generador	Dominio reservado

El único secreto real del sistema —la llave de cifrado— se genera en el dispositivo, vive en Keychain/Keystore y **nunca** se escribe en el repositorio, en un export ni en un diagnóstico.

`tool/validate_structure.py` incluye `check_sensitive_logging`, que falla si aparece una llamada a `print`, `debugPrint` o `log` cuyo argumento mencione `rawValue`, `password`, `secret`, `otp` o `payload`.

11 · Seguridad

Este documento describe los controles **presentes en el código** y, con la misma claridad, los que **no existen o no se han comprobado**. No es una certificación ni sustituye una auditoría independiente.

Modelo de seguridad en una frase

El activo a proteger no es un servidor: son los datos que la persona escanea y la decisión que toma después. El sistema los protege manteniéndolo todo local, cifrando lo que persiste y **negándose a ejecutar** la carga que analiza.

Autenticación

Aspecto	Estado
Autenticación de usuario	No existe. No hay cuentas ni sesión
Autenticación de servidor	No aplica: no hay servidor
Bloqueo local	Opcional, con el autenticador del dispositivo

`BiometricLockGate` (`lib/app.dart`) implementa el bloqueo:

- se activa desde Ajustes, y **solo si la autenticación tiene éxito en ese momento**: no se puede activar a ciegas;
- vuelve a bloquear cuando la aplicación pasa a `inactive`, `paused`, `hidden` o `detached`, no solo al cerrarse. Eso cubre el conmutador de aplicaciones y la vista previa del sistema;
- si la autenticación falla, la única acción disponible es reintentar. **No hay salida alternativa ni código de respaldo propio**;
- `BiometricService` traduce cualquier excepción a `false`, de modo que un dispositivo sin enrolamiento deja la aplicación bloqueada en vez de abrirla.

Requiere validación: el comportamiento con biometría cancelada, bloqueada por intentos fallidos o sin enrolar solo puede comprobarse en hardware.

Autorización

No hay roles ni permisos de usuario. La autorización que sí existe es **sobre acciones**, no sobre personas:

`QrActionDecision` decide si una carga puede entregarse a otra aplicación.

Decisión	Botón de acción	Confirmación
<code>allow</code>	Sí	Solo si <code>confirm_before_open</code> está activo o el riesgo no es bajo
<code>confirm</code>	Sí	Siempre , aunque la confirmación general esté desactivada
<code>inspectOnly</code>	No hay acción externa	—
<code>block</code>	No aparece	—

`verify_rootcause_contract.py` comprueba que la interfaz sigue respetando `record.investigation.action == QrActionDecision.confirm`. Es un control de regresión sobre una propiedad de seguridad.

Gestión de sesiones

No hay sesiones. El estado en memoria muere con el proceso. El «modo temporal» es lo más parecido: base en memoria y llave volátil, con un banner permanente que avisa de que nada sobrevivirá al cierre.

Validación y saneamiento de la entrada

Entrada	Control
Carga de un código	No se sana: se analiza. Nunca se ejecuta ni se abre automáticamente
Carga binaria	Se codifica como <code>binary-base64</code> : y se clasifica como opaca
Respaldo JSON	Cinco barreras; ver 06
Profundidad del JSON	Recorrido iterativo con pila explícita: un documento anidado no puede desbordar la pila
Nodos del JSON	Máximo 100 000
Tamaño	25 MB, comprobado dos veces
Campos derivados de un respaldo	Se recalculan siempre
Notas y etiquetas	Se recortan; las etiquetas se deduplican
Preferencias	Valor por defecto conservador por clave

El control más importante es el último de la lista de respaldos:

```
ScanRecord.fromJson(map, trustDerivedAnalysis: false)
```

Sin él, un archivo manipulado podría declarar `severity: normal` y `action: allow` para una URL de phishing, y la interfaz lo mostraría como seguro.

Ausencia de superficies clásicas

Vector	Estado
Inyección SQL	No aplica: no hay SQL
Inyección de comandos	No aplica: no se ejecutan procesos
XSS	No aplica: no hay WebView ni HTML propio
Deserialización insegura	Solo <code>jsonDecode</code> a tipos primitivos, con validación posterior
Path traversal	No se construyen rutas con datos del usuario. Las temporales llevan nombre generado
CORS / CSRF	No aplica: no hay servidor propio

Carga de archivos a un servidor	No existe
---------------------------------	-----------

La demo web publicada en GitHub Pages sí es una superficie HTTP, pero sirve contenido estático y no expone ninguna API.

Cifrado

Aspecto	Valor
Algoritmo	AES-256-GCM (autenticado)
Librería	cryptography 2.9.0
Alcance	Toda la carga de historial e inventario
Nonce	Generado por la librería en cada operación
MAC	Almacenado en el sobre; su fallo rechaza el descifrado
Llave	256 bits, generada en el dispositivo
Almacén de la llave	Keychain (iOS) / Keystore (Android) con prefijo <code>rcqr_database_key_</code>
Metadatos del sobre	Versión, algoritmo, identificador de llave e instante
Rotación	Manual desde Ajustes, transaccional

Propiedades que el diseño garantiza y las pruebas fijan:

1. **Una llave ausente no se recrea.** El descifrado usa `read`, que devuelve `null`, no `readOrCreate`. Si se recreara, todos los registros anteriores quedarían ilegibles en silencio.
2. **Una llave ausente bloquea nuevas escrituras** con ese identificador hasta que la persona recupere, rote o descarte de forma explícita.
3. **Una carga manipulada se rechaza** por el MAC de GCM.
4. **Una versión de sobre desconocida se rechaza** en vez de interpretarse.
5. **Una rotación fallida no deja llave huérfana:** se borra en el `catch`.

No cifrado, y declarado: `scannedAt` y `createdAt` viven en claro para poder ordenar y podar sin descifrar 5000 sobres. Quien acceda al archivo sabe *cuándo* hubo lecturas, aunque no *qué* se leyó.

Manejo de secretos

Secreto	Dónde vive	Sale de ahí
Llave de cifrado	Keychain / Keystore	Nunca
Contraseñas Wi-Fi de un QR	Memoria durante el resultado	Solo si la persona copia o comparte, con confirmación
Secretos OTP	Igual	Igual
Datos de pago	Igual	Igual

Ninguno de los cuatro se escribe en la base, en un export de evidencia, en el diagnóstico ni en el paquete de recuperación.

Registro y auditoría

Aspecto	Estado
Registro de aplicación	No existe. El lint <code>avoid_print</code> está activo
Diagnóstico	Máximo 100 entradas en memoria : instante, área, tipo de error y huella de pila
Mensaje de la excepción	No se guarda , a propósito
Auditoría de acciones	No existe: no se registra qué abrió la persona
Telemetría	Cero

`check_sensitive_logging` en `validate_structure.py` falla si aparece una llamada a `print`, `debugPrint` o `log` cuyo argumento mencione `rawValue`, `password`, `secret`, `otp` o `payload`.

La ausencia de auditoría es coherente con el modelo de privacidad, pero también significa que **no hay forma de reconstruir qué se escaneó** si el historial se borra. Es un compromiso explícito.

Dependencias potencialmente vulnerables

No se ejecutó ningún escáner de vulnerabilidades en este análisis.

Lo que sí existe en el repositorio:

Control	Estado
Versiones exactas en <code>pubspec.yaml</code>	Sí: todas fijadas, sin rangos
<code>pubspec.lock</code> versionado	Sí, y la CI comprueba que exista
SBOM CycloneDX	<code>tool/generate_sbom.py</code> , publicado como artefacto
Inventario de licencias	<code>tool/generate_license_inventory.py</code>
Dependabot	Semanal para <code>pub</code> , mensual para <code>Actions</code>
Acciones fijadas a SHA	Sí, y <code>validate_structure.py</code> falla si alguna no lo está

Riesgo declarado: `pdf-rx` está bloqueado por debajo de 2.4.6 y `excel` en 4.0.6 por un conflicto real de `archive`. Un aviso de seguridad en cualquiera de los dos exigiría resolver antes ese conflicto. Ver [../quality/LOCKFILE.md](#).

Exposición de información

Canal	Qué expone	Control
Pantalla	Campos interpretados	Ocultación de valores sensibles
Historial	Carga completa	Cifrado en reposo; sensibles excluidos

Export de historial	Carga en claro	Diálogo de advertencia obligatorio
Export de evidencia	Solo huella y hechos	Redacción por defecto
Portapapeles	Carga completa	Confirmación si es sensible; borrado programado
Compartir	Lo que se comparte	Confirmación si es sensible
Diagnóstico	Metadatos técnicos	Sin mensajes ni cargas
Recuperación	Sobres cifrados	Sin llave
Vista previa del sistema	Contenido en pantalla	Solo mitigado si el bloqueo está activo

Hallazgo. La lista del historial muestra la carga completa en el subtítulo de cada elemento, sin ocultación, aunque el registro provenga de contenido con parámetros largos. La ocultación solo se aplica en la tarjeta de detalle. Registrado en 15-risks-and-technical-debt.md.

Hallazgo. No se llama a FLAG_SECURE ni al equivalente de iOS, así que el sistema puede capturar la pantalla en el conmutador de aplicaciones. El bloqueo biométrico mitiga el caso, pero solo si está activado.

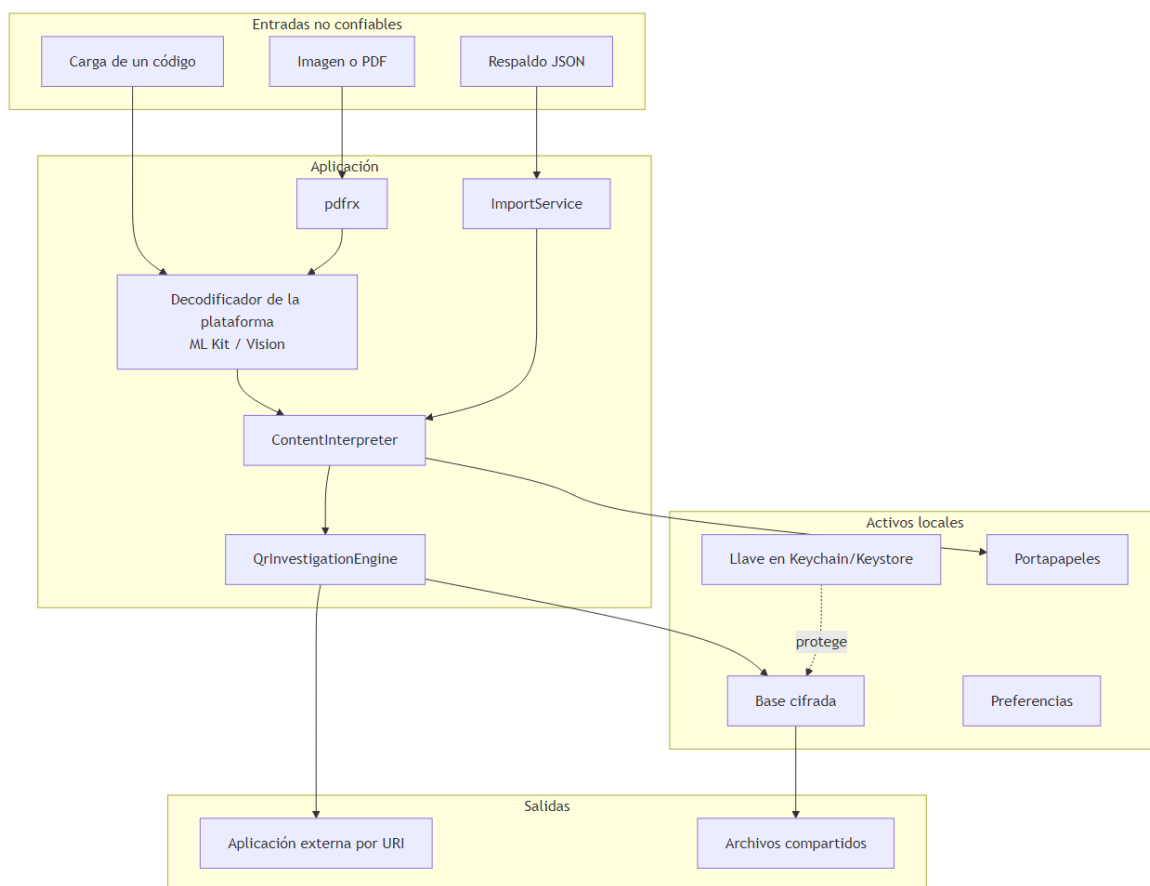
Protección de datos personales

Principio	Cómo se cumple
Minimización	Solo se guarda lo escaneado, y no todo
Limitación de finalidad	No hay finalidad secundaria: no hay analítica
Limitación del plazo	Retención configurable; límite de 5000 registros
Integridad y confidencialidad	AES-256-GCM y llave en almacén del sistema
Transparencia	La interfaz declara qué se guarda y qué no
Portabilidad	Export JSON, CSV y XLSX
Supresión	Borrado por registro, por historial completo o por modo temporal

Categorías especiales que el sistema puede llegar a tocar: datos de identificación (AAMVA), datos financieros (pagos) y credenciales. Ninguna se persiste.

Hallazgo. Los contactos de una vCard —nombre, teléfono, correo, dirección— **no** están marcados como sensibles y sí entran en el historial.

Superficie de ataque



Explicación. Tres entradas no confiables cruzan la frontera. Dos de ellas —código e imagen— pasan primero por código nativo de terceros: el decodificador de la plataforma y el renderizador de PDF. Ese es el punto donde el sistema tiene **menos** control: una vulnerabilidad en ML Kit, Vision o pdfrx sería explotable con un archivo diseñado. Los límites de páginas, tamaño y escala reducen la exposición, pero no la eliminan.

Vector	Mitigación	Riesgo residual
Carga diseñada para el decodificador	Límites de lote; sin <code>returnImage</code>	Depende del código nativo del proveedor
PDF malicioso	50 páginas, escala acotada, limpieza, cancelación	Superficie de <code>pdfrx</code>
Respaldo malicioso	Cinco barreras y recálculo obligatorio	Consumo de CPU dentro de los límites
URI diseñada para otra aplicación	<code>block</code> para esquema, host o autoridad ambiguos; controles invisibles	La aplicación destino puede interpretar distinto
Acceso físico al dispositivo	Bloqueo opcional; datos cifrados	Sin bloqueo, el historial está a la vista
Copia de seguridad del sistema	<code>allowBackup="false"</code>	—
Manipulación del archivo de base	AES-GCM aísla el registro dañado	Se pierde ese registro
Suplantación de una evidencia	<code>bundleHash</code>	No hay firma: el checksum se puede recalcular

Controles implementados

1. Análisis local sin red ni telemetría.

2. Ninguna carga se ejecuta automáticamente.
3. Bloqueo de URI ambiguas, con cuatro condiciones distintas.
4. Confirmación obligatoria cuando el motor lo decide.
5. Cifrado autenticado de todo lo persistido.
6. Llave en el almacén seguro del sistema, que nunca se recrea al descifrar.
7. Exclusión de OTP, Wi-Fi, pagos e identidad del historial automático.
8. Detección de URL con token, secreto o firma en consulta, fragmento o `userInfo`.
9. Evidencia redactada por defecto, con `effectiveUri` eliminado.
10. Entrada no confiable con cinco barreras y recálculo obligatorio.
11. Migraciones transaccionales con verificación previa al borrado.
12. Aislamiento —no borrado— de registros ilegibles.
13. Rotación de llave transaccional con limpieza de material huérfano.
14. Portapapeles con borrado programado y confirmación previa.
15. Diagnóstico sin mensajes ni cargas.
16. `allowBackup="false"` en Android.
17. Permisos mínimos: cámara y biometría.
18. Dependencias fijadas, lockfile, SBOM, licencias y acciones a SHA.
19. Verificadores offline que fallan ante una regresión de contrato.
20. Análisis estático estricto con `--fatal-infos` en CI.

Controles ausentes o no comprobados

Control	Estado	Consecuencia
Firma digital de la evidencia	Ausente	El checksum no prueba autoría; el campo <code>assurance</code> lo declara
Cadena automática de evidencias	Ausente	<code>previousEvidenceHash</code> debe enlazarse a mano
FLAG_SECURE / protección de capturas	Ausente	La vista previa del sistema puede mostrar contenido
Detección de root o jailbreak	Ausente	Un dispositivo comprometido puede leer la memoria
Ofuscación del binario	Ausente	El APK es analizable
Certificate pinning	No aplica	No hay red
Firma comercial del APK	Ausente	Se firma con la clave de depuración de Flutter; <code>apksigner</code> valida el esquema v2, no la identidad
Escaneo de vulnerabilidades de dependencias	No ejecutado aquí	Requiere una herramienta externa
Pruebas de penetración	No realizadas	—

Auditoría independiente	No realizada	—
Validación en dispositivo físico	Pendiente	Cámara, biometría, almacén y ciclo de vida
Conformidad UTS #39	Parcial	Se detecta presencia y mezcla de tres alfabetos; no hay skeleton ni perfiles
Public Suffix List	Ausente	La familia de host se aproxima por sufijo

Pruebas de seguridad existentes

Prueba	Qué demuestra
<code>payload_cipher_test.dart</code>	Ida y vuelta, sobre heredado, llave ausente, manipulación rechazada, versión futura rechazada
<code>data_maintenance_test.dart</code>	Rotación transaccional, aborto antes de tocar metadatos, limpieza de llave huérfana
<code>recovery_service_test.dart</code>	El paquete conserva el texto cifrado y no incluye la llave
<code>diagnostics_test.dart</code>	El diagnóstico no incluye mensajes ni valores sensibles
<code>import_service_test.dart</code>	Límites y, sobre todo, que un respaldo no puede inyectar un veredicto
<code>scan_record_test.dart</code>	OTP, Wi-Fi con contraseña y URL con secreto se clasifican como sensibles
<code>qr_evidence_exporter_test.dart</code>	Redacción, detección de alteración y canonicalización
<code>qr_investigation_engine_test.dart</code>	Punycodé, <code>userInfo</code> , esquema ejecutable, control codificado, redirección anidada, APK, red privada

Plan completo, con lo que falta: `../security/SECURITY_TEST_PLAN.md`. Modelo de amenazas: `../security/THREAT_MODEL.md`. Matriz MASVS: `../security/MASVS_CHECKLIST.md`.

Cómo reportar una vulnerabilidad

Mediante GitHub Security Advisories, según `../SECURITY.md`. Sin adjuntar QR reales, OTP, contraseñas, semillas, documentos de identidad ni datos de pago.

12 · Pruebas y calidad

Qué se ejecutó y qué no, en este análisis

Comprobado localmente:

Comando	Resultado
<code>python tool/verify_rootcause_contract.py</code>	Correcto: 26 reglas coherentes entre motor, esquema, textos, fixtures, política, versión y redacción
<code>python tool/validate_structure.py --require-lock</code>	Correcto
Recuento de casos sobre <code>test/</code> e <code>integration_test/</code>	88 declarados

No ejecutado localmente: `flutter analyze`, `flutter test` y las compilaciones. Flutter y Dart no están instalados en la máquina de análisis.

Comprobado en la CI pública, ejecución [33029927460](#) sobre el commit `a7ebf2c`:

Gate	Resultado
Estructura y contrato offline	Correcto
<code>flutter analyze --fatal-infos</code>	Sin hallazgos
<code>flutter test --coverage</code>	Verde
<code>flutter build web --release</code>	Correcto
<code>flutter build apk --release</code>	Correcto
<code>flutter build ios --debug --simulator</code>	Correcto

Tipos de prueba existentes

Tipo	Archivos	Casos	Necesita dispositivo
Unitarias puras	15	55	No
De widget	5	15	No
Con base de datos en memoria	3	17	No
De integración	1	1	Sí

`flutter test` ejecuta los 87 de `test/`. El caso de `integration_test/` exige un dispositivo o emulador y no forma parte del gate de CI.

Inventario por área

Área	Archivo	Casos
Motor de reglas	test/core/qr_investigation_engine_test.dart	3
Adaptador de riesgo	test/scan_security_analyzer_test.dart	9
Barra de estado y overlay	test/features/scan_status_bar_test.dart	5
Confirmación de lectura	test/services/scan_feedback_test.dart	6
Intérprete de contenido	test/content_interpreter_test.dart	6
Cifrado	test/core/payload_cipher_test.dart	5
Importación	test/services/import_service_test.dart	5
Evidencia	test/core/qr_evidence_exporter_test.dart	4
Registro de lectura	test/scan_record_test.dart	4
Localización	test/core/localization_test.dart	4
Marco de teléfono	test/core/handheld_frame_test.dart	4
Rotación de llave	test/core/data_maintenance_test.dart	3
Geometría del visor	test/features/scanner_viewport_geometry_test.dart	3
Configuración del motor de captura	test/features/scanner_engine_config_test.dart	3
Cola de escrituras	test/core/async_write_queue_test.dart	2
Cancelación y progreso	test/core/cancellation_token_test.dart	2
Migración de esquema	test/core/schema_migrator_test.dart	1
Recuperación	test/core/recovery_service_test.dart	1
Diagnóstico	test/core/diagnostics_test.dart	1
Accesibilidad	test/core/accessibility_test.dart	1
Historial	test/services/history_repository_test.dart	1
Registro de parsers	test/services/content_parser_registry_test.dart	1
Sesión de inventario	test/inventory_session_test.dart	1
Arranque	integration_test/app_launch_test.dart	1

Cobertura observable

La CI genera `coverage/lcov.info` y lo publica como artefacto, pero **no hay umbral de cobertura** ni informe agregado en el repositorio. Por eso este documento no cita un porcentaje: sería un número no verificado.

Lo que sí puede afirmarse leyendo el código y las pruebas:

Módulo	Cobertura de comportamiento	Comentario
--------	-----------------------------	------------

QrInvestigationEngine	Alta	13 casos sobre las reglas de mayor peso, incluidos negativos
PayloadCipher	Alta	Los cinco caminos de fallo
QrEvidenceExporter	Alta	Redacción, alteración, canonicalización y validación de entrada
ImportService	Alta	Límites y el control anti-inyección de veredicto
DataMaintenanceService	Alta	Incluido el caso de llave huérfana
ContentInterpreter	Media	6 de 17 familias de contenido
ScanStatusBar	Media-alta	Cinco estados y movimiento reducido
ScanFeedback	Alta	Los dos canales y toda la degradación
ScanRecord	Media	Serialización, binario y sensibilidad
HistoryRepository	Baja	Solo <code>replaceAll</code> . Sin pruebas de la migración heredada
InventoryRepository	Ninguna directa	—
SettingsRepository	Ninguna	—
RecoveryService	Baja	Solo el paquete de export
ScannerScreen	Ninguna	Requiere cámara
InventoryScreen	Ninguna	Requiere cámara
HistoryScreen	Ninguna	—
GeneratorScreen	Ninguna	—
SettingsScreen	Ninguna	—
ScanResultsSheet	Ninguna	—
PdfPageRenderer	Ninguna	Requiere <code>dart:io</code> y un PDF
ExportService	Ninguna	Requiere la hoja de compartir
BiometricService	Ninguna	Requiere plataforma

Cómo ejecutar las pruebas

<code>flutter test</code>
<code>flutter test --coverage</code>
<code>flutter test test/core/qr_investigation_engine_test.dart</code>
<code>flutter test integration_test/app_launch_test.dart</code>

Verificadores offline, que no necesitan Flutter:

```
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py
```

Datos y fixtures

Recurso	Qué contiene	Quién lo valida
<code>fixtures/qr/manifest.json</code>	12 casos sintéticos con carga, severidad, acción esperadas y reglas que deben o no aparecer	<code>verify_rootcause_contract.py</code>
<code>test_assets/manifest.json</code>	Imágenes reales de regresión por categoría	<code>validate_structure.py</code>
<code>test_assets/qr/,wifi,damaged,low_light,gs1,multiple_codes</code>	PNG reales	—

Reglas que el verificador impone a los fixtures:

- mínimo 12 casos, con id único;
- acción y severidad dentro de los valores válidos;
- toda regla citada debe existir en el motor;
- **hosts reservados obligatorios:** `.example`, `example.com` o `192.168.*`, con `bit.ly` como única excepción, necesaria para probar la regla de acortadores;
- once reglas concretas deben tener al menos un fixture que las cubra.

Hallazgo. Los 12 fixtures **no los consume ninguna prueba Dart**. Los valida el verificador Python, que comprueba su forma y su coherencia con el motor, pero nadie ejecuta el motor contra ellos y compara el resultado con `expectedSeverity` y `expectedAction`. Es la oportunidad de mejora más rentable del repositorio. Registrado en [15-risks-and-technical-debt.md](#).

Lo mismo ocurre con `test_assets/`: las imágenes existen y su manifiesto se valida, pero ninguna prueba las decodifica —haría falta el motor nativo de la plataforma—.

Herramientas de análisis estático

Herramienta	Configuración	En CI
<code>flutter analyze --fatal-infos</code>	<code>analysis_options.yaml</code>	Sí, bloqueante
<code>flutter_lints</code> 6.0.0	Base	Sí
Reglas propias	<code>always_declare_return_types</code> , <code>avoid_print</code> , <code>prefer_final_locals</code> , <code>use_build_context_synchronously</code>	Sí
<code>validate_structure.py</code>	14 comprobaciones	Sí, bloqueante
<code>verify_rootcause_contract.py</code>	Contrato de reglas y evidencia	Sí, bloqueante

`--fatal-infos` convierte cualquier sugerencia en error. Es un gate estricto: en la primera ejecución de CI de la versión 0.1.1, un único `undefined_class` tumbó todo el pipeline, que es exactamente lo que debe ocurrir.

Las cuatro reglas propias tienen intención:

- `avoid_print` impide que una carga escaneada acabe en la consola;
- `use_build_context_synchronously` evita usar un contexto tras un `await`, un fallo frecuente en pantallas con diálogos;
- `always_declare_return_types` y `prefer_final_locals` sostienen la legibilidad.

Qué comprueba `validate_structure.py`

Comprobación	Qué previene
<code>check_yaml</code>	YAML inválido en manifiesto y workflows
<code>check_action_pins</code>	Acciones sin fijar a SHA de commit
<code>check_imports</code>	Import local a un archivo inexistente
<code>check_absolute_paths</code>	Rutas del entorno de desarrollo filtradas al repositorio
<code>check_version</code>	Formato de versión inválido
<code>check_interface_version</code>	Que la interfaz muestre una versión distinta de la construida
<code>check_sensitive_logging</code>	Registro de contenido sensible
<code>check_test_assets</code>	Manifiesto de regresión que apunte a un archivo inexistente
<code>check_json_files</code>	JSON inválido
<code>check_markdown_links</code>	Enlace Markdown local roto
<code>check_landing</code>	Recurso de la landing inexistente o no ensamblado por el workflow
<code>check_launcher_assets</code>	Icono de producto ausente o vacío
<code>check_mobile_product_scope</code>	Que el escritorio vuelva a presentarse como plataforma del producto
<code>check_source_sbom</code>	SBOM de fuente ausente o no CycloneDX

Integración continua

Tres workflows; detalle en [13-deployment-and-operations.md](#).

Workflow	Disparo	Bloquea
<code>flutter-ci.yml</code>	push a <code>main/develop</code> , PR, manual	Sí
<code>android-release.yml</code>	tag <code>VX.Y.Z</code>	Sí: analiza y prueba antes de compilar
<code>deploy-landing.yml</code>	cambios publicables en <code>main</code>	No al código

Que el workflow de release **repita** análisis y pruebas antes de compilar es deliberado: garantiza que ningún artefacto se publique desde un árbol que no pasa el gate.

Criterios de aceptación

Los que aplica la CI hoy:

1. estructura y contrato offline correctos;
2. `flutter analyze --fatal-infos` sin hallazgos;
3. `flutter test` en verde;
4. compilan Android, web e iOS simulador;
5. para un release, la versión del tag coincide con `pubspec.yaml`.

Los que **no** aplica y están declarados como pendientes:

6. matriz de dispositivos físicos —ver `../quality/DEVICE_TEST_MATRIX.md`;
7. accesibilidad con lector de pantalla real;
8. umbral de cobertura;
9. auditoría de seguridad independiente.

Casos límite ya cubiertos

Vale la pena conocerlos, porque son los que documentan decisiones sutiles:

Caso	Prueba
Un dominio que empieza por <code>fc</code> no es una IPv6 privada	motor
Un correo en la consulta no es una credencial	analizador
La huella cubre la carga exacta, con espacios y controles	motor
Un control codificado bloquea también un <code>mailto:</code>	motor
El checksum de evidencia resiste reordenar las claves	evidencia
Un enlace anterior mal formado se rechaza	evidencia
Una escritura fallida no bloquea las siguientes	cola
Un idioma no soportado no produce interfaz a medias	localización
Exactamente en el umbral de 560 px la pantalla se llena	marco
Con movimiento reducido la barra es legible sin animación	barra de estado
Un lector de pantalla distingue captura de pausa	barra de estado
Un reproductor de audio que falla degrada y deja de intentarlo	confirmación

Propuesta priorizada de pruebas faltantes

Ordenada por relación entre riesgo cubierto y esfuerzo.

Prioridad 1 — riesgo alto, esfuerzo bajo

Prueba	Por qué
Ejecutar los 12 fixtures contra el motor y comparar severidad, acción, <code>mustInclude</code> y <code>mustExclude</code>	El activo de regresión existe y nadie lo usa. Es la brecha más grande
<code>HistoryRepository</code> : migración heredada completa	El procedimiento con más riesgo de pérdida de datos no tiene prueba propia
<code>HistoryRepository</code> : registro ilegible se aísla y el resto carga	Propiedad de resiliencia central
<code>HistoryRepository</code> : recorte a <code>maxItems</code> y poda por retención	Borran datos de la persona
<code>SettingsRepository</code> : valores por defecto y <code>resetNonSensitive</code>	Se apoya en ella el arranque seguro

Prioridad 2 — riesgo alto, esfuerzo medio

Prueba	Por qué
<code>InventoryStore</code> con la cola: lecturas y ediciones concurrentes	La cola tiene prueba; su uso real no
<code>ScanResultsSheet</code> : <code>block</code> no muestra botón; <code>confirm</code> exige diálogo	Es una propiedad de seguridad verificada hoy solo por un <code>grep</code> del verificador
<code>ScanResultsSheet</code> : la ocultación de sensibles funciona	Control de exposición
<code>ContentInterpreter</code> : las 11 familias sin cobertura, en especial AAMVA, Swiss QR y EPC	Deciden <code>sensitive</code>
<code>ScanRecord.fromJson</code> con <code>trustDerivedAnalysis</code> en ambos valores	Control anti-inyección

Prioridad 3 — completitud

Prueba	Por qué
<code>ExportService</code> : cabeceras y escapado del CSV	Un carácter mal escapado corrompe el archivo
<code>PdfPageRenderer</code> : cancelación y limpieza	Requiere un PDF de prueba
<code>RecoveryService.retry</code> y <code>discard</code>	Solo el export tiene prueba
Widget del historial: filtros y búsqueda	—
Umbral de cobertura en CI	Evita regresiones silenciosas

Prioridad 4 — requiere dispositivo

Toda la matriz de `../quality/DEVICE_TEST_MATRIX.md`, con las cuatro filas añadidas en 0.1.1: código lejano y descentrado, confirmación de captura, relectura del mismo código y conteo de unidades repetidas.

13 · Despliegue y operación

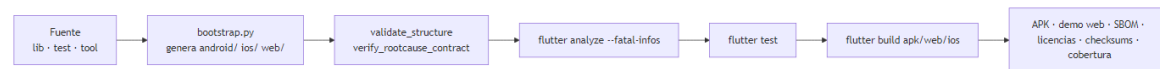
Entornos

No hay entornos de servidor. No existe despliegue de backend, base de datos gestionada ni infraestructura que operar. Lo que se despliega son artefactos.

«Entorno»	Qué es	Dónde vive
Desarrollo	Máquina con Flutter y un dispositivo o emulador	Local
Integración	Runners de GitHub Actions	Efímeros
Distribución	GitHub Releases	Un APK y su checksum
Documentación pública	GitHub Pages	Landing en / y demo web en /app/
Producción real	El teléfono de cada persona	Base cifrada local

La última fila es la que define la operación: **no hay nada que monitorizar del lado del servidor**, porque no hay servidor.

Proceso de construcción



Explicación. El orden no es casual: primero las comprobaciones baratas que no necesitan Flutter, después el análisis estático, después las pruebas y solo al final la compilación. Un fallo de contrato se detecta en segundos, sin gastar minutos de runner.

Empaquetado

Plataforma	Artefacto	Comando	Publicado
Android	APK release	<code>flutter build apk --release</code>	Sí, en GitHub Releases
Android	App Bundle	<code>flutter build appbundle --release</code>	No: pendiente para tienda
iOS	App de simulador	<code>flutter build ios --debug --simulator</code>	No: solo se compila en CI
iOS	IPA	<code>flutter build ipa --release</code>	No: requiere firma y cuenta
Web	Sitio estático	<code>flutter build web --release</code>	Sí, como demo , no como producto

Sobre la firma del APK

El APK publicado está firmado con la **clave de depuración** que genera Flutter. El workflow ejecuta `apksigner verify --verbose --print-certs`, que confirma el esquema de firma v2 y que hay un firmante, y publica el SHA-256 del archivo.

Eso no equivale a una firma comercial de tienda. Es exactamente lo que la documentación del repositorio declara, y conviene repetirlo en cualquier informe: la verificación demuestra integridad del archivo, no identidad del publicador.

Contenedores e infraestructura

No identificados. No hay Dockerfile, ni Compose, ni Kubernetes, ni Terraform, ni proveedor de nube. La única infraestructura son los runners de GitHub y GitHub Pages.

CI/CD

`flutter-ci.yml` — calidad y compatibilidad

Aspecto	Valor
Disparo	push a <code>main</code> o <code>develop</code> , cualquier pull request, o manual
Permisos	<code>contents: read</code>
Trabajos	<code>quality</code> en Ubuntu y <code>ios</code> en macOS

Pasos del trabajo principal, en orden:

1. checkout, Python 3.12, uv 0.12.5, Flutter 3.44.7 con caché;
2. **comprobaciones offline:** `validate_structure.py --require-lock` y `verify_rootcause_contract.py`;
3. `bootstrap.py --platforms android,web`;
4. verificación de que existe `pubspec.lock` y `flutter pub deps`;
5. `flutter analyze --fatal-infos`;
6. `flutter test --coverage`;
7. SBOM e inventario de licencias;
8. `flutter build web --release`;
9. `flutter build apk --release`;
10. checksums;
11. subida de artefactos.

Artefactos conservados: APK, demo web, SBOM, licencias, checksums, `coverage/lcov.info`, `pubspec.lock` y el manifiesto de recursos de prueba.

El trabajo de iOS corre en macOS —Xcode lo exige— y compila para simulador, que no necesita identidad de firma.

`android-release.yml` — publicación

Aspecto	Valor
Disparo	tag que cumpla <code>v[0-9]+.[0-9]+.[0-9]+</code>

Permisos	<code>contents: write, id-token: write, attestations: write</code>
Tiempo máximo	35 minutos

Pasos:

1. **verificación de versión:** el nombre del tag debe coincidir exactamente con la versión de `pubspec.yaml`. Si no, el workflow falla antes de compilar;
2. comprobaciones offline de estructura y contrato;
3. generación del proyecto Android;
4. `flutter analyze --fatal-infos` y `flutter test`;
5. `flutter build apk --release`;
6. copia a `rootcause-qr-inspector-<tag>-android.apk`, verificación con `apksigner` y generación del `.sha256`;
7. **atestación de procedencia** con `actions/attest-build-provenance`;
8. publicación con `gh release create ... --notes-file docs/releases/<tag>.md --verify-tag`.

El paso 8 exige que exista `docs/releases/<tag>.md`. Etiquetar sin escribir antes las notas hace fallar la publicación.

deploy-landing.yml — landing y demo

Se dispara con cambios en `landing/`, `lib/`, `web/`, `assets/`, las capturas de Android, el manifiesto, el lockfile, el bootstrap o el propio workflow. Compila la demo con `--base-href /rootcause-qr-inspector/app/`, ensambla el sitio y lo despliega en Pages. Los pasos de ensamblado comprueban con `test -f` que cada recurso existe antes de publicar.

`validate_structure.py` verifica que ese ensamblado siga copiando los recursos que la landing referencia: si alguien añade una imagen a la landing y no la copia en el workflow, el gate falla antes del despliegue.

Publicación de una versión

Procedimiento completo, en orden:

```
# 1. Cambiar la versión en los dos sitios que deben coincidir
#   pubspec.yaml           → version: X.Y.Z+N
#   lib/core/app_info.dart → const String appVersion = 'X.Y.Z';

# 2. Escribir las notas de la versión
#   docs/releases/vX.Y.Z.md

# 3. Actualizar el CHANGELOG con una entrada NUEVA
#   la historia anterior no se reescribe

# 4. Comprobar en local lo que no necesita Flutter
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py

# 5. Regenerar el manifiesto de fuente
python tool/generate_source_manifest.py

# 6. Confirmar y publicar la rama
git add <rutas explícitas>
git commit
git push origin main

# 7. ESPERAR A QUE LA CI ESTÉ EN VERDE
```

```
gh run watch <id>

# 8. Solo entonces, etiquetar
git tag -a vX.Y.Z -m "...
git push origin vX.Y.Z

# 9. Verificar el artefacto publicado
gh release view vX.Y.Z --json assets
gh release download vX.Y.Z --pattern "*.sha256"
gh release download vX.Y.Z --pattern "*.apk"
sha256sum -c rootcause-qr-inspector-vX.Y.Z-android.apk.sha256
```

El paso 7 no es opcional. El workflow de release repite el gate, así que un árbol roto no publica nada, pero descubrirlo ahí gasta 35 minutos y deja un tag inútil en el repositorio.

El paso 9 tampoco: un release con assets de 0 bytes, o con un fichero de checksums que no verifica, es un release roto aunque el workflow esté en verde.

Migraciones en despliegue

No hay migraciones que lanzar. Las de esquema las ejecuta la propia aplicación al abrir la base, dentro de una transacción, y son idempotentes. Ver [07-database.md](#).

Lo que sí exige atención al publicar una versión que cambie datos:

Cambio	Obligación
Nuevo paso de esquema	Idempotente y transaccional
Nueva versión de sobre cifrado	Los sobres antiguos deben seguir leyéndose
Cambio en una regla del motor	Subir <code>engineVersion</code>
Cambio en el formato de evidencia	Nueva versión del esquema, no una modificación silenciosa
Cambio de significado de una preferencia	Conservar la clave y no relajar la elección de la persona

Los tres primeros están recogidos como compromisos en [../quality/COMPATIBILITY_CONTRACT.md](#).

Registros

Fuente	Qué hay
Aplicación	Nada. <code>avoid_print</code> está activo y no hay librería de logging
Diagnóstico	Máximo 100 entradas en memoria, sin mensajes ni cargas
CI	Registros de GitHub Actions, con su retención por defecto
Dispositivo	Lo que emita el sistema operativo

Consecuencia operativa: **no hay forma de investigar un incidente a posteriori** salvo que la persona copie su diagnóstico privado y lo comparta. Es un compromiso deliberado a favor de la privacidad.

Métricas, monitoreo y alertas

No existen, por diseño. No hay telemetría, ni informes de fallo, ni analítica de uso. Nadie sabe cuántas personas usan la aplicación ni qué escanean.

Lo único observable desde fuera:

Señal	Dónde
Estado de la CI	Insignia del README y pestaña Actions
Descargas del release	Contador de GitHub Releases
Estado de Pages	Historial de despliegues
Avisos de dependencias	Dependabot

RespalDOS

Ver [07-database.md](#). Resumen operativo:

- **no hay respaldo automático de los datos de la persona;**
- `allowBackup="false"` mantiene la base fuera de la copia del sistema, algo coherente con que la llave viva en el Keystore y no viaje con ella;
- la única vía es exportar el historial, y ese archivo **no está cifrado**;
- **desinstalar la aplicación equivale a perder el historial**, sin recuperación.

Esto último debe comunicarse a cualquier persona que use el producto de forma seria.

Recuperación

Escenario	Procedimiento
La aplicación no arranca	Pantalla Inicio seguro : reintentar, abrir sin datos persistentes, restablecer preferencias visuales o copiar diagnóstico
Un registro no se descifra	Ajustes → Centro de recuperación: reintentar, descartar solo ese registro o marcarlo revisado
Migración pendiente	Ajustes → «Reintentar migración del historial». El origen y su respaldo cifrado se conservan
Llave ausente	El descifrado informa y bloquea escrituras con esa llave. Recuperar, rotar o descartar de forma explícita
Base ilegible	Modo temporal para seguir trabajando sin tocar los datos
Cámara que no arranca	«Reintentar» reconstruye el controlador

Reversión

Qué revertir	Cómo
Una versión publicada	La anterior sigue disponible en Releases. Android puede exigir desinstalar antes si la firma difiere

Un cambio en <code>main</code>	<code>git revert</code> y nueva versión: no reescribir la historia publicada
Un release equivocado	Marcarlo como <i>pre-release</i> o borrarlo, y publicar una versión de corrección. Un tag ya publicado no debe reutilizarse
Un despliegue de Pages	Volver a ejecutar el workflow desde el commit correcto
Los datos de la persona	No hay reversión. Un borrado es definitivo

La última fila es la más importante y conviene tenerla presente antes de tocar cualquier código que borre.

Mantenimiento básico

Tarea	Frecuencia	Cómo
Revisar Dependabot	Semanal	Una dependencia por PR, con pruebas
Regenerar SBOM y licencias	En cada release	La CI lo hace
Regenerar <code>SOURCE_MANIFEST.json</code>	Al cambiar la fuente	<code>python tool/generate_source_manifest.py</code>
Revisar los anclajes de <code>pdfx</code> y <code>excel</code>	Cuando <code>excel</code> publique sobre <code>archive ^4</code>	<code>../quality/LOCKFILE.md</code>
Revisar la cadena Gradle	Al subir Flutter	Constantes en <code>tool/bootstrap.py</code>
Comprobar coherencia de la documentación	Al cambiar versión o conteos	<code>validate_structure.py</code> y una revisión de afirmaciones
Ampliar la matriz de dispositivos	Antes de una publicación en tienda	<code>../quality/DEVICE_TEST_MATRIX.md</code>

Actualizar Flutter

Cambiar la versión implica tocar cuatro sitios a la vez:

1. `.fvmrc`;
2. `FLUTTER_VERSION` en los tres workflows;
3. `pubspec.yaml` si cambia el mínimo;
4. las constantes de la cadena Gradle en `tool/bootstrap.py`, si la nueva plantilla genera otras versiones.

Generar los PDF de la documentación

```
python tool/build_system_documentation_pdf.py
```

Produce un PDF por cada documento de `docs/system-documentation/`, más uno consolidado, dentro de `docs/system-documentation/pdf/`.

Requisito	Para qué	Si falta
markdown	Markdown a HTML	El script se detiene con instrucciones
xhtml2pdf	HTML a PDF	Igual

mmdc (@mermaid-js/mermaid-cli)	Diagramas Mermaid a PNG	Degrada con aviso: el diagrama se incluye como texto
--------------------------------	-------------------------	---

Instalación de lo opcional:

```

pip install markdown xhtml2pdf
npm install -g @mermaid-js/mermaid-cli

```

Los diagramas se cachean por hash de su contenido, así que una segunda ejecución solo vuelve a renderizar lo que cambió.

14 · Solución de problemas

Cada entrada sigue el mismo formato: síntoma, causa posible, diagnóstico, solución, archivos relacionados y riesgo de aplicar la solución.

Esta guía cubre el punto de vista de quien **desarrolla y opera**. La guía orientada a quien **usa** la aplicación está en [../TROUBLESHOOTING.md](#).

Instalación y compilación

No such file or directory: android/

Aspecto	Detalle
Causa	Las carpetas nativas no se versionan; hay que generarlas
Diagnóstico	<code>ls android ios web</code> no encuentra nada
Solución	<code>python tool/bootstrap.py --platforms android,web</code>
Archivos	<code>tool/bootstrap.py</code> , <code>.gitignore</code>
Riesgo	Ninguno. Con <code>--force</code> sí: borra y regenera, y pierde cambios hechos a mano

cannot find symbol: class FilePickerPlugin

Aspecto	Detalle
Causa	La plantilla de Flutter 3.44.7 genera AGP 9. Varios plugins dejan de aplicar el Kotlin Gradle Plugin al detectarlo, dando por hecho el Kotlin integrado, pero la misma plantilla entrega <code>android.builtInKotlin=false</code> : nadie compila su Kotlin
Diagnóstico	<code>grep 'com.android.application' android/settings.gradle.kts</code> muestra una versión 9.x
Solución	Volver a ejecutar el bootstrap, que fija AGP 8.11.1, KGP 2.2.20 y Gradle 8.14.3
Archivos	<code>tool/bootstrap.py</code> (<code>patch_android_toolchain</code>)
Riesgo	Activar el Kotlin integrado rompe el caso contrario, en los plugins que sí aplican KGP

Falta pubspec.lock

Aspecto	Detalle
Causa	<code>--require-lock</code> exige el lockfile versionado
Diagnóstico	<code>ls pubspec.lock</code>
Solución	<code>flutter pub get</code> con la versión fijada y confirmar el archivo

Riesgo	Regenerarlo con otra versión de Flutter puede mover dependencias transitivas
--------	--

ModuleNotFoundError: yaml

Aspecto	Detalle
Causa	<code>validate_structure.py</code> y <code>generate_sbom.py</code> necesitan <code>pyyaml</code>
Solución	<code>pip install pyyaml</code> , o <code>uv run --with pyyaml python tool/...</code> como hace la CI
Riesgo	Ninguno

Conflicto al resolver `pdfrx` o `excel`

Aspecto	Detalle
Causa	<code>pdfrx</code> $\geq 2.4.6$ arrastra <code>archive</code> $\wedge 4$, incompatible con el <code>archive</code> $\wedge 3.6.1$ que exige <code>excel</code> $4.0.6$
Diagnóstico	<code>flutter pub get</code> falla en la resolución
Solución	Mantener los anclajes. <code>flutter pub outdated</code> los mostrará como actualizables: es esperado
Archivos	<code>pubspec.yaml</code> , <code>.github/dependabot.yaml</code> , <code>../quality/LOCKFILE.md</code>
Riesgo	Subirlos sin resolver el conflicto rompe la compilación

Gates y verificadores

La versión mostrada en la interfaz no coincide con `pubspec.yaml`

Aspecto	Detalle
Causa	Se cambió <code>pubspec.yaml</code> sin cambiar <code>lib/core/app_info.dart</code>
Solución	Igualar ambos valores
Riesgo	Ninguno. La comprobación existe porque esa deriva ya ocurrió antes

El motor 0.1.0 debe declarar 26 reglas; encontró N

Aspecto	Detalle
Causa	Se añadió o quitó una llamada a <code>evaluate('...')</code>

Solución	Completar la entrega: motor, <code>QrFindingText</code> , esquema, <code>HEURISTICS.md</code> , fixture, pruebas y <code>engineVersion</code> . Si el número cambia a propósito, actualizar también el verificador
Archivos	<code>tool/verify_rootcause_contract.py</code> , motor, textos, esquema, heurísticas
Riesgo	Cambiar solo el verificador para que pase oculta una regla huérfana

Desalineación motor ↔ schema O motor ↔ textos

Aspecto	Detalle
Causa	Un id existe en un archivo y no en los demás
Diagnóstico	El mensaje lista qué falta y qué sobra
Solución	Añadir el id al esquema y a <code>QrFindingText.title</code>
Riesgo	Un id sin texto se muestra crudo en la interfaz

Enlace Markdown local inexistente

Aspecto	Detalle
Causa	Un enlace relativo apunta a un archivo que no existe
Diagnóstico	El mensaje da archivo y destino
Solución	Corregir la ruta o crear el archivo
Riesgo	Ninguno. Este gate es lo que mantiene la documentación navegable

Action no fijada a commit SHA

Aspecto	Detalle
Causa	Se usó <code>uses: org/action@v1</code> en vez del SHA de 40 caracteres
Solución	Fijar el SHA y dejar la versión legible en un comentario
Riesgo	Una etiqueta móvil puede cambiar bajo los pies y ejecutar otro código

undefined_class u otro error de flutter analyze

Aspecto	Detalle
Causa	<code>--fatal-infos</code> convierte cualquier hallazgo en error
Diagnóstico	<code>flutter analyze --fatal-infos</code> en local; en CI, <code>gh run view <id> --log-failed</code>

Solución	Corregir el hallazgo
Riesgo	Relajar <code>analysis_options.yaml</code> debilita el gate para todo el repositorio

Ocurrió en esta versión: sustituir `package:flutter/foundation.dart` por `package:flutter/widgets.dart` dejó `ValueListenable` sin definir, porque `widgets.dart` reexporta `Size` pero no ese tipo. La CI lo detectó y bloqueó la publicación, que es exactamente lo que debe hacer.

Cámara y lectura

La cámara no arranca

Aspecto	Detalle
Causa	Permiso denegado, dispositivo sin cámara compatible, u otra aplicación ocupándola
Diagnóstico	La barra muestra <code>Sensor no disponible</code> con el mensaje específico. El de permiso es distinto del genérico
Solución	Conceder el permiso, cerrar la otra aplicación, o pulsar «Reintentar», que reconstruye el controlador
Archivos	<code>scanner_screen.dart</code> (<code>_startCamera</code> , <code>_restartCamera</code> , <code>_describe</code>)
Riesgo	Ninguno: reiniciar libera la sesión de cámara antes de crear la nueva

La vista previa se queda congelada al volver del segundo plano

Aspecto	Detalle
Causa	<code>MobileScanner</code> solo gestiona el ciclo de vida cuando él crea el controlador. Aquí lo crea la pantalla
Diagnóstico	La imagen no se actualiza tras volver de otra aplicación
Solución	Ya está resuelto: ambas pantallas con cámara observan <code>didChangeAppLifecycleState</code> . Si reaparece, comprobar que ese método no se eliminó
Archivos	<code>scanner_screen.dart</code> , <code>inventory_screen.dart</code>
Riesgo	Quitar la observación reintroduce el fallo original

Un código legible no se lee

Aspecto	Detalle
Causa 1	Resolución insuficiente para un código lejano

Causa 2	Antes de 0.1.1, el marco filtraba la detección y descartaba en silencio lo que quedara fuera
Diagnóstico	Acercarse: si a 20 cm sí lee, es alcance. Descentrar el código: si deja de leer, el marco está filtrando
Solución	Acercarse o usar el zoom. Comprobar que <code>MobileScanner</code> no recibe <code>scanWindow</code> y que <code>cameraResolution</code> está declarada
Archivos	<code>mobile_scanner_engine.dart</code> , <code>scanner_screen.dart</code> , <code>test/features/scanner_engine_config_test.dart</code>
Riesgo	Subir la resolución aumenta memoria y temperatura en gama baja: medir antes

La barra dice «Ese código ya se inspeccionó»

Aspecto	Detalle
Causa	Es el filtro de repetición, no un fallo
Diagnóstico	El aviso aparece mientras el mismo código sigue delante del lente
Solución	Apartar la cámara unos segundos y volver a apuntar, o pulsar «Reiniciar cámara», que limpia la firma
Archivos	<code>scanner_screen.dart</code> (<code>_repeatWindow</code> , <code>_showRepeatNotice</code>)
Riesgo	Quitar el filtro reabre el resultado en bucle mientras el código esté a la vista

El inventario no suma unidades repetidas

Aspecto	Detalle
Causa	<code>DetectionSpeed.noDuplicates</code> impedía emitir el mismo código dos veces
Diagnóstico	Escanear diez veces el mismo producto y contar
Solución	Corregido en 0.1.1 con <code>DetectionSpeed.normal</code> . Verificar que el controlador del inventario no volvió a <code>noDuplicates</code>
Archivos	<code>inventory_screen.dart</code> (<code>_createController</code> , <code>_onDetect</code>)
Riesgo	Sin el filtro de 1200 ms de <code>_onDetect</code> , una caja se contaría en cada cuadro

No suena el tono de confirmación

Aspecto	Detalle
---------	---------

Causa 1	sound_enabled desactivado
Causa 2	El reproductor falló y degradó a SystemSound.play, que Android silencia si los sonidos táctiles están apagados
Diagnóstico	Comprobar Ajustes. En pruebas, ScanFeedback.toneUnavailable indica la degradación
Solución	Activar el sonido; comprobar que el asset sigue declarado en pubspec.yaml
Archivos	scan_feedback.dart, assets/sounds/scan_success.wav
Riesgo	Ninguno: el fallo del audio nunca interrumpe una lectura

Datos, cifrado y recuperación

Un registro aparece aislado en el Centro de recuperación

Aspecto	Detalle
Causa	El sobre no se pudo descifrar: llave ausente o carga manipulada
Diagnóstico	El código de la incidencia: decrypt_ValidationError suele ser llave ausente; otro tipo apunta a manipulación
Solución	«Reintentar recuperación». Si falla, descartar solo ese registro
Archivos	recovery_service.dart, payload_cipher.dart
Riesgo	Descartar es irreversible para ese registro. No editar la base a mano

encryption_key_missing:<keyId>

Aspecto	Detalle
Causa	La llave de ese sobre no está en el almacén seguro. Suele ocurrir tras reinstalar o restaurar en otro dispositivo
Diagnóstico	El identificador indica cuál falta
Solución	No hay recuperación posible sin la llave. Descartar los registros afectados o rotar la llave para el contenido que sí se lee
Riesgo	Nunca cambiar el código para que el descifrado use readOrCreate: crearía una llave nueva y perdería todo lo anterior en silencio

La rotación de llave falla

Aspecto	Detalle
---------	---------

Causa	Un registro incompleto (<code>history_payload_missing:<id></code>), un descifrado imposible, u otra rotación en curso
Diagnóstico	El mensaje de la excepción nombra el registro
Solución	Resolver ese registro en el Centro de recuperación y volver a rotar
Archivos	<code>data_maintenance_service.dart</code>
Riesgo	Ninguno para los datos: la transacción se revierte y la llave nueva se borra

El historial aparece vacío

Aspecto	Detalle
Causa 1	<code>private_mode</code> activo o <code>save_history</code> desactivado
Causa 2	Modo temporal: nada persiste
Causa 3	Retención configurada que ya pasó
Causa 4	Solo se escanearon contenidos sensibles, que no se guardan
Diagnóstico	Revisar Ajustes y el banner de modo temporal
Solución	Ajustar las preferencias
Riesgo	La poda por retención es irreversible

La migración del historial heredado no termina

Aspecto	Detalle
Causa	El origen no es una lista válida, o la verificación posterior a la escritura falló
Diagnóstico	<code>history_migration_error</code> y una incidencia con <code>entityId: history_v1_to_v2</code>
Solución	Ajustes → «Reintentar migración del historial»
Archivos	<code>history_repository.dart</code> (<code>_migrateLegacyHistory</code>)
Riesgo	Ninguno: el origen y su respaldo cifrado se conservan hasta que la verificación pasa

La aplicación arranca en «Inicio seguro»

Aspecto	Detalle
Causa	Falló abrir la base, leer preferencias o el almacén seguro

Diagnóstico	La pantalla muestra tipo de error y huella de pila. «Copiar diagnóstico privado» da el detalle sin cargas
Solución	Reintentar; si persiste, abrir sin datos persistentes para seguir trabajando; restablecer preferencias visuales
Riesgo	El modo temporal no conserva nada de esa sesión

Importación y exportación

El respaldo no es válido o no pudo leerse

Aspecto	Detalle
Causa	Tamaño, forma, aplicación no compatible, tipo incorrecto, versión futura o exceso de registros
Diagnóstico	El mensaje de la interfaz es genérico; el detalle está en el <code>FormatException</code>
Solución	Comprobar que el archivo lleva <code>application</code> , <code>type</code> y <code>schemaVersion</code> correctos
Archivos	<code>import_service.dart</code>
Riesgo	Ninguno: nada se escribe hasta elegir la estrategia

La importación descarta registros

Aspecto	Detalle
Causa	Cada registro se recalcula ; los que fallan se cuentan como rechazados
Diagnóstico	La vista previa muestra válidos, duplicados y rechazados
Solución	Es el comportamiento correcto: un respaldo no puede imponer campos derivados
Riesgo	«Reemplazar» sustituye la base completa. Preferir «Combinar» u «Omitir duplicados»

El CSV exportado se ve mal en la hoja de cálculo

Aspecto	Detalle
Causa	Codificación o separador
Diagnóstico	El archivo se escribe con BOM UTF-8 y todas las celdas entrecomilladas
Solución	Importarlo indicando UTF-8 y coma como separador
Archivos	<code>export_service.dart</code> (<code>_encodeCsv</code>)

Riesgo	Recordar que el CSV contiene las cargas en claro
--------	---

Demo web

El PDF no se procesa

Aspecto	Detalle
Causa	El renderizador solo existe con <code>dart:io</code>
Solución	Exportar la página como imagen, o usar una plataforma nativa
Archivos	<code>pdf_page_renderer_stub.dart</code>
Riesgo	Ninguno

Página vacía o recursos 404

Aspecto	Detalle
Causa	Ruta incompleta, o un service worker de una versión anterior
Solución	Abrir la ruta completa <code>/rootcause-qr-inspector/app/</code> , forzar recarga o borrar los datos del sitio
Archivos	<code>.github/workflows/deploy-landing.yml</code>
Riesgo	Ninguno

Documentación y PDF

`python tool/build_system_documentation_pdf.py` se detiene

Aspecto	Detalle
Causa	Falta <code>markdown</code> o <code>xhtml2pdf</code>
Solución	<code>pip install markdown xhtml2pdf</code>
Riesgo	Ninguno

Los diagramas salen como texto

Aspecto	Detalle
Causa	<code>mmdc</code> no está instalado; el script degrada con aviso
Solución	<code>npm install -g @mermaid-js/mermaid-cli</code>
Riesgo	Ninguno: sin <code>mmdc</code> el PDF sigue generándose, con los diagramas como bloque de código

Caracteres corruptos: mÃ¡s, Ã³

Aspecto	Detalle
Causa	Doble codificación UTF-8, típica al escribir desde una consola de Windows sin fijar la codificación
Diagnóstico	<code>grep -rl '\$\xc3\x83' docs/</code>
Solución	Reescribir el archivo leyendo y escribiendo con <code>encoding="utf-8"</code> explícito
Riesgo	Ninguno, pero conviene revisar el archivo entero

Comandos útiles de diagnóstico

```
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py
flutter analyze --fatal-infos
flutter test
gh run list --branch main --limit 5
gh run view <id> --log-failed
gh release view v0.1.1 --json assets
sha256sum -c rootcause-qr-inspector-v0.1.1-android.apk.sha256
grep -rn "package:flutter" lib/core/investigation/
grep -rn "http\.get\|HttpClient\|WebSocket" lib/
```

15 · Riesgos y deuda técnica

Este documento es informativo. Ningún hallazgo se corrigió al escribirlo. Su propósito es que la decisión de arreglar, aceptar o descartar sea humana y explícita.

Cómo leer la clasificación

Campo	Escala
Severidad	Crítica · Alta · Media · Baja
Impacto	Qué se rompe o se expone si ocurre
Probabilidad	Alta · Media · Baja
Evidencia	Comprobado en el código, o inferencia
Prioridad	P1 (antes de la próxima entrega) · P2 (esta serie) · P3 (cuando toque)

Resumen: **19 hallazgos** — 0 críticos, 6 altos, 8 medios, 5 bajos.

Severidad alta

R-01 · Los fixtures de regresión no los ejecuta ninguna prueba

Aspecto	Detalle
Severidad	Alta · Probabilidad Alta · Prioridad P1
Ubicación	fixtures/qv/manifest.json, test/
Evidencia	Comprobado: <code>grep -rn "fixtures" test/</code> no devuelve nada. <code>verify_rootcause_contract.py</code> valida la <i>forma</i> del manifiesto, no ejecuta el motor contra él
Impacto	Los 12 casos declaran <code>expectedSeverity</code> , <code>expectedAction</code> , <code>mustInclude</code> y <code>mustExclude</code> , y nadie comprueba que el motor los cumpla. Un cambio de peso o de condición puede pasar el gate completo sin que nadie note la regresión
Recomendación	Añadir una prueba que lea el manifiesto, ejecute <code>QrInvestigationEngine.analyze</code> sobre cada carga y compare los cuatro campos. Coste estimado: una tarde. Es la mejora con mejor relación coste/beneficio del repositorio

R-02 · La migración del historial heredado no tiene prueba

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P1

Ubicación	lib/services/history_repository.dart, _migrateLegacyHistory
Evidencia	Comprobado: history_repository_test.dart solo cubre replaceAll
Impacto	Es el procedimiento con mayor riesgo de pérdida de datos del sistema: lee un origen en claro, lo respalda cifrado, convierte, verifica y borra el origen . Un error en el orden es irreversible
Recomendación	Pruebas para: origen ausente, origen no-lista, conversión correcta, verificación fallida que revierte, e idempotencia al repetir

R-03 · Los contactos de una vCard entran en el historial

Aspecto	Detalle
Severidad	Alta · Probabilidad Alta · Prioridad P1
Ubicación	lib/services/content_interpreter.dart, _vcard y _mecard
Evidencia	Comprobado: ninguno de los dos marca sensitive: true
Impacto	Nombre, teléfono, correo y dirección postal de terceros quedan guardados —cifrados, pero guardados— sin que la persona lo decida. La política declarada del producto excluye OTP, Wi-Fi, pagos e identidad; los contactos caen en un hueco
Recomendación	Decidir explícitamente: marcarlos sensibles, o documentar en la política de privacidad que los contactos sí se conservan. La decisión es del responsable del producto, no técnica

R-04 · La evidencia no está firmada

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P2
Ubicación	lib/core/investigation/qr_evidence_exporter.dart
Evidencia	Comprobado: assurance: checksum-only-not-authenticated
Impacto	Quien modifique el JSON puede recalcular bundleHash. Si alguien presenta una evidencia como prueba en un procedimiento, el checksum no acredita autoría ni integridad frente a un adversario
Mitigación actual	El propio campo lo declara, y la documentación lo repite
Recomendación	Firma asimétrica opcional, o anclaje externo del hash. Hasta entonces, no describirlo nunca como «evidencia firmada»

R-05 · La corrección de lectura de 0.1.1 no está probada en hardware

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P1
Ubicación	<code>mobile_scanner_engine.dart</code> , <code>scanner_screen.dart</code> , <code>inventory_screen.dart</code>
Evidencia	Comprobado: las pruebas añadidas verifican la configuración, no el comportamiento óptico
Impacto	Subir la resolución a 1920×1080 puede aumentar memoria y temperatura en gama baja. Nadie ha confirmado en un teléfono real que un QR lejano se lea, ni que la confirmación se oiga
Recomendación	Ejecutar las cuatro filas nuevas de la matriz de dispositivos en al menos un teléfono de gama baja y uno de gama alta antes de anunciar la corrección como verificada

R-06 · La pantalla del escáner no tiene pruebas

Aspecto	Detalle
Severidad	Alta · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/scanner/scanner_screen.dart</code> , 780 líneas
Evidencia	Comprobado: no hay ningún archivo de prueba para ella
Impacto	Concentra el filtro de repetición, la política de persistencia de contenido sensible, el ciclo de vida de la cámara y los lotes cancelables. La regla «un registro sensible nunca se guarda» vive aquí y no la comprueba ninguna prueba
Recomendación	Extraer la lógica sin interfaz —filtro de repetición y decisión de persistencia— a funciones puras y probarlas. El widget completo requiere cámara; sus reglas, no

Severidad media

R-07 · `ScannerEngine` filtra el tipo del paquete que abstrae

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/features/scanner/domain/scanner_engine.dart</code>
Evidencia	Comprobado: la interfaz expone <code>MobileScannerController get controller</code> y <code>ValueListenable<MobileScannerState></code>
Impacto	Un segundo motor no podría implementarla sin depender de <code>mobile_scanner</code> . La frontera «estable» no aísla lo que dice aislar

Recomendación	Al añadir un segundo motor, sustituir por un tipo propio de estado. Mientras haya una sola implementación, el coste de arreglarlo supera al beneficio
---------------	---

R-08 · El inventario no usa `ScannerEngine`

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/inventory/inventory_screen.dart</code>
Evidencia	Comprobado: construye <code>MobileScannerController</code> directamente
Impacto	Duplica el ciclo de vida, el manejo de errores y la configuración. La corrección de 0.1.1 tuvo que aplicarse dos veces , y una tercera pantalla con cámara la olvidaría
Recomendación	Migrar el inventario a <code>MobileScannerEngine</code> con su resolución propia

R-09 · Las banderas de capacidades no se leen

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/core/feature_flags/feature_flags.dart</code>
Evidencia	Comprobado: <code>grep -rn "featureFlags\" lib/</code> solo encuentra serialización
Impacto	Nueve booleanos que se guardan y se leen sin efecto. Un lector puede creer que activarlas hace algo
Recomendación	Conservarlas —el contrato de compatibilidad las menciona— y documentar en la interfaz que están reservadas. Ya está documentado en <code>FEATURE_FLAGS.md</code>

R-10 · La lista del historial muestra la carga sin ocultar

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	<code>lib/features/history/history_screen.dart</code>
Evidencia	Comprobado: el subtítulo incluye <code>item.rawValue</code> sin comprobar <code>hideSensitiveValues</code>
Impacto	La ocultación solo se aplica en la tarjeta de detalle. Una URL larga con parámetros queda visible en la lista, y en cualquier captura de pantalla
Mitigación	Los contenidos marcados sensibles no llegan al historial

Recomendación	Aplicar la misma política de ocultación en la lista
---------------	---

R-11 · Sin protección frente a capturas de pantalla

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P2
Ubicación	Todo el árbol de la interfaz
Evidencia	Comprobado: no hay <code>FLAG_SECURE</code> ni equivalente
Impacto	El conmutador de aplicaciones puede mostrar el resultado; una captura conserva un secreto
Mitigación	El bloqueo biométrico oculta el contenido al perder el primer plano, si está activado
Recomendación	Evaluar <code>FLAG_SECURE</code> en las pantallas de resultado e historial. Tiene coste: impide capturas legítimas para soporte

R-12 · `RiskLevel` duplica una fuente de verdad

Aspecto	Detalle
Severidad	Media · Probabilidad Baja · Prioridad P3
Ubicación	<code>lib/core/security/scan_security_analyzer.dart</code>
Evidencia	Comprobado, y el propio código lo declara legado
Impacto	Cada <code>ScanRecord</code> guarda <code>riskLevel</code> y <code>riskReasons</code> derivados que se recalculan al leer. Datos redundantes en el sobre cifrado
Recomendación	Mantener mientras existan filtros e importaciones heredadas. No añadir nuevos consumidores

R-13 · Interfaz solo en español, con infraestructura a medias

Aspecto	Detalle
Severidad	Media · Probabilidad Alta · Prioridad P3
Ubicación	<code>lib/core/localization/app_localizations.dart</code> y todas las pantallas
Evidencia	Comprobado: la clase tiene 10 cadenas; el resto son literales en el código
Impacto	No se puede ofrecer inglés sin dejar la interfaz a medio traducir. Ya hay una prueba que impide exponerlo por accidente
Recomendación	Migrar las cadenas a <code>AppLocalizations</code> de forma incremental, empezando por las pantallas más pequeñas

R-14 · Sin umbral de cobertura

Aspecto	Detalle
Severidad	Media · Probabilidad Media · Prioridad P3
Ubicación	<code>.github/workflows/flutter-ci.yml</code>
Evidencia	Comprobado: se genera <code>lcov.info</code> y se sube, pero no se evalúa
Impacto	La cobertura puede caer sin que nada falle
Recomendación	Fijar un umbral por debajo del valor actual y subirlo poco a poco

Severidad baja

R-15 · `PayloadCipher.legacyKeyId` es idéntico a `currentKeyId`

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: ambos valen <code>'v2'</code>
Impacto	Un sobre heredado sin campo <code>version</code> se interpreta con la llave <code>v2</code> . Si alguna vez existió otra llave, esa distinción se perdió
Recomendación	Documentar por qué coinciden, o unificarlos

R-16 · `AppLanguage.en` es inalcanzable desde la interfaz

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: el desplegable lo convierte a «Sistema»
Impacto	Un valor del enum que ninguna ruta de la interfaz puede producir
Recomendación	Es la solución correcta al problema de la traducción parcial. Conservar hasta completar R-13

R-17 · `ScanRecord.fromJson` confía por defecto

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: <code>trustDerivedAnalysis = true</code> por defecto
Impacto	Es correcto para la base propia y peligroso para un archivo externo. Un llamante nuevo que olvide el parámetro abre el agujero

Mitigación	<code>verify_rootcause_contract.py</code> comprueba que la importación pasa <code>false</code>
Recomendación	Invertir el valor por defecto a <code>false</code> y exigir <code>true</code> explícito en el repositorio

R-18 · El portapapeles no se limpia si la aplicación muere

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: el temporizador vive en el proceso
Impacto	Una carga sensible copiada permanece en el portapapeles del sistema
Recomendación	Documentarlo en la interfaz. Una solución real exigiría un servicio en segundo plano, contrario al diseño

R-19 · El identificador de un registro depende del reloj

Aspecto	Detalle
Severidad	Baja · Prioridad P3
Evidencia	Comprobado: <code>id = SHA-256(carga\ microsegundos)</code>
Impacto	Un reloj mal ajustado produce ids con instantes incorrectos, que además viajan a la evidencia. No hay colisión práctica, pero sí desorden temporal
Recomendación	Aceptable. Documentar que el instante procede del dispositivo y no está verificado

Riesgos operativos, no de código

Id	Riesgo	Severidad	Nota
O-01	El APK se firma con la clave de depuración de Flutter	Alta	Impide una actualización sobre una copia firmada de otra forma y no acredita identidad. Declarado en toda la documentación
O-02	<code>pdfrx</code> y <code>excel</code> anclados por un conflicto de <code>archive</code>	Media	Un aviso de seguridad en cualquiera exigiría resolver antes el conflicto
O-03	Desinstalar equivale a perder el historial	Media	<code>allowBackup="false"</code> y llave en el Keystore. Es coherente, pero debe comunicarse
O-04	Ninguna auditoría de seguridad independiente	Media	Declarado en <code>MASVS_CHECKLIST.md</code>

O-05	Ningún escáner de vulnerabilidades ejecutado	Media	Existen SBOM e inventario de licencias; falta el escaneo
O-06	Matriz de dispositivos físicos vacía	Alta	Ninguna fila obligatoria tiene registro; declarado
O-07	Un solo mantenedor	Media	Factor bus de uno

Decisiones que requieren validación humana

Estas **no** son defectos. Son elecciones con coste que alguien debe confirmar:

1. **¿Los contactos deben persistirse?** (R-03) Es una decisión de privacidad, no técnica.
2. **¿1920×1080 es la resolución correcta?** (R-05) Hay que medir batería y temperatura en gama baja antes de fijarla.
3. **¿Debe firmarse la evidencia?** (R-04) Añade gestión de claves a un producto que hoy no la tiene.
4. **¿Merece la pena FLAG_SECURE?** (R-11) Protege, pero impide capturas de soporte.
5. **¿Se completa la traducción?** (R-13) Abre el producto a más personas y multiplica el mantenimiento de cadenas.
6. **¿Se busca firma comercial y publicación en tienda?** (O-01) Cambia el modelo de distribución y exige cuentas de desarrollador.

Lo que está bien y conviene no romper

Un informe de deuda que solo enumera problemas da una imagen falsa. Estas propiedades son sólidas y merecen protección explícita:

Fortaleza	Por qué importa
El motor es puro y no depende de Flutter	Permite probar sin dispositivo y reutilizar
Los identificadores de regla son neutrales al idioma	Traducir no rompe el formato de evidencia
Un registro ilegible se aísla, no se borra	Ningún dato se pierde por un fallo de lectura
Una llave ausente nunca se recrea	Evita la pérdida silenciosa e irreversible
La migración verifica antes de borrar el origen	El patrón correcto, aplicado
Todo campo derivado de un respaldo se recalcula	Cierra la inyección de veredictos
La evidencia omite <code>effectiveUri</code> por defecto	Cierra la reconstrucción del secreto por vía secundaria
Los verificadores offline fallan ante una regresión de contrato	Convierten decisiones documentales en gates ejecutables
Los límites se declaran como datos, no como prosa	<code>limitations</code> viaja en el JSON
El código explica por qué , no qué	Los comentarios documentan decisiones, no líneas

16 · Glosario

Definiciones pensadas para que las entienda alguien sin formación técnica, con la precisión suficiente para que sirvan a quien sí la tiene.

Conceptos del producto

Hallazgo (*finding*) : Un hecho que la aplicación observó de verdad en el contenido de un código. Por ejemplo: «la dirección usa una conexión sin cifrar». No es una acusación ni una opinión: es algo comprobable mirando la carga. Cada hallazgo tiene un identificador estable, una severidad, un peso y los datos concretos que lo sustentan.

Hipótesis : Una explicación posible de por qué varios hallazgos aparecen juntos. Por ejemplo: «podría ser un intento de suplantación». Requiere investigación humana y **nunca** se convierte en certeza. Las hipótesis no suman puntos.

Evidencia : Los datos mínimos que respaldan un hallazgo: el host observado, el puerto, la extensión del archivo. También, en otro sentido, el **paquete de evidencia**: el archivo JSON que se puede compartir.

Paquete de evidencia : Archivo JSON exportable con lo que se observó de un código. Por defecto **no contiene la dirección ni el contenido**: lleva una huella digital, los identificadores de lo observado y la lista de lo que no se pudo comprobar. Sirve para pedir ayuda sin reenviar el secreto que el código llevaba dentro.

Decisión de acción : Lo que la aplicación permite hacer con el contenido. Cuatro valores: *permitir*, *confirmar*, *solo inspeccionar* y *bloquear*. Bloquear no significa «esto es malicioso»: significa «no puedo entregar esto a otra aplicación sin ambigüedad».

Severidad : La gravedad del hallazgo más grave. Tres niveles: normal, advertencia y crítico. **No** se calcula a partir del puntaje.

Puntaje : Una suma de pesos, acotada a 100. Sirve para ordenar y comparar casos. **No es una probabilidad de fraude**.

Límite (*limitation*) : Algo que la aplicación **no puede** saber sin conexión: la reputación de un sitio, quién es su dueño, qué certificado servirá. Se declara siempre, y nunca se convierte en «sin riesgo».

Carga (*payload*) : El contenido que hay dentro del código, tal como se leyó. Puede ser una dirección web, una red Wi-Fi, un contacto, una instrucción de pago o datos que no se pueden interpretar.

Superficie observable : La parte del mundo que un producto RootCause puede mirar. Aquí es «el contenido codificado en un código gráfico», no el dispositivo entero ni la red.

Sensor de apoyo a la decisión : Cómo se define este producto. No decide por la persona ni bloquea amenazas: le muestra lo que hay para que decida con información.

Conceptos técnicos

AES-256-GCM : El método de cifrado que protege lo guardado. Además de ocultar el contenido, detecta si alguien lo modificó: al descifrar, un archivo alterado se rechaza en lugar de devolver datos falsos.

Base de datos embebida : Una base de datos que vive dentro de la aplicación, en un archivo del propio teléfono. No hay servidor, ni contraseña, ni conexión.

Checksum · SHA-256 : Una «huella digital» de un archivo o un texto: una cadena de 64 caracteres que cambia por completo si cambia un solo byte. Sirve para comprobar que algo no se modificó. **No** dice quién lo creó.

Cifrado autenticado : Cifrado que, además de ocultar, garantiza que el contenido no se alteró.

Compilación condicional : Técnica para que un mismo código use una implementación distinta según la plataforma. Aquí decide si la base de datos es un archivo o el almacén del navegador.

Función pura : Una función que, con las mismas entradas, devuelve siempre lo mismo, y no toca nada fuera de sí misma. El motor de reglas lo es, y por eso puede probarse sin teléfono.

Idempotente : Que se puede repetir sin cambiar el resultado. Las migraciones lo son: ejecutarlas dos veces equivale a ejecutarlas una.

Lockfile : Archivo que fija la versión exacta de cada dependencia, incluidas las indirectas. Garantiza que dos compilaciones del mismo código usen lo mismo.

Sobre cifrado (*envelope*) : El paquete que envuelve un dato cifrado: versión del formato, algoritmo, identificador de la llave, instante, y el contenido cifrado con su marca de integridad.

Transacción : Un conjunto de cambios que ocurren todos o ninguno. Si algo falla a mitad, todo vuelve al estado anterior.

SBOM : *Software Bill of Materials*: la lista de todos los componentes de terceros que usa el programa, con su versión. Sirve para saber si un aviso de seguridad afecta al producto.

Isolate : En Dart, un hilo de ejecución con memoria propia. Aquí se usa para generar CSV y Excel sin congelar la pantalla.

Términos de códigos y contenido

QR · Código de barras · Simbología : Un QR es un código de dos dimensiones. Un código de barras clásico es de una. *Simbología* es el nombre del formato concreto: QR Code, Data Matrix, Aztec, PDF417, EAN-13, Code 128...

Punycode : Forma de escribir dominios con caracteres no latinos usando solo letras inglesas; empiezan por xn- . Es legítimo, pero permite crear nombres que **se ven** casi idénticos a los de otra marca.

Alfabetos mezclados (*mixed script*) : Un dominio que combina letras de alfabetos distintos —latino, cirílico, griego— para imitar visualmente otro nombre. La «■» cirílica y la «a» latina se ven iguales.

Userinfo : La parte de una dirección que va antes de @. En `https://banco.example@evil.example`, el destino real es `evil.example`, aunque a primera vista parezca lo contrario.

Acortador : Un servicio que convierte una dirección larga en una corta. Oculta el destino final hasta que se abre.

Redirección anidada : Una dirección que lleva otra dentro, en uno de sus parámetros. La visible puede ser conocida y la escondida, no.

Autoridad : La parte de una dirección que identifica el destino: usuario, host y puerto.

URI · URL · Esquema : Una URI identifica un recurso; una URL es una URI que además dice cómo llegar. El *esquema* es lo que va antes de los dos puntos: `https`, `mailto`, `wifi`, `otpauth`.

OTP : *One-Time Password*. Los códigos de seis dígitos que cambian cada 30 segundos. Un QR `otpauth`: contiene la **semilla** que los genera: quien la tenga puede generarlos todos.

vCard · MeCard : Formatos de tarjeta de contacto dentro de un código.

GS1 · GTIN · SSCC : Estándares de identificación de productos y logística. GTIN es el número que identifica un producto; SSCC, una unidad de envío.

EMVCo · EPC/SEPA · Swiss QR : Formatos de QR de pago: interoperable internacional, europeo de transferencia y suizo de factura.

AAMVA : Formato de los datos de una licencia de conducir estadounidense, normalmente en un PDF417.

Carga binaria : Contenido que no es texto y no se puede interpretar. La aplicación lo declara opaco: opacidad no equivale a malicia.

Estados y roles

Fases de la cámara : Preparando (arrancando), Inspección activa (analizando), Código leído (acaba de capturar), Inspección en pausa (detenida por la persona) y Sensor no disponible (no pudo arrancar).

Modo temporal : Arranque de emergencia que usa una base en memoria y una llave que no se guarda. Nada sobrevive al cierre. Aparece cuando el almacenamiento normal falla.

Modo privado : Preferencia que impide guardar cualquier lectura mientras está activa.

Registro aislado : Un registro que no se pudo descifrar. Se aparta para que no impida leer los demás, y **nunca** se borra solo.

Rotación de llave : Cambiar la llave de cifrado y volver a cifrar todo con la nueva, en una sola operación que o se completa entera o no ocurre.

Contenido sensible : Contraseñas Wi-Fi, semillas OTP, datos de pago, documentos de identidad y direcciones con secretos. Se muestran pero **no se guardan**.

Términos del proyecto y del proceso

RootCause : La familia de productos a la que pertenece esta aplicación, organizada por superficie observable, no por tipo de amenaza.

Universal Code Scanner : El proyecto del que procede el subsistema de lectura, interpretación, cifrado e inventario. La procedencia se conserva documentada.

Bootstrap : Aquí, `tool/bootstrap.py`: el script que genera las carpetas de Android, iOS y web, y les aplica los ajustes necesarios. También, el arranque de la aplicación.

Gate : Una comprobación que debe pasar antes de continuar. Si falla, se detiene la publicación.

CI : *Integración continua*. Comprobaciones automáticas que se ejecutan en servidores de GitHub cada vez que cambia el código.

Fixture : Un caso de prueba con datos preparados y un resultado esperado.

Deriva de versión (drift) : Que la versión mostrada, la construida y la documentada dejen de coincidir. El repositorio tiene una comprobación específica para impedirlo.

Telemetría cero : Que la aplicación no envía absolutamente ninguna información sobre su uso.

Redacción (redaction) : Quitar deliberadamente información de un documento antes de compartirlo. Aquí, la carga y la dirección efectiva se omiten del paquete de evidencia.

Entrada no confiable : Cualquier dato que venga de fuera y pueda estar manipulado. Los respaldos importados se tratan así: todo campo calculado se vuelve a calcular.

17 · Resumen ejecutivo

RootCause QR Inspector · versión 0.1.1 · análisis del 26 de agosto de 2026, commit a7ebf2c.

Qué es

Una aplicación móvil Android que **inspecciona códigos QR antes de abrirlos**. En lugar de llevar a la persona al destino y avisarle después, muestra qué hay dentro del código, explica qué señales de riesgo observó y solo entonces ofrece —o niega— una acción.

Todo el análisis ocurre en el teléfono. No hay servidor, cuentas, publicidad ni estadísticas de uso.

Qué necesidad cubre

Un QR es una instrucción que nadie puede leer a simple vista. Esa opacidad es justo lo que aprovecha el fraude: una pegatina sobre el QR de un parquímetro, un cartel con un cobro falso, un mensaje con un enlace que imita al del banco. Los lectores habituales del teléfono abren el destino primero y explican después.

Este producto invierte el orden. Su promesa es acotada y verificable: **reduce la opacidad**. No promete detectar fraude ni certificar que un sitio sea seguro, y lo dice explícitamente cada vez que no encuentra nada.

Quién lo utiliza

Perfil	Uso
Persona ante un QR dudoso	Verlo antes de abrirlo
Equipo de seguridad o soporte	Documentar un caso con evidencia compartible
Operación de almacén	Contar inventario leyendo códigos de producto
Organización con marca propia	Detectar su nombre usado fuera de sus dominios

Capacidades principales

- lectura con cámara, desde imágenes o desde un PDF por lotes;
- interpretación de 17 familias de contenido: enlaces, Wi-Fi, contactos, eventos, OTP, pagos, criptomonedas, códigos de producto, documentos;
- **26 comprobaciones locales** que producen hechos con su evidencia;
- separación explícita entre hecho observado e hipótesis;
- decisión de acción en cuatro niveles, con bloqueo de direcciones ambiguas;
- **evidencia exportable** que no incluye el enlace ni el secreto;
- historial e inventario cifrados en el dispositivo;
- generador de códigos y centro de recuperación de datos.

Tecnologías

Flutter 3.44.7 y Dart. Base de datos embebida Sembast, cifrado AES-256-GCM con la llave en el almacén seguro del sistema. Integración continua en GitHub Actions. Licencia MIT.

Escala del código: 65 archivos fuente, unas 9 600 líneas, 88 casos de prueba, 13 herramientas de automatización, 36 documentos.

Arquitectura, en una idea

El motor de análisis **no depende de Flutter**: recibe un texto y devuelve un objeto. Esa decisión permite probarlo sin dispositivo, comparar resultados entre versiones y, en el futuro, reutilizarlo desde otro producto. Todo lo demás —pantalla, base de datos, exportación— son proyecciones de ese núcleo.

Estado actual

Aspecto	Estado
Código fuente	Completo y coherente; verificadores automáticos en verde
Integración continua	Verde: análisis estricto, 87 pruebas y tres compilaciones
Distribución Android	Publicada: APK con SHA-256 y atestación de procedencia
Firma de tienda	Pendiente: se firma con la clave de depuración de Flutter
iOS	Compila para simulador; sin paquete instalable ni firma
Validación en dispositivo físico	Pendiente: la matriz no tiene ninguna fila registrada
Auditoría de seguridad independiente	No realizada

La versión 0.1.1 corrige tres fallos de interacción reportados en uso real: una lectura conseguida no se distinguía de que no ocurriera nada; un código legible pero lejano no se leía; y volver a apuntar al mismo código no producía ningún efecto. Las tres causas están documentadas con su corrección.

Fortalezas

1. **La promesa es verificable.** Cada afirmación del producto apunta a código, prueba o documento. Lo pendiente se declara como pendiente.
2. **Privacidad real, no declarativa.** Sin red no hay nada que auditar: la ausencia de telemetría es estructural.
3. **Disciplina de datos poco común.** Un registro ilegible se aísla en vez de borrarse; una llave ausente nunca se recrea; una migración verifica antes de borrar el origen; un respaldo importado no puede imponer un veredicto.
4. **Contratos ejecutables.** Dos verificadores fallan si una regla queda huérfana entre el motor, el esquema, los textos y la documentación. Las decisiones documentales son gates, no buenas intenciones.
5. **Honestidad como control de calidad.** La aplicación se niega a decir «seguro», y hay una prueba que impide quitar esa frase.

Riesgos

Riesgo	Severidad	Consecuencia
Los 12 casos de regresión existen pero ninguna prueba los ejecuta	Alta	Un cambio de regla puede pasar el gate sin que se note

La migración de datos heredados no tiene prueba propia	Alta	Es el procedimiento con más riesgo de pérdida
Los contactos de una vCard se guardan sin marcarse sensibles	Alta	Datos personales de terceros conservados sin decisión explícita
La corrección de lectura no se ha probado en un teléfono real	Alta	La mejora podría no funcionar, o calentar la gama baja
La evidencia lleva checksum, no firma	Alta	No acredita autoría frente a un adversario
Sin validación en dispositivos físicos	Alta	Cámara, biometría y almacenamiento sin confirmar
APK firmado con clave de depuración	Alta	No apto para tienda; complica la actualización
Dos dependencias ancladas por un conflicto	Media	Un aviso de seguridad exigiría resolverlo antes
Un solo mantenedor	Media	Factor bus de uno

Ninguno es crítico. Todos están documentados en [15-risks-and-technical-debt.md](#) con su recomendación.

Oportunidades de mejora

Coste bajo, valor alto

1. Ejecutar los 12 fixtures contra el motor en una prueba automática.
2. Cubrir la migración de datos heredados con pruebas.
3. Decidir explícitamente qué hacer con los contactos.

Coste medio

4. Ejecutar la matriz de dispositivos en al menos dos teléfonos.
5. Unificar el inventario con la abstracción del escáner, para no tener que corregir dos veces cada fallo de cámara.
6. Umbral de cobertura en CI.

Decisiones de producto

7. Firma comercial y publicación en tienda.
8. Firma criptográfica de la evidencia.
9. Completar la traducción para abrir el producto a más idiomas.
10. Pantalla de administración de la política de marcas, que hoy solo existe como API.

Próximos pasos recomendados

Plazo	Acción	Por qué
Inmediato	Prueba de los fixtures y de la migración	Cierra las dos brechas de mayor riesgo con esfuerzo bajo

Inmediato	Probar la corrección de lectura en dos teléfonos	Confirma o refuta la mejora que motivó la versión
Corto	Decisión sobre los contactos	Es una cuestión de privacidad, no técnica
Corto	Escaneo de vulnerabilidades sobre el SBOM	El inventario ya existe; falta usarlo
Medio	Matriz de dispositivos completa	Requisito declarado antes de una tienda
Medio	Firma comercial y App Bundle	Habilita la distribución masiva
Largo	Auditoría independiente	Necesaria antes de presentar el producto como herramienta de seguridad

Conclusión

El repositorio está por encima de la media en algo que suele fallar: **la distancia entre lo que un producto dice de sí mismo y lo que hace**. Aquí esa distancia es corta y está medida. Las carencias son de *validación* —dispositivos físicos, firma, auditoría— más que de *construcción*.

Para un uso profesional serio, el orden recomendado es: cerrar las dos brechas de prueba, validar en hardware, y solo entonces plantear la distribución en tienda.

18 · Guía para un nuevo desarrollador

Escrita para alguien que llega hoy al proyecto y quiere ser útil esta semana.

Antes de nada: qué NO es este proyecto

Aclararlo primero ahorra malentendidos:

- **no es un lector de QR con una advertencia añadida.** Es un sensor que explica antes de permitir actuar. Si una propuesta acelera la lectura a costa de la explicación, va contra el producto;
- **no tiene servidor.** No hay API que consumir ni backend que desplegar;
- **no puede decir «seguro».** Hay una prueba y un verificador que lo impiden;
- **no envía nada.** Cualquier llamada de red sería un cambio de contrato, no una funcionalidad.

Qué leer primero

En este orden. Unas tres horas en total.

Orden	Documento	Tiempo	Para qué
1	../../README.md	15 min	Qué promete el producto
2	01-system-overview.md	20 min	Qué hace y qué no
3	03-architecture.md	30 min	Cómo está organizado
4	../rootcause/HEURISTICS.md	30 min	Las 26 reglas, que son el producto
5	06-deep-code-explanation.md	45 min	Por qué el código es así
6	../quality/COMPATIBILITY-CONTRACT.md	15 min	Qué no se puede romper
7	15-risks-and-technical-debt.md	20 min	Qué ya se sabe que está flojo

Preparar el entorno

```
git clone https://github.com/vladimiracunadev-create/rootcause-qr-inspector.git
cd rootcause-qr-inspector
flutter --version      # debe ser 3.44.7
python --version       # 3.12
flutter pub get
python tool/bootstrap.py --platforms android,web
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py
flutter analyze --fatal-infos
flutter test
```

Si los siete comandos pasan, el entorno está listo.

La sorpresa habitual: android/, ios/ y web/ **no están en el repositorio.** Los genera el bootstrap. No las edites a mano: cualquier cambio ahí se pierde en la siguiente generación. Los ajustes de plataforma viven en tool/bootstrap.py.

Ejecutar

```
flutter run          # dispositivo o emulador
flutter run -d chrome # demo web: sin PDF ni almacén seguro
```

Cómo está organizado el repositorio

```
lib/
■■■ main.dart           punto de entrada
■■■ bootstrap*.dart     composición y arranque seguro
■■■ app.dart            tema, bloqueo y navegación
■■■ core/               infraestructura transversal
■   ■■■ investigation/ ← EL PRODUCTO ESTÁ AQUÍ
■   ■■■ security/       cifrado, rotación, adaptador de riesgo
■   ■■■ database/       Sembast y migraciones
■   ■■■ recovery/       aislamiento de registros
■   ■■■ ...             rendimiento, tema, idioma, diagnóstico
■■■ models/             entidades inmutables
■■■ services/            intérprete, repositorios, import/export, plataforma
■■■ state/              tres stores ChangeNotifier
■■■ features/           una carpeta por caso de uso

test/                   88 casos
tool/                   13 herramientas Python y shell
docs/                   36 documentos
fixtures/ test_assets/  datos de regresión
```

Si solo puedes mirar una carpeta, que sea `lib/core/investigation/`.

Seguir un flujo completo

Recorre esta cadena con el editor abierto; es la columna vertebral del sistema:

1. `lib/features/scanner/scanner_screen.dart` → `_handleCapture`
2. `lib/models/scan_record.dart` → `ScanRecord.fromBarcode`
3. `lib/services/content_interpreter.dart` → `ContentInterpreter.parse`
4. `lib/core/investigation/qr_investigation_engine.dart` → `analyze`
5. `lib/features/result/scan_result_sheet.dart` → `ScanRecordCard`
6. `lib/state/scan_store.dart` → `addAll`
7. `lib/services/history_repository.dart` → `upsertAll`
8. `lib/core/security/payload_cipher.dart` → `encryptJson`

Ocho archivos. Después de recorrerlos entiendes el 80 % del sistema.

Para verlo en marcha sin cámara:

```
flutter test test/core/qr_investigation_engine_test.dart
```

Dónde añadir cada cosa

Quiero...	Va en...	Y además debo...
Una regla nueva	<code>qr_investigation_engine.dart</code>	Ver la lista de siete pasos más abajo
Interpretar un formato nuevo	<code>ContentParser</code> + registro	Decidir su <code>sensitive</code> y probarlo

Una pantalla nueva	<code>lib/features/<caso>/</code>	Pasar las dependencias por constructor
Un campo persistente	El modelo + <code>toJson/fromJson</code>	Comprobar que un JSON antiguo sigue leyéndose
Un ajuste nuevo	<code>AppSettings + SettingsRepository</code> + pantalla	Elegir un valor por defecto conservador
Un límite de rendimiento	Donde se usa, como constante nombrada	Documentarlo en <code>PERFORMANCE.md</code>
Un texto visible	Por ahora, literal en la pantalla	Idealmente, <code>AppLocalizations</code>

Añadir una regla: los siete pasos

Una regla no está terminada hasta que **los siete** están en el mismo cambio:

1. `qr_investigation_engine.dart`: `evaluate('mi-regla')` y su `add(...)`;
2. `qr_finding_text.dart`: título, explicación y recomendación;
3. `schemas/rootcause-qr-evidence.schema.json`: el id en `$defs.findingId.enum`;
4. `docs/rootcause/HEURISTICS.md`: fila en la tabla, con el id entre acentos graves;
5. `fixtures/qr/manifest.json`: un caso sintético con dominio reservado;
6. `test/core/qr_investigation_engine_test.dart`: prueba positiva y, si hay excepción legítima, negativa;
7. `QrInvestigationEngine.engineVersion`: subirla.

`python tool/verify_rootcause_contract.py` falla si olvidas cualquiera de los cuatro primeros. Y recuerda actualizar el número «26» donde aparezca.

Crear pruebas

Convenciones observadas en el repositorio:

```
test('descripción en la lengua del archivo, en presente', () {
  // Arrange: el mínimo necesario
  // Act: una sola acción
  // Assert: una propiedad, no muchas
});
```

- los nombres describen **la propiedad**, no la función: «un respaldo no puede inyectar un veredicto», no «prueba de fromJson»;
- los comentarios explican **por qué** existe el caso;
- para la base de datos, `AppDatabase.openTemporary()` con `MemoryEncryptionKeyProvider`, y `addTearDown(database.close)`;
- en widgets con temporizadores reales, `tester.runAsync` y nunca `pumpAndSettle` sobre algo que anima siempre;
- fechas fijas (`DateTime.utc(2026, 8, 20)`) para que el resultado sea determinista.

Qué requiere especial cuidado

Ordenado por consecuencia si se rompe.

1. Nunca hagas que el descifrado cree una llave

```
final SecretKey? key = await _keyProvider.read(keyId);    // correcto
// await _keyProvider.readOrCreate(...)                // JAMÁS al descifrar
```

Crearía una llave nueva y dejaría **todos** los registros anteriores ilegibles, en silencio y para siempre.

2. Nunca borres el origen antes de verificar el destino

La migración escribe, **comprueba dentro de la misma transacción** y solo después borra. Invertir ese orden es pérdida de datos irreversible.

3. Nunca confíes en un campo derivado de un archivo

```
ScanRecord.fromJson(map, trustDerivedAnalysis: false)    // en importación
```

Sin ese `false`, un respaldo manipulado puede declararse `allow` y la interfaz lo mostrará como tal.

4. Nunca quites la eliminación de `effectiveUri`

Omitir `rawPayload` no basta: `effectiveUri` lleva la misma consulta y el mismo token. Es lo que separa un paquete redactado de una filtración.

5. Nunca elimines la frase de resultado normal

«No se observaron señales locales. Esto no demuestra que el destino sea seguro.»

`verify_rootcause_contract.py` falla si desaparece de la interfaz.

6. Cuidado con el ciclo de vida de la cámara

`MobileScanner` solo lo gestiona si él crea el controlador. Aquí lo crean las pantallas, así que **ellas** deben observar `didChangeAppLifecycleState`. Al reiniciar: parar, desechar y **solo entonces** crear el nuevo, porque ambos comparten una única sesión de cámara.

7. Cuidado con los `switch` sobre enumeraciones

Dart exige exhaustividad. Añadir un valor a `ScanPhase` o a `ContentKind` obliga a revisar cada `switch`, y son varios repartidos por las pantallas.

8. La versión vive en dos sitios que deben coincidir

`pubspec.yaml` y `lib/core/app_info.dart`. El validador falla si divergen.

Convenciones del código

Convención	Detalle
Tipos explícitos	<code>final String x = ..., <Widget>[...]</code> . Es el estilo dominante
<code>final</code> en locales	Lint <code>prefer_final_locals</code>
Sin <code>print</code>	Lint <code>avoid_print</code> ; además, podría filtrar una carga

unawaited() explícito	Cuando un futuro no se espera a propósito
on Object catch	Con un comentario que explique por qué se ignora
Comentarios de por qué	No describas la línea: explica la decisión
Documentación en la declaración	/// sobre clases y métodos públicos
Textos visibles en español	La interfaz es monolingüe hoy
Idioma de los comentarios	Conviven español e inglés; sigue el del archivo que tocas

Convenciones de Git

- **una rama por cambio**, con un solo tema;
- mensajes con tipo(ámbito): resumen y un cuerpo que explique la **causa**;
- **nunca git add -A**: rutas explícitas, para no colar artefactos ni datos;
- CHANGELOG.md si el cambio es visible;
- describe qué comandos ejecutaste, y no afirmes que algo pasa sin haberlo visto pasar.

Antes de abrir un pull request

```
python tool/validate_structure.py --require-lock
python tool/verify_rootcause_contract.py
flutter analyze --fatal-infos
flutter test
```

Si tocaste una regla, además:

```
flutter test test/core/qr_investigation_engine_test.dart
flutter test test/core/qr_evidence_exporter_test.dart
```

Itinerario sugerido

Día 1 — leer

Los siete documentos de la lista, y recorre los ocho archivos del flujo principal sin cambiar nada.

Día 2 — ejecutar

Levanta la aplicación, escanea un QR de <https://example.com> desde el generador, mira el resultado, exporta la evidencia y **léela**. Rompe algo a propósito —cambia el peso de una regla— y observa cuál de los gates te lo dice.

Día 3 — cambiar algo pequeño

Elige una tarea de la lista de abajo. Hazla completa: código, prueba, documentación.

Semana 1 — una regla nueva

Propón una regla, discútela y complétala con sus siete pasos. Al terminar, entiendes el producto.

Semana 2 — un módulo entero

Toma un área con poca cobertura —repositorios, recuperación— y añade pruebas. Aprenderás más leyendo para probar que leyendo para leer.

Tareas apropiadas para empezar

Ordenadas de menor a mayor dificultad. Las tres primeras cierran hallazgos reales del informe de riesgos.

#	Tarea	Dificultad	Cierra
1	Prueba que ejecute los 12 fixtures contra el motor y compare severidad, acción, <code>mustInclude</code> y <code>mustExclude</code>	Baja	R-01 , el hallazgo de mayor valor
2	Pruebas de <code>SettingsRepository</code> : valores por defecto y <code>resetNonSensitive</code>	Baja	Cobertura
3	Aplicar la ocultación de sensibles también en la lista del historial	Baja	R-10
4	Pruebas de <code>ContentInterpreter</code> para AAMVA, Swiss QR y EPC	Media	Cobertura de <code>sensitive</code>
5	Pruebas de la migración del historial heredado	Media	R-02
6	Migrar el inventario a <code>MobileScannerEngine</code>	Media	R-08
7	Extraer el filtro de repetición y la decisión de persistencia a funciones puras, y probarlas	Media	R-06
8	Migrar las cadenas de una pantalla a <code>AppLocalizations</code>	Media	R-13

A quién preguntar

Un solo mantenedor: [Vladimir Acuña](#). Para vulnerabilidades, el canal privado de `../../SECURITY.md`, sin adjuntar datos reales.

Errores que ya cometió alguien

Están documentados para que no se repitan:

Error	Dónde se cuenta
Fijar la ventana de lectura con un umbral que impedía recalcularla	<code>../quality/SCANNER_UX.md</code> §1

Dejar el ciclo de vida de la cámara sin atender	Íd.
Usar el sonido del sistema, que el usuario suele tener apagado	Íd. §3
Anunciar una lectura conseguida con el texto de «en pausa»	Íd. §6
Usar el marco como filtro y descartar códigos en silencio	Íd. §6
Dejar la resolución de cámara sin declarar: Android cae a 640×480	Íd. §6
Mostrar en la interfaz una versión distinta de la construida	<code>check_interface_version</code>
Sustituir un import por otro que no reexporta el mismo tipo	14-troubleshooting.md

Todos comparten un patrón: **un fallo silencioso es peor que uno ruidoso**. Si tu cambio puede hacer que algo no ocurra, haz que la aplicación lo diga.

19 · Matriz de trazabilidad

Permite seguir una funcionalidad desde la interfaz hasta el dato y su prueba.

Estado de validación: ■ cubierto por prueba automática · ■ parcial · ■ sin prueba · ■ requiere dispositivo

Funcionalidades principales

#	Funcionalidad	Regla de negocio	Interfaz	Módulo	Clase / función	Persistencia	Prueba	Documento	Estado
F-01	Leer un código con la cámara	Ninguna carga se ejecuta al detectarla	ScannerScr	features/	s_handleCapture		—	06	■
F-02	La lectura cubre toda la imagen	El marco es guía, no filtro	ScannerScr	features/	sMobileScanner sin scanWindow		scanner_er (config)	SCANNER_UX	■ test
F-03	Alcanzar un código lejano	Declarar la resolución en vez de aceptar 640×480	—	features/	sinspectionResolution		scanner_er	SCANNER_UX	■ test
F-04	Confirmar una captura	Una lectura conseguida no se anuncia como pausa	ScanStatus	features/	sScanPhase.captured		scan_stat	SCANNER_UX	■
F-05	Tono y vibración	Nunca pueden romper una lectura	—	services	ScanFeedback.succes		scan_feedback (6)	back_test	■
F-06	Releer el mismo código	La repetición se explica, no se silencia	ScannerScr	features/	s_repeatWindow, _showRepeatNotice		■	SCANNER_UX	■
F-07	Interpretar el contenido	17 familias reconocidas	ScanRecord	services	ContentIntparsed.er		content_interpreter (6 de 17)	■ test	■

F-08	Analizar con 26 reglas	Hechos, nunca veredictos	<code>_RiskBannecore/investigation</code>	<code>Investigation</code>	<code>investigator</code>	<code>qr_investigation</code> (13)	HEURISTICS	line_test
F-09	Separar hipótesis de hechos	Las hipótesis no suman puntos	<code>_RiskBannecore/investigation</code>	<code>Investigation</code>	<code>hypotheses</code>	<code>qr_investigation</code>	HEURISTICS	line_test
F-10	Decidir la acción	block retira el botón; confirm exige diálogo	<code>ScanRecordcore/investigation</code>	<code>QrActionDeverdict</code>	<code>action</code>	03 interfaz; <code>verify_rootcause_contract</code> la comprueba por texto		■
F-11	Declarar los límites	Un dato ausente nunca es favorable	<code>_RiskBannecore/investigation</code>	<code>limitation</code>	<code>limitation</code>	<code>qr_investigation</code>	LIMITATION	ne_test
F-12	Frase de resultado normal	No se puede eliminar	<code>_RiskBannecore/features/normal</code>	<code>normal</code>	—	<code>verify_rootcause_contract</code>	LIMITATION	tract
F-13	Exportar evidencia redactada	Sin carga ni URL efectiva	Botón «Evidencia»	<code>core/investigation</code>	<code>QrEvidenceExport</code>	<code>qr_evidence_export</code> (4)	09	■ test
F-14	Verificar una evidencia	Checksum canónico, no firma	—	<code>core/investigation</code>	<code>verify_on_canonicalJson</code>	<code>qr_evidence_export</code>	09	■ test
F-15	No persistir lo sensible	OTP, Wi-Fi, pago e identidad fuera del historial	—	<code>features/s_persist</code>	<code>Arscan_history</code>	08 en la pantalla; <code>scan_record_test</code> cubre la clasificación		■
F-16	Cifrar lo persistente	AES-256-GCM por registro	—	<code>core/securePayloadCipher</code>	<code>payload:ryppayload_cipher</code>	(5)		■
F-17	No recrear una llave ausente	Evita pérdida irreversible	Centro de recuperación	<code>core/securePayloadCipher</code>	<code>decryptJson</code> con read	<code>payload_cipher_test</code>		■
F-18	Aislar un registro ilegible	Nunca se borra solo	Centro de recuperación	<code>services + core/recovery</code>	<code>HistoryRecoveryIssues</code>	11	RECOVERY	■
F-19	Recuperar o descartar	Solo el registro afectado	<code>RecoveryScore/recovery</code>	<code>retry, discard</code>	Ambos almacenes	■ (solo <code>exportBundle</code>)	RECOVERY	■

F-20	Paquete de recuperación sin llave	El texto cifrado se conserva	RecoveryScore/recoverexportBundle	Archivo	recovery_service_test	■		■
F-21	Rotar la llave	Todo o nada, sin llave huérfana	SettingsScore/securerotateEncryptionKey	data_maintenance_test	■			■
F-22	Migrar el esquema	Idempotente y transaccional	—	core/dataSchemaMigr_schema_meschema_migrator_test	■			■
F-23	Migrar el historial heredado	Verificar antes de borrar el origen	Ajustes → reintentar	services	_migrateLscan_history	■	MIGRATIONS	■
F-24	Importar sin confiar	Todo campo derivado se recalcula	HistoryScr	services	parseHistcsan_histcimport_service_test + (5) trustDerivedAnalysis: false	■		■
F-25	Vista previa de importación	Nada se escribe antes de elegir	Diálogo	services + state	HistoryImportPreviewimport_service_test	■		■
F-26	Exportar historial completo	Advertir que va en claro	HistoryScr	services	ExportService	■	08	■
F-27	Buscar y filtrar	En memoria, sobre lo descifrado	HistoryScr	features/history build	—	■	04	■
F-28	Notas y etiquetas	Se persisten cifradas	HistoryScr	state	ScanStore.payload	■	07	■
F-29	Retención del historial	0 significa sin límite	SettingsScr	services	pruneOlderscan_history	■	10	■
F-30	Límite de 5000	Se eliminan los más antiguos	—	services	_trim scan_history	■	07	■
F-31	Contar inventario	Cada lectura suma una unidad	InventoryScr	state	InventoryInventory_inventory_session_test (modelo)	■		■

F-32	Contar unidades repetidas	Diez cajas iguales son diez unidades	InventorySfeatures/i_onDetect	inventory_sessions	SCANNER_UX	■ ■
F-33	Serializar escrituras	Sin carreras entre cámara y edición	—	core/perfAsyncWriteQueue.run async_write_queue_test (2)		
F-34	Cerrar y reabrir sesión	Cerrada no acepta lecturas	InventorySstate	closeActiveInventorySessions reopenSession	04	■
F-35	Generar códigos	Sin enviar datos a un servidor	GeneratorSfeatures/c_payload, —	_barcode	■	04 ■
F-36	Leer imágenes por lotes	Máximo 20, cancelable	ScannerScrfeatures/s_scanFromGallery		■	PERFORMANCE ■
F-37	Leer páginas de PDF	Máximo 50, con limpieza	ScannerScrservices	PdfPageRenderTemporaryAndRender	PERFORMANCE	■
F-38	Cancelar un lote	Sin modificar el historial	Diálogo	core/perfCancellationToken	cancellation_token_test (2)	
F-39	Bloqueo de la aplicación	Se rebloquea al perder el primer plano	BiometricIapp.dart	didChangeAppLifecycleState	11	■ ■
F-40	Arranque seguro	Cuatro salidas ante un fallo	_StartupReobootstrap_StartupFailure.from app_launcher		05	■ ■
F-41	Modo temporal	Nada sobrevive al cierre	Banner	bootstrap.openTemporaryMemory + llave en memoria	Usado en varias pruebas	06 ■
F-42	Diagnóstico privado	Sin mensajes ni cargas	RecoveryScore/diagAppDiagnosticMemoryexposediagnostics		11	■
F-43	Copiar con borrado	Confirmación si es sensible	ScanRecordscservices	ClipboardService	11	■

F-44	Ocultar valores sensibles	Puntos en vez del valor	ScanRecord.features/rconceal	—	■	11	■
F-45	Accesibilidad	Contraste, tamaño táctil, movimiento	SettingsScore/themeAppTheme	Preferencias	accessibi	ACCESSIBILITY	■
F-46	Solo español	Ninguna interfaz a medio traducir	—	core/localization	Preferencias	localizati	ACCESSIBILITY
F-47	Marco de teléfono	No estirar en pantallas grandes	HandheldFrapp.dart	maxWidth = 560	—	handheld_frame_test	■
F-48	Marco sin solapes	Nunca bajo los controles	ScannerOverfeatures/ScannerViewportGeom	scanner_viewport_geometry_test	(3)	■	■
F-49	Política de marcas	Token fuera de dominio autorizado	Sin interfaz	core/investQrAnalysisPolicy	qr_investigation_engine_test	■	■
F-50	Extender el intérprete	Sin tocar el parser integrado	—	features/fContentParserRegistry	content_parser_registry_test	■	■

Reglas de negocio no negociables

Las que rompen el producto si desaparecen.

Id	Regla	Dónde se aplica	Quién la protege	Estado
RN-01	Ninguna carga se ejecuta al detectarla	Toda la aplicación	Revisión humana	■
RN-02	Un resultado normal no afirma que el destino sea seguro	_RiskBanner	verify_rootcause_contract	■
RN-03	Hallazgo e hipótesis son campos distintos	Contrato y esquema	Esquema + pruebas	■
RN-04	Las hipótesis no suman puntos	Motor	qr_investigation_engine_test	■
RN-05	La severidad es el máximo, no el puntaje	Motor	Íd.	■
RN-06	block retira la acción externa	ScanRecordCard	verify_rootcause_contract (por texto)	■

RN-07	confirm exige diálogo aunque la confirmación general esté apagada	Íd.	Íd.	■
RN-08	La evidencia omite carga, parseo y effectiveUri	Exportador	qr_evidence_exporte + verificador	■ test
RN-09	El checksum nunca se describe como firma	Exportador y documentación	assurance + verificador	■
RN-10	Un respaldo no puede imponer campos derivados	Importación	import_service_test + verificador	■
RN-11	Un registro sensible no se persiste	_persistAndShow	■ sin prueba	■
RN-12	Un registro ilegible se aísla, no se borra	Repositorios	■ sin prueba	■
RN-13	Una llave ausente no se recrea	PayloadCipher	payload_cipher_test	■
RN-14	La migración verifica antes de borrar el origen	HistoryRepository	■ sin prueba	■
RN-15	La huella cubre la carga exacta	Motor	qr_investigation_engine_test	
RN-16	Cambiar una regla obliga a subir engineVersion	Proceso	Revisión humana	■
RN-17	La lectura no descarta un código en silencio	ScannerScreen	■ sin prueba	■
RN-18	No hay telemetría	Toda la aplicación	Ausencia de dependencias de red	■

Resumen de cobertura

Estado	Funcionalidades	Reglas de negocio
■ Cubierto	21	10
■ Parcial	12	4
■ Sin prueba	17	4

Las cuatro reglas de negocio en rojo son la mayor deuda de calidad del repositorio. Tres de ellas —RN-11, RN-12 y RN-14— protegen datos de la persona; la cuarta, RN-17, es la que motivó la versión 0.1.1. Ver [15-risks-and-technical-debt.md](#) y la propuesta priorizada de [12-testing-and-quality.md](#).

De la interfaz al dato: dos ejemplos completos

Inspeccionar un QR y guardarlo

```
ScannerScreen (pestaña «Escanear»)
  ■■ MobileScanner.onDetect
    ■■ _handleCapture
      ■■ ScanRecord.fromBarcode
        ■■ ContentParserRegistry.parse → ParsedContent (decide `sensitive`)
        ■■ ScanSecurityAnalyzer.analyze
          ■■ QrInvestigationEngine.analyze → QrInvestigation
      ■■ _persistAndShow
        ■■ filtro: !isSensitive ← RN-11
        ■■ ScanStore.addAll
        ■■ HistoryRepository.upsertAll
        ■■ PayloadCipher.encryptJson ← AES-256-GCM
        ■■ store `scan_history`, campo `payload`
      ■■ ScanResultsSheet → ScanRecordCard
        ■■ _RiskBanner hallazgos, hipótesis, límites ← RN-02
        ■■ acciones copiar · compartir · evidencia · abrir ← RN-06
```

Exportar evidencia de un caso

```
ScanRecordCard → botón «Evidencia»
  ■■ _shareEvidence
    ■■ QrEvidenceExporter.toJson(record) includeRawPayload = false
    ■■ toMap
      ■■ investigation.remove('effectiveUri') ← RN-08
      ■■ redaction = 'payload-omitted'
      ■■ _canonicalJson(content) claves ordenadas
      ■■ integrity.bundleHash = SHA-256(...) ← RN-09
    ■■ SharePlus → archivo rootcause-qr-evidence-<id>.json
```

Trazabilidad de la corrección 0.1.1

Síntoma reportado	Causa	Corrección	Prueba	Falta
Volver a apuntar al mismo código no hacía nada	DetectionSpeed.noDuplicates	DetectionSpeed.normal + filtro con aviso	scanner_engine_configuration_test	Figura completa en dispositivo
Un código legible no se leía	El marco filtraba como scanWindow	Detección en toda la vista previa	■	Confirmación en dispositivo
Un código lejano no se leía	Resolución sin declarar: 640×480	1920×1080 y 1280×720	scanner_engine_configuration_test	Figura real y consumo
Una captura parecía una pausa	Reutilizaba ScanPhase.paused	ScanPhase.captured	scan_status_bar_test	Captura de pantalla real
La confirmación llegaba tarde	Se esperaba el tono	warmUp + reproducción no bloqueante	scan_feedback_test	Latencia audible
El inventario no contaba repetidos	noDuplicates	Mismo cambio de detector	■	Diez unidades en dispositivo